



**INSTITUTO POLITÉCNICO
NACIONAL**
ESCUELA SUPERIOR DE
CÓMPUTO



Trabajo Terminal

2026-B136

**«Prototipo de un sistema web para la gestión
de expedientes digitales y actividad procesal de
un despacho legal, con servicios de integridad
y no repudio.»**

Presentan

Alonso Sánchez Eduardo
Vitales Herrera Hatziry

Directora

Sandra Díaz Santiago

Resumen

El presente protocolo plantea un prototipo de sistema web para la gestión de expedientes digitales y la actividad procesal de un despacho legal. El prototipo implementa los servicios criptográficos de *integridad*, orientado a detectar cualquier modificación no autorizada en los expedientes, y de *no repudio*, que impide que las partes involucradas nieguen su participación en la firma de contratos mediante evidencia criptográfica verificable. El prototipo se validará mediante pruebas funcionales y de usabilidad para verificar el correcto funcionamiento de los módulos y flujos principales.

Palabras clave: expedientes digitales, integridad, no repudio, firma digital, criptografía aplicada, gestión legal, CNPP.

Índice general

Resumen	I
1 Introducción	1
1.1 Problemática	1
1.2 Propuesta de solución	3
1.3 Objetivo	3
1.4 Justificación	5
1.5 Revisión de Plataformas de Gestión Legal	6
1.6 Alcances y Delimitaciones	8
1.7 Supuestos del Proyecto	9
2 Marco teórico	10
2.1 Seguridad de la Información en el Ámbito Jurídico	10
2.2 Sistema Legal Mexicano	11
2.3 Primitivas y Servicios Criptográficos	23
2.4 Gestión de Datos Híbrida	28
3 Análisis y diseño	29
3.1 Metodología	29
3.2 Historias de Usuario	31
3.3 Casos de Uso	35
3.4 Requerimientos del Sistema	67
3.5 Análisis de Costos	84
3.6 Análisis de Riesgos	88
3.7 Diseño de Arquitectura del Sistema	97
3.8 Modelado de Base de Datos Híbrida	114
3.9 Diagrama de Despliegue y Stack Tecnológico	115
3.10 Modelo de Datos Jurídico-Técnico	117
3.11 Diseño Criptográfico del Prototipo	117
4 Conclusiones y trabajo futuro	124
4.1 Resultados obtenidos	124
4.2 Contribuciones	124
4.3 Limitaciones	125
4.4 Trabajo futuro	125
Referencias	127
Glosario de Términos	134

A	Diagramas detallados de arquitectura	139
A.1	Vista detallada de Fronteras de Confianza	139
A.2	Arquitectura Hexagonal completa con puertos y adaptadores nombrados	140

Índice de figuras

3.1	Ciclo de la metodología XP (Extreme Programming) aplicada al proyecto.	30
3.2	Diagrama CU-01. Registro de despacho y selección de plan.	37
3.3	Diagrama CU-02. Gestión del ciclo de vida de miembros del equipo.	39
3.4	Diagrama CU-03. Inicio de sesión y gestión de sesiones.	41
3.5	Diagrama CU-04. Control de acceso por perfil.	43
3.6	Diagrama CU-05. Registro y administración de expediente penal.	45
3.7	Diagrama CU-06. Gestión del directorio de participantes.	47
3.8	Diagrama CU-07. Transición de etapa procesal.	49
3.9	Diagrama CU-08. Programación de audiencia y activación de plazos.	51
3.10	Diagrama CU-09. Configuración del calendario judicial.	52
3.11	Diagrama CU-10. Monitoreo de plazos y emisión de alertas.	54
3.12	Diagrama CU-11. Carga y clasificación de documentos.	56
3.13	Diagrama CU-12. Consulta de documentos con verificación de integridad.	58
3.14	Diagrama CU-13. Firma digital de contrato con sellado de tiempo.	60
3.15	Diagrama CU-14. Verificación de firma digital y sello de tiempo.	62
3.16	Diagrama CU-15. Consulta del tablero de control.	63
3.17	Diagrama CU-16. Generación de informes.	65
3.18	Diagrama CU-17. Consulta de bitácora de actividad.	66
3.19	Arquitectura Hexagonal: capas conceptuales y regla de dependencias. Las dependen- cias siempre apuntan hacia el dominio.	102
3.20	Vista de componentes: siete contextos limitados del sistema y sus dependencias principales.	103
3.21	Estructura del workspace de Cargo: cinco crates miembros con dependencias permiti- das (flechas negras) y prohibidas (flechas rojas punteadas).	105
3.22	Modelo de datos híbrido: PostgreSQL para datos persistentes con valor probatorio, Redis para datos volátiles.	115
3.23	Diagrama de despliegue: Astro+Svelte (cliente) → Axum/Rust (backend) → Post- greSQL + Redis + servicios externos.	116
A.1	Modelo de defensa en profundidad por capas y controles aplicados a cada cruce de frontera.	139
A.2	Arquitectura hexagonal completa: cada puerto es un trait de Rust en el crate domain; cada adaptador es una struct en el crate infrastructure.	140

Índice de tablas

1.1	Criterios de éxito por objetivo específico.	5
1.2	Resumen ampliado de productos similares (función, servicios y criptografía).	7
2.1	Comparación entre el sistema inquisitivo y el sistema acusatorio oral.	11
2.2	Sujetos procesales del CNPP y sus implicaciones en la gestión digital del expediente.	14
2.3	Términos fatales del proceso penal y su implicación para el módulo de alertas (RF-09, RF-10).	16
2.4	Principales PSC acreditados por la Secretaría de Economía relevantes para el prototipo.	21
3.1	Caso de uso CU-01: Registro de despacho y selección de plan.	36
3.2	Caso de uso CU-02: Gestión del ciclo de vida de miembros del equipo.	38
3.3	Caso de uso CU-03: Inicio de sesión y gestión de sesiones.	40
3.4	Caso de uso CU-04: Control de acceso por perfil.	42
3.5	Caso de uso CU-05: Registro y administración de expediente penal.	44
3.6	Caso de uso CU-06: Gestión del directorio de participantes.	46
3.7	Caso de uso CU-07: Transición de etapa procesal.	48
3.8	Caso de uso CU-08: Programación de audiencia y activación de plazos.	50
3.9	Caso de uso CU-09: Configuración del calendario judicial.	52
3.10	Caso de uso CU-10: Monitoreo de plazos y emisión de alertas.	53
3.11	Caso de uso CU-11: Carga y clasificación de documentos.	55
3.12	Caso de uso CU-12: Consulta de documentos con verificación de integridad.	57
3.13	Caso de uso CU-13: Firma digital de contrato con sellado de tiempo.	59
3.14	Caso de uso CU-14: Verificación de firma digital y sello de tiempo.	61
3.15	Caso de uso CU-15: Consulta del tablero de control.	63
3.16	Caso de uso CU-16: Generación de informes.	64
3.17	Caso de uso CU-17: Consulta de bitácora de actividad.	66
3.18	RF-01: Autenticación y gestión de sesiones	67
3.19	RF-02: Control de acceso basado en roles (RBAC)	68
3.20	RF-03: Gestión de equipos colaborativos	68
3.21	RF-04: Expediente penal digital	69
3.22	RF-05: Control de etapas procesales (CNPP)	69
3.23	RF-06: Directorio de participantes	70
3.24	RF-07: Gestión de audiencias especializadas	70
3.25	RF-08: Blindaje de plazos procesales	71
3.26	RF-09: Sistema de alertas preventivas	71
3.27	RF-10: Calendario jurídico integrado	72
3.28	RF-11: Cadena de custodia digital	72
3.29	RF-12: Repositorio documental	73
3.30	RF-13: Verificación de integridad de documentos	73

3.31 RF-14: Cifrado autenticado de expedientes y documentos	74
3.32 RF-15: Firma digital de contratos	74
3.33 RF-16: Sellado de tiempo (NOM-151)	75
3.34 RF-17: Verificación de firmas y sellos de tiempo	75
3.35 RF-18: Dashboard ejecutivo	76
3.36 RF-19: Generación de reportes	76
3.37 RF-20: Bitácora de actividad (Audit Trail)	77
3.38 RNF-01: Aislamiento lógico multi-tenant	78
3.39 RNF-02: Gestión segura de credenciales	78
3.40 RNF-03: Gestión de material criptográfico	79
3.41 RNF-04: Inmutabilidad de registros críticos	79
3.42 RNF-05: Privacidad entre despachos	80
3.43 RNF-06: Procesamiento asíncrono	80
3.44 RNF-07: Tiempo de respuesta de interfaz	81
3.45 RNF-08: Diseño responsivo	81
3.46 RNF-09: Soporte de localización	82
3.47 RNF-10: Conformidad con el CNPP	82
3.48 RNF-11: Conformidad con la NOM-151	83
3.49 RNF-12: Cumplimiento de la LFPDPPP	83
3.50 RNF-13: Arquitectura mantenible	84
3.51 RNF-14: Aseguramiento de calidad	84
3.52 Fuentes salariales consultadas para la estimación del costo de recurso humano.	85
3.53 Escenarios salariales y tarifa horaria derivada.	85
3.54 Factores de ajuste sobre la capacidad de desarrollo.	86
3.55 Resumen de capacidad del equipo y presupuesto base.	86
3.56 Desglose de costos del proyecto en fase de prototipo.	87
3.57 Resumen financiero del proyecto.	87
3.58 Escala de probabilidad de ocurrencia.	88
3.59 Escala de impacto en tiempo.	89
3.60 Matriz de severidad (Probabilidad × Impacto).	89
3.61 Ficha del riesgo RTC-01: Falla en integración con PSC (RFC 3161).	90
3.62 Ficha del riesgo RTC-02: Implementación insegura de AES-256-GCM.	90
3.63 Ficha del riesgo RTC-03: Mala configuración de infraestructura.	91
3.64 Ficha del riesgo RTC-04: Pérdida de clave maestra de cifrado.	91
3.65 Ficha del riesgo RTC-05: Expiración de certificado X.509 en producción.	92
3.66 Ficha del riesgo RLC-01: Discrepancia de hashes SHA-256 (NOM-151).	92
3.67 Ficha del riesgo RLC-02: Mutabilidad en registros de auditoría (CNPP).	93
3.68 Ficha del riesgo RLC-03: Fuga de datos inter-tenant (LFPDPPP).	93
3.69 Ficha del riesgo RLC-04: Indisponibilidad del PSC (Cincel).	94
3.70 Ficha del riesgo ROP-01: Curva de aprendizaje TDD en módulos criptográficos.	94
3.71 Ficha del riesgo ROP-02: Scope creep en interfaces gráficas.	95
3.72 Ficha del riesgo ROP-03: Ruptura de cadencia de Pair Programming.	95
3.73 Resumen cuantitativo de los riesgos identificados con su severidad y VME.	96
3.74 Trazabilidad entre riesgos identificados y objetivos específicos.	97
3.75 Priorización de atributos de calidad y su mapeo a requerimientos no funcionales.	99

3.76	Comparativa de estilos arquitectónicos contra atributos de calidad priorizados.	100
3.77	Mapecto entre contextos delimitados, casos de uso y módulos del workspace de Cargo.	104
3.78	Inventario de crates externos utilizados por el proyecto, agrupados por capa arquitectónica.	108
3.79	Mapecto de alto nivel entre componentes arquitectónicos y los requerimientos que satisfacen.	113

CAPÍTULO 1

Introducción

1.1 Problemática

La reforma constitucional del 18 de junio de 2008 transformó el sistema de justicia penal en México, sustituyendo el modelo inquisitivo por un sistema acusatorio y oral. El Código Nacional de Procedimientos Penales (CNPP), publicado en marzo de 2014 [1], unificó los procedimientos penales bajo un marco normativo único para todas las entidades federativas y la Federación, entrando en operación gradual hasta quedar implementado en todos los estados de la República en 2016 [2]. Este modelo, sustentado en los principios de publicidad, contradicción, concentración, continuidad e inmediación (Art. 4, CNPP) [1], genera un volumen significativo de actuaciones documentales: carpetas de investigación, carpetas administrativas, registros de audiencia, evidencias y resoluciones judiciales que conforman el expediente de cada caso. Un aspecto central del CNPP es la cadena de custodia, definida en su artículo 227 como el sistema de control y registro que se aplica a la evidencia desde su localización hasta que la autoridad competente ordena su conclusión, considerando factores como identidad, estado original, condiciones de recolección, preservación y el registro de todas las personas que hayan tenido contacto con los elementos [1]. El artículo 228 establece que cuando durante el procedimiento de cadena de custodia los indicios se alteren, no perderán su valor probatorio a menos que se verifique que han sido modificados de tal forma que hayan perdido su eficacia probatoria [1]. Garantizar la integridad y trazabilidad de estos elementos es, por tanto, un requisito legal para la validez del proceso penal.

Con la modernización del sistema judicial —y de manera acelerada por la contingencia sanitaria de 2020— las instituciones del Poder Judicial iniciaron una transición hacia el expediente electrónico. El Consejo de la Judicatura Federal reformó sus disposiciones para incorporar medios electrónicos y soluciones digitales como ejes rectores del trabajo jurisdiccional, definiendo el expediente electrónico como el conjunto de documentos electrónicos y digitalizados que integran la totalidad de actuaciones judiciales [3]. A nivel local, el Poder Judicial de la Ciudad de México reporta contar con 15 millones de expedientes digitalizados con valor legal, resultado de un proceso iniciado hace más de una década y respaldado por la reforma de 2021 [4], mientras que entidades como el Estado de México han adoptado modelos de “cero papel” orientados a que escritos, acuerdos, resoluciones y notificaciones se manejen de manera completamente electrónica [5]. Esta transición responde a problemas estructurales del modelo en papel: rezago judicial, extravío de documentos y dificultades de acceso. Como señala la literatura sobre justicia digital en México, el rezago existente en los tribunales ha constituido una violación sistemática al derecho de acceso a la justicia y a la tutela judicial efectiva [6], y la digitalización ofrece beneficios concretos en reducción de tiempos procesales, acceso remoto y menor riesgo de deterioro o pérdida física.

No obstante, la digitalización de expedientes y la coordinación de procesos jurídicos mediante plataformas digitales introduce riesgos que no existían en el entorno físico. Cuando la migración al entorno digital se realiza sin mecanismos de seguridad adecuados, la información no solo queda

expuesta a accesos no autorizados, sino que pierde las propiedades que le otorgan valor probatorio ante un tribunal. El panorama de ciberseguridad en América Latina evidencia la magnitud de este riesgo: según el ESET Security Report 2025, basado en encuestas a más de 3,000 profesionales de TI en más de 15 países de la región, el 27 % de las organizaciones latinoamericanas sufrió al menos un ciberataque durante 2024, mientras que un 32 % adicional reconoció no contar con herramientas para confirmar si fueron atacadas o no [7]. El ransomware ocupa un lugar central en este panorama, con el 95 % de los encuestados ubicándolo entre sus principales amenazas y un 22 % que sufrió un incidente de este tipo en los últimos dos años [7]. En cuanto a la distribución geográfica, la telemetría de ESET para el primer semestre de 2024 posiciona a México como el segundo país con mayor número de amenazas detectadas en Latinoamérica [8].

El sector jurídico es particularmente vulnerable a estas amenazas. Los despachos legales gestionan información confidencial de múltiples clientes en repositorios centralizados, lo que los convierte en objetivos de alto valor para ciberdelincuentes que pueden obtener información de diversas fuentes en un solo ataque [9]. El ABA Legal Technology Survey Report 2023, publicado por la American Bar Association, reporta que el 29 % de los despachos de abogados ha experimentado alguna forma de brecha de seguridad [10], y el costo promedio de una brecha de datos para organizaciones de servicios profesionales —incluyendo firmas legales— alcanzó los 5.08 millones de dólares en 2024, un incremento del 10 % respecto al año anterior según el IBM Cost of a Data Breach Report 2024 [11]. Estas cifras no se limitan a grandes corporaciones: los despachos pequeños y medianos son a menudo atacados precisamente porque sus defensas tienden a ser más débiles [12].

Las consecuencias de esta vulnerabilidad trascienden lo económico y operativo, pues en el ámbito jurídico el problema central es que la evidencia digital almacenada sin garantías de integridad criptográfica resulta legalmente impugnabile. La legislación mexicana establece requisitos específicos para que un documento electrónico tenga valor probatorio pleno: el Código de Comercio, en su artículo 89, reconoce la equivalencia funcional de los documentos electrónicos con los físicos siempre que los datos de creación de la firma correspondan exclusivamente al firmante, estuvieran bajo su control exclusivo al momento de la firma, y sea posible detectar cualquier alteración posterior [13]; la NOM-151-SCFI-2016 complementa este marco al establecer que la integridad de un mensaje de datos se presume cuando ha permanecido íntegro e inalterado desde su generación, lo cual se acredita mediante una constancia de conservación emitida por un Prestador de Servicios de Certificación autorizado [14]. Cuando estos requisitos se cumplen, los documentos electrónicos gozan de presunción legal de atribución y garantía de integridad, con una fuerza probatoria que incluso supera a la del documento en papel [15]; en contraste, cuando un despacho almacena sus expedientes y contratos en plataformas que no implementan estos mecanismos, sus documentos carecen de dichas presunciones y quedan expuestos a impugnación por falta de integridad y autenticidad. Un juez puede restar valor probatorio o rechazar evidencia digital cuando la cadena de custodia presenta inconsistencias, como discrepancias en los valores hash [16], y la propia guía del Poder Judicial de la Federación para la valoración de prueba pericial en materia digital reconoce el hash como pieza clave en la cadena de custodia del contenido digital [17]. Adicionalmente, la gestión de datos personales de clientes por parte de los despachos está sujeta a la Ley Federal de Protección de Datos Personales en Posesión de los Particulares (LFPDPPP), cuyo artículo 19 exige implementar medidas de seguridad técnicas para proteger los datos contra daño, pérdida, alteración o acceso no autorizado [18], con sanciones administrativas significativas en caso de incumplimiento.

En síntesis, la digitalización del entorno jurídico es una transición necesaria e irreversible, pero cuando se implementa sin protocolos criptográficos que provean los servicios de integridad y no

repudio, se carece de los mecanismos técnicos para validar la inalterabilidad de los documentos en operaciones críticas. Esta ausencia de controles específicos compromete la certeza sobre la información y el valor probatorio de la evidencia digital en la gestión de expedientes de un despacho de la CDMX. Esta brecha entre la digitalización operativa y la disponibilidad de servicios de seguridad criptográfica constituye el problema que motiva el presente trabajo terminal.

1.2 Propuesta de solución

Se propone un prototipo de sistema web para la gestión de expedientes digitales y la actividad procesal de un despacho legal, que incorpora servicios criptográficos orientados a cerrar las brechas identificadas en el manejo digital de información jurídica.

Para garantizar que cualquier modificación no autorizada sobre un expediente sea detectable, el sistema implementa integridad criptográfica sobre cada documento almacenado, de modo que cualquier alteración —por mínima que sea— quede evidenciada en la siguiente consulta.

Para asegurar que el contenido de los expedientes sea accesible únicamente por las partes autorizadas, el sistema aplica confidencialidad sobre el material almacenado, de forma que un acceso indebido al repositorio no sea suficiente para comprometer la información.

Para impedir que un firmante niegue haber suscrito un contrato, el sistema genera evidencia criptográfica verificable de forma independiente sobre la autoría y el momento exacto de cada firma, proveyendo así no repudio en el flujo contractual del despacho.

Finalmente, para que los tres servicios anteriores tengan validez, el sistema controla que cada operación sea ejecutada únicamente por la identidad que le corresponde, mediante mecanismos de autenticación diferenciados por perfil de usuario.

1.3 Objetivo

Desarrollar un prototipo de sistema web para la gestión de expedientes digitales y la actividad procesal de un despacho legal, que brinde los servicios criptográficos de integridad y no repudio para el manejo de contratos; así como mecanismos de autenticación para accesos y gestión de credenciales.

Objetivos Específicos

- Realizar el análisis de requerimientos, el diseño funcional y técnico del sistema para la gestión de expedientes, contratos, casos y documentos legales. Para tener el flujo de funcionalidades con los que el usuario pueda interactuar y gestionar sus procedimientos y expedientes.
- Implementar los módulos de gestión de expedientes penales, etapas procesales, audiencias, plazos y directorio de participantes conforme a la estructura y terminología del CNPP, incluyendo operaciones CRUD y un calendario jurídico integrado que permita al despacho administrar su actividad procesal desde el prototipo.
- Implementar el servicio de no repudio para el flujo de firma de contratos mediante firma digital (véase §2.3.3) con certificados X.509 (véase §2.3.3.3) y sellado de tiempo (véase §2.3.3.4) emitido por un Prestador de Servicios de Certificación autorizado conforme a la NOM-151-SCFI-2016 (véase §2.2.7) y al protocolo RFC (Request for Comments) 3161, generando evidencia criptográfica verificable sobre la autoría y el momento de cada firma.

- Implementar el servicio de integridad mediante dos mecanismos complementarios: verificación por hash SHA-256 (Secure Hash Algorithm de 256 bits; véase §2.3.1) para detectar modificaciones no autorizadas en los documentos almacenados, y cifrado autenticado AES-256-GCM (Estándar de Cifrado Avanzado en modo Galois/Counter; véase §2.3.2) para proveer simultáneamente confidencialidad y detección de alteraciones en los expedientes.
- Implementar mecanismos de autenticación diferenciados por rol (basada en certificados digitales para los socios del despacho y por múltiples factores (MFA) para clientes) con control de acceso basado en roles (RBAC) y gestión segura de credenciales mediante funciones de hashing resistentes a ataques de fuerza bruta.
- Validar el correcto funcionamiento de los servicios criptográficos y los módulos de gestión procesal mediante pruebas funcionales que verifiquen la detección de alteraciones, la validez de las firmas digitales y los sellos de tiempo, y la integridad del flujo de extremo a extremo; complementadas con pruebas de usabilidad con usuarios del despacho.

La siguiente tabla sintetiza, para cada objetivo específico, el criterio de éxito verificable que permitirá declarar cumplido el objetivo al concluir el desarrollo del prototipo.

Tabla 1.1: Criterios de éxito por objetivo específico.

OE	Objetivo específico (resumen)	Criterio de éxito medible
OE-1	Análisis y diseño funcional/técnico	Catálogo completo de 18 casos de uso derivados de las 7 agrupaciones de historias de usuario; arquitectura hexagonal documentada con al menos tres puertos (persistencia, criptografía, TSA); modelo de datos híbrido (relacional y volátil) definido con esquemas normalizados.
OE-2	Módulos de gestión procesal penal (CNPP)	CRUD completo para expedientes, audiencias y plazos; calendario jurídico operando sobre las cuatro etapas del CNPP (investigación, intermedia, juicio oral y recursos); cómputo automático de términos conforme al artículo 94 del CNPP.
OE-3	No repudio con sello RFC 3161	Firma digital RSA-3072 con SHA-256 verificable de forma independiente sobre el 100 % de los contratos firmados; sello de tiempo RFC 3161 vinculado al hash del documento; tasa de verificación exitosa $\geq 99\%$ sobre sellos emitidos por el sandbox de Cincel.
OE-4	Integridad y confidencialidad	Detección del 100 % de alteraciones de un byte en documentos firmados mediante pruebas de mutación; cifrado AES-256-GCM con nonce único por operación y cero reutilizaciones en una suite de 10 000 cifrados; envelope encryption con DEK por documento.
OE-5	Autenticación diferenciada por rol	Argon2id calibrado a 300–500 ms por intento en el hardware de despliegue ($m=46$ MiB, $t=1$, $p=1$); MFA basado en TOTP (RFC 6238 [19]) con ventana de tolerancia ± 1 periodo; control de acceso RBAC con cuatro roles diferenciados (Owner, Litigante, Paralegal, Cliente).
OE-6	Validación del prototipo	Cobertura de pruebas $\geq 80\%$ en los módulos criptográficos; al menos 15 pruebas end-to-end que cubran los flujos de firma y verificación; matriz de pruebas funcionales con, por lo menos, un caso positivo y uno negativo por caso de uso.

1.4 Justificación

Los despachos jurídicos requieren infraestructura que provea evidencia técnica con valor probatorio, integridad verificable y mecanismos de no repudio en contratos que aseguren la trazabilidad de la autoría. La legislación mexicana establece requisitos específicos para que un documento electrónico goce de presunción legal de integridad y atribución: el Código de Comercio (art. 89) exige que la firma sea fiable y que cualquier alteración posterior sea detectable [13]; la NOM-151-SCFI-2016 requiere constancias de conservación emitidas por un Prestador de Servicios de Certificación autorizado para acreditar la inalterabilidad del documento [14]; y la LFPDPPP (art. 19) obliga a implementar medidas de seguridad técnicas para proteger los datos personales contra alteración y acceso no autorizado [18].

Estos requisitos no son opcionales: su incumplimiento expone los expedientes a impugnación por falta de integridad y autenticidad, y al despacho a sanciones administrativas.

Las soluciones comerciales analizadas en el estado del arte priorizan la operatividad sobre estos requisitos normativos, presentando brechas técnicas que comprometen el valor probatorio de la información gestionada:

Dependencia de terceros sin verificación independiente. Las plataformas obligan a los despachos a confiar en certificaciones externas (Service Organization Control 2 (SOC 2) Tipo II e ISO 27001 [20]) sin proporcionar mecanismos para que el propio despacho verifique, de forma independiente y criptográfica, la integridad de sus archivos.

Ausencia de sellado de tiempo conforme a la normativa mexicana. Las plataformas delegan la firma en servicios externos (DocuSign, Adobe Sign) que no implementan sellado de tiempo mediante un PSC autorizado conforme a la NOM-151-SCFI-2016, lo que impide acreditar la existencia del documento en una forma determinada en un momento específico ante la legislación mexicana.

Controles de acceso sin vinculación criptográfica. Si bien existen mecanismos de autenticación, su implementación suele ser inconsistente, careciendo de una vinculación criptográfica entre la identidad del usuario y las operaciones realizadas sobre los documentos.

El prototipo propuesto aborda estas brechas al proveer servicios criptográficos orientados a la generación de evidencia técnica verificable de forma independiente:

No repudio con evidencia temporal. Implementación de firma digital mediante certificados X.509 y sellado de tiempo conforme al protocolo RFC 3161, vinculando criptográficamente la autoría del firmante con el contenido del contrato y una marca temporal emitida por un PSC autorizado.

Integridad y confidencialidad mediante cifrado autenticado. Uso de AES-256-GCM en el almacenamiento de expedientes y documentos, proveyendo simultáneamente protección contra accesos no autorizados y detección de modificaciones, de modo que la seguridad de la información dependa de protocolos criptográficos y no únicamente de políticas de acceso administrativo.

Autenticación robusta y gestión segura de credenciales. Control de acceso mediante certificados digitales para socios y autenticación por múltiples factores (MFA) para clientes, complementado con almacenamiento de contraseñas bajo funciones hash resistentes (Argon2 o bcrypt), mitigando riesgos de suplantación de identidad.

A diferencia de las soluciones del mercado, este prototipo otorga al despacho soberanía sobre su cadena de custodia digital, proveyendo la evidencia criptográfica necesaria para sustentar el valor probatorio de sus documentos y la trazabilidad de su actividad procesal ante cualquier instancia judicial. El alcance del prototipo se acota a la gestión procesal penal conforme al CNPP, validándose con un despacho de la Ciudad de México como caso de estudio.

1.5 Revisión de Plataformas de Gestión Legal

El mercado de software de gestión para despachos legales (Legal Practice Management Software) cuenta con plataformas maduras que cubren funcionalidades operativas como administración de casos, gestión documental y comunicación con clientes. Con el fin de identificar las capacidades y limitaciones de las soluciones existentes en materia de seguridad criptográfica, se analizaron tres plataformas representativas del segmento: Clio [21], MyCase [22] y PracticePanther [23]. Los criterios de selección fueron su presencia consolidada en el mercado hispanohablante, la disponibilidad pública de documentación técnica sobre sus mecanismos de seguridad, y su orientación a despachos de tamaño pequeño y mediano, perfil equivalente al caso de estudio de este trabajo. La [tabla 1.2](#) sintetiza

la comparación en términos de funcionalidad, servicios de seguridad y mecanismos criptográficos reportados.

Tabla 1.2: Resumen ampliado de productos similares (función, servicios y criptografía).

Software	Funcionalidad principal	Cifrado a nivel documento	Firma digital	Sellado de tiempo (TSA)	Cumplimiento normativo MX
Clio	Gestión de casos, facturación, portal de clientes	No (solo en reposo a nivel infraestructura)	No	No	No reportado
MyCase	Comunicación cliente–abogado, cobros, apps móviles	No (solo en reposo a nivel infraestructura)	No	No	No reportado
PracticePanther	Plantillas, automatizaciones, registro de tiempo	No (solo en reposo a nivel infraestructura)	No	No	No reportado
Propuesta	Expedientes contratos y documentos legales	AES-256-GCM (cifrado autenticado)	X.509 (ECD-SA/RSA)	NOM-151 vía PSC	NOM-151, Código de Comercio Art. 89 bis

1.5.1 Mecanismos Criptográficos y Brechas Identificadas

Las tres plataformas convergen en un conjunto reducido de controles criptográficos: cifrado simétrico AES-256 en reposo para confidencialidad de los datos almacenados [24], Seguridad de la Capa de Transporte (TLS, Transport Layer Security) para la protección del canal de comunicación y mecanismos de autenticación basados en Autenticación por Múltiples Factores (MFA) y Control de Acceso Basado en Roles (RBAC). Clio se distingue al ser la única con certificaciones independientes (Service Organization Control 2 (SOC 2) Tipo II e ISO 27001) [20] y transparencia operativa verificable, lo que le otorga un perfil de riesgo bajo. MyCase [22] y PracticePanther [23] presentan un perfil de riesgo moderado, derivado de la ausencia de auditorías verificables y políticas de retención de datos ambiguas que dificultan la portabilidad de información.

Sin embargo, estos mecanismos son controles de prevención de acceso y confidencialidad, no de evidencia. Controlan quién puede acceder a los datos, pero no generan prueba criptográfica de quién realizó una operación ni cuándo la realizó. Del análisis se identifican tres mecanismos ausentes que son relevantes para escenarios con valor probatorio:

Firma digital con certificados X.509. Las plataformas delegan la firma en servicios externos (DocuSign, Adobe Sign), pero no implementan un flujo nativo de firma digital basada en criptografía asimétrica que vincule criptográficamente la identidad del firmante con el documento de forma verificable de manera independiente.

Sellado de tiempo conforme a la NOM-151-SCFI-2016. Ninguna plataforma implementa sellado

de tiempo mediante un Prestador de Servicios de Certificación autorizado [14], mecanismo necesario para acreditar que un documento existía en una forma determinada en un momento específico ante la legislación mexicana.

Cifrado autenticado. Si bien todas reportan AES-256, no se documenta el uso de modos de cifrado autenticado (como AES-GCM) que provean simultáneamente confidencialidad e integridad en un solo mecanismo, permitiendo detectar cualquier modificación no autorizada del contenido cifrado.

En síntesis, las plataformas existentes han alcanzado madurez en funcionalidades operativas y controles de seguridad estándar, pero presentan una brecha consistente en servicios criptográficos orientados a evidencia. La propuesta de este trabajo terminal se posiciona en esa brecha: no busca competir en amplitud de funcionalidades, sino proveer los servicios de no repudio, integridad y confidencialidad que estas plataformas no ofrecen, orientados a escenarios donde el valor probatorio de la información digital es un requisito.

1.6 Alcances y Delimitaciones

Para acotar el esfuerzo de investigación y desarrollo del prototipo, se establecen a priori los siguientes alcances y delimitaciones. Aquellos aspectos no listados expresamente como alcance del prototipo se consideran fuera del objeto del Trabajo Terminal.

- El prototipo opera bajo una arquitectura de inquilino único (single-tenant): cada instancia atiende a un solo despacho, simplificando el modelo de aislamiento y los mecanismos de cifrado por organización.
- La gestión procesal se limita a la materia penal conforme al CNPP; otras materias (civil, mercantil, laboral o administrativa) quedan fuera del alcance por requerir esquemas procesales y de valoración probatoria distintos.
- El caso de estudio corresponde a un despacho con sede en la Ciudad de México. La adaptación a particularidades procesales de otras entidades federativas no forma parte del prototipo.
- El sistema se ofrece como aplicación web accesible desde navegadores modernos; no se desarrolla una aplicación móvil nativa ni cliente de escritorio.
- El ámbito jurídico es estrictamente privado (Código de Comercio); no se contempla la integración con la Ley de Firma Electrónica Avanzada (LFEA), cuyo ámbito es la Administración Pública Federal.
- La firma digital emitida por el prototipo es firma electrónica simple en los términos del artículo 89 del Código de Comercio. Al no provenir de un Prestador de Servicios de Certificación autorizado, no alcanza la presunción de firma avanzada establecida en el artículo 97 del mismo ordenamiento. El respaldo probatorio se sustenta en el sello de tiempo conforme a la NOM-151-SCFI-2016.
- La integración con el PSC Cincel se realiza contra su entorno de sandbox para los fines del Trabajo Terminal. El despliegue en producción requeriría contratación comercial de la API y queda fuera del alcance.

1.7 Supuestos del Proyecto

El desarrollo del prototipo parte de los siguientes supuestos. La falsación de cualquiera de ellos durante la ejecución del Trabajo Terminal motivaría la activación de los planes de mitigación descritos en el análisis de riesgos (§3.6).

- El servicio de sellado de tiempo de Cincel (API v3, entorno sandbox) se mantiene disponible durante el ciclo de desarrollo y pruebas del prototipo.
- El hardware de despliegue dispone de al menos 46 MiB de memoria por proceso de autenticación, condición necesaria para ejecutar Argon2id con los parámetros seleccionados sin degradar el tiempo de respuesta del inicio de sesión.
- Existe conectividad estable a internet para consultar listas de revocación (CRL) y servicios OCSP de los PSCs mexicanos, así como la autoridad de sellado de tiempo de Cincel.
- Los usuarios acceden al sistema mediante navegadores modernos con soporte para ECMAScript 2020, Web Crypto API y TLS 1.2 o superior.
- El equipo de dos integrantes mantiene disponibilidad continua durante las diez semanas del cronograma XP, con cuatro jornadas efectivas por semana dedicadas al proyecto.
- La directora del Trabajo Terminal provee retroalimentación al final de cada iteración semanal, totalizando cinco entregas intermedias en la Fase I y cinco en la Fase II.
- Los socios del despacho caso de estudio están dispuestos a participar en pruebas de usabilidad de los flujos de firma y verificación.

CAPÍTULO 2

Marco teórico

El presente capítulo expone los fundamentos teóricos que sustentan el trabajo. Los temas abordados fueron seleccionados en función de los dos dominios que convergen en la problemática: el jurídico-procesal, que define qué se gestiona y bajo qué restricciones legales; y el criptográfico-técnico, que determina cómo se garantiza la validez probatoria de la información gestionada. El capítulo se organiza en cuatro bloques. El primero aborda el contexto procesal: el sistema acusatorio oral establecido por la reforma constitucional de 2008, la estructura del proceso penal conforme al CNPP —etapas, sujetos procesales, audiencias y plazos fatales— y los conceptos de expediente digital y cadena de custodia que determinan los requisitos del modelo de datos. El segundo describe el marco legal mexicano aplicable: la NOM-151-SCFI-2016, el Código de Comercio y la LFPDPPP, cuyo cumplimiento condiciona la validez probatoria de los documentos gestionados. El tercer bloque desarrolla los fundamentos criptográficos pertinentes: integridad mediante funciones hash (SHA-256, Estándar Federal de Procesamiento de Información (FIPS) 180-4 [25]) y cifrado autenticado (AES-256-GCM, FIPS 197 [26]); no repudio mediante firma digital con certificados X.509 y sellado de tiempo conforme al protocolo RFC 3161 [27]; y autenticación y control de acceso mediante certificados digitales, MFA y RBAC. El cuarto bloque cubre la arquitectura de almacenamiento híbrida y la metodología XP. Las referencias de cada sección se indican en el texto para quien desee profundizar en los temas tratados.

2.1 Seguridad de la Información en el Ámbito Jurídico

La seguridad de la información constituye la arquitectura sobre la cual se construye la confianza en el entorno digital. En la práctica jurídica, la transición del expediente físico al electrónico exige que las propiedades del documento en papel —dificultad de alteración, firma autógrafa, sello notarial— sean replicadas y superadas mediante herramientas criptográficas.

La tríada clásica de la seguridad (Confidencialidad, Integridad y Disponibilidad) [28] resulta insuficiente en el contexto del derecho, donde el concepto central es el valor probatorio: la capacidad de un documento electrónico de ser presentado como prueba legítima en un procedimiento legal. Stallings [28] señala que la seguridad no es un componente que se añade a un sistema, sino un proceso continuo orientado a garantizar que los activos de información estén protegidos contra amenazas que comprometan su veracidad.

En el ámbito jurídico digital, la seguridad se materializa en tres dimensiones verificables: que el contenido de los expedientes no haya sido alterado (integridad), que el autor de una operación —particularmente la firma de un contrato— no pueda negar haberla realizado (no repudio) y que solo las partes autorizadas accedan al contenido de los documentos almacenados (confidencialidad).

2.2 Sistema Legal Mexicano

2.2.1 El Sistema Acusatorio Oral en México

La reforma constitucional del 18 de junio de 2008 al artículo 20 de la Constitución Política de los Estados Unidos Mexicanos transformó estructuralmente el sistema de justicia penal, sustituyendo el modelo mixto-inquisitivo por un sistema de corte acusatorio y oral. Este cambio de paradigma no es meramente procedimental; representa una transformación en la ontología del derecho penal mexicano: el proceso abandona la secrecía de las oficinas judiciales para trasladarse a la audiencia pública, y el expediente de papel deja de ser el receptáculo de la verdad jurídica para convertirse en un registro auxiliar de lo que las partes producen de manera contradictoria ante el juez [1], [29].

El modelo inquisitivo anterior se sustentaba en la desconfianza: el juez delegaba sus funciones en secretarios, la “verdad” era aquello que quedaba plasmado en el papel, frecuentemente sin que el juzgador hubiera tenido contacto directo con las partes o las pruebas, y la prisión preventiva operaba como regla general. La doctrina procesal contemporánea, impulsada por figuras como Miguel Carbonell y Alberto Binder, sostiene que el sistema acusatorio busca equilibrar la eficacia en la persecución del delito con el respeto irrestricto a las garantías individuales [30], situando al imputado como sujeto de derechos y no como objeto de persecución penal. La **tabla 2.1** sintetiza las diferencias estructurales entre ambos modelos.

Tabla 2.1: Comparación entre el sistema inquisitivo y el sistema acusatorio oral.

Característica	Sistema Inquisitivo (tradicional)	Sistema Acusatorio (vigente)
Forma del proceso	Predominantemente escrito y secreto [29].	Oral, público y transparente [29].
Rol del juez	Investiga, acusa y juzga; delega funciones en secretarios [31].	Tercero imparcial; presencia obligatoria en todas las audiencias [31].
Valor de la confesión	Prueba reina; frecuentemente obtenida bajo coacción [29].	Solo tiene valor si se rinde voluntariamente ante el juez con defensa técnica [1].
Prisión preventiva	Regla general para la mayoría de los delitos [29].	Medida cautelar excepcional y proporcional; opera la presunción de inocencia [1].
El expediente	“Lo que no está en autos no está en el mundo”; centro de la verdad jurídica [31].	Registro auxiliar; la prueba se produce en la audiencia viva ante el juez [31].

Los Principios Rectores del Artículo 4 del CNPP como Base del Modelado Digital

El artículo 4 del CNPP no es un catálogo de aspiraciones, sino la estructura normativa que define la validez de todo acto procesal [1]. Cada principio impone exigencias técnicas concretas que cualquier herramienta de gestión procesal digital debe satisfacer [32].

- **Publicidad.** Las audiencias son abiertas al público salvo excepciones taxativas. En la abstracción digital este principio implica un control de acceso diferenciado por rol: el estado del proceso debe ser consultable por las partes legitimadas, mientras los documentos reservados permanecen cifrados para terceros no autorizados [1].
- **Contradicción.** Las partes tienen derecho a conocer, controvertir y confrontar los medios de prueba de la contraparte. En el ámbito digital, esto se traduce en descubrimiento probatorio: todas las partes deben tener acceso oportuno y completo a las evidencias digitales, con trazabilidad de quién las consultó y cuándo [1].
- **Concentración.** El mayor número de actos procesales posible debe realizarse en una sola audiencia o en el menor número de días consecutivos. En la práctica, este principio exige una gestión eficiente de la agenda que evite fragmentaciones innecesarias y anticipe riesgos a la continuidad de las audiencias [1].
- **Continuidad.** Las audiencias deben desarrollarse de forma sucesiva y secuencial hasta su conclusión. Este principio exige una bitácora de actividad inmutable (append-only) que registre el flujo cronológico del proceso, impidiendo saltos lógicos o alteraciones en el orden de las actuaciones [1].
- **Inmediación.** El juez debe estar presente físicamente en todas las audiencias y percibir de manera directa las pruebas y alegatos. En contextos de videoconferencia, los certificados digitales permiten verificar que quien firma una resolución es efectivamente el juzgador que presidió la sesión [1].
- **Igualdad entre las partes.** Tanto la defensa como el Ministerio Público deben tener las mismas oportunidades de acceso a la información procesal. Un esquema de control de acceso basado en roles debe reflejar esta paridad, sin conferir ventajas informacionales a ninguna de las partes [1].

2.2.2 Estructura del Proceso Penal conforme al CNPP

El artículo 211 del CNPP estructura el procedimiento ordinario en etapas secuenciales con finalidades, actuaciones, plazos y sujetos diferenciados [1]. Cada etapa habilita actuaciones específicas y activa plazos que deben monitorearse. La transición de una etapa a la siguiente solo es posible mediante el documento procesal habilitante correspondiente, lo que impide saltos lógicos que comprometerían la validez del expediente.

Etapas de Investigación

La investigación se subdivide en dos fases. La **investigación inicial** comienza con la noticia criminal —denuncia, querrela o detención en flagrancia— y concluye cuando el imputado queda a disposición del juez de control. Su instrumento documental es la **Carpeta de Investigación**, que es el registro administrativo del Ministerio Público y contiene indicios y datos de prueba aún no validados judicialmente [1], [33].

La **investigación complementaria** inicia con la formulación de cargos en la audiencia inicial y concluye con el escrito de acusación. El artículo 321 del CNPP fija plazos máximos de dos meses —cuando la pena máxima no supera los dos años— y seis meses para los demás casos, salvo prórroga

autorizada judicialmente. El cumplimiento de estos plazos es crítico, y la fase incluye actos de investigación complejos como peritajes, entrevistas a testigos e inspecciones de lugar [1], [33].

Etapas Intermedia

La etapa intermedia, también denominada de preparación del juicio oral, tiene por objeto la depuración de los hechos controvertidos y la admisión de los medios de prueba [1]. Comprende una **fase escrita**—activada con la presentación del escrito de acusación— y una **fase oral** desarrollada en la audiencia intermedia, donde las partes debaten la pertinencia y licitud de las pruebas ofrecidas. Esta etapa culmina con el **auto de apertura a juicio oral**, que determina los hechos acusados, las pruebas admitidas, los acuerdos probatorios y el tribunal competente [1]. El auto de apertura constituye el documento de transferencia de estado que habilita la etapa de juicio oral.

Etapas de Juicio Oral

El juicio oral es la fase de decisión de las cuestiones esenciales del proceso y se rige por la aplicación estricta de los seis principios del artículo 4 del CNPP [1]. En esta etapa la prueba se desahoga ante el tribunal de enjuiciamiento con plena contradicción; los registros audiovisuales de las audiencias constituyen el “*acta*” del juicio. La integridad de estos registros es prioritaria, y el fallo debe documentarse con firma digital del tribunal inmediatamente tras su pronunciamiento para garantizar su autenticidad [32].

Recursos, Impugnación y Ejecución

El proceso no finaliza con la sentencia de primer grado. El CNPP prevé **recursos de apelación** ante un Tribunal de Alzada dentro de los plazos del artículo 471 del CNPP, y posteriormente el seguimiento de la ejecución de la sentencia firme ante el Juez de Ejecución de Sanciones. En esta fase los registros del expediente original adquieren especial relevancia probatoria, dado que los tribunales revisores basan su análisis exclusivamente en las constancias documentadas [1].

2.2.3 Sujetos Procesales

El artículo 105 del CNPP define el catálogo de sujetos procesales con roles y atribuciones específicas que condicionan su interacción con el expediente digital [1]. La correcta representación de cada sujeto no es solo una cuestión de nomenclatura: determina la lógica del control de acceso basado en roles (RBAC). Un mismo individuo puede desempeñar roles distintos en procedimientos diferentes, por lo que la identidad del usuario debe vincularse con su rol procesal a nivel de caso, no de manera global [34], [35].

Tabla 2.2: Sujetos procesales del CNPP y sus implicaciones en la gestión digital del expediente.

Sujeto procesal	Atributos para el directorio (RF-07)	Implicaciones en la gestión digital
Ministerio Público	Identificador de Fiscalía, Unidad de Adscripción, Cédula Profesional [34].	Carga la acusación, solicita medidas cautelares y registra actos de investigación en la Carpeta.
Imputado	CURP, datos generales, estatus de libertad o detención [1].	Acceso restringido a la carpeta digital para consulta de pruebas y recepción de notificaciones.
Defensor	Cédula Profesional validada ante el PJ, firma electrónica, modalidad (particular o público) [34].	Presenta promociones, contesta la acusación, ofrece pruebas e interpone recursos.
Víctima u ofendido	Datos de contacto seguro, medidas de protección activas [1].	Consulta el estado del proceso y solicita reparación del daño mediante el portal restringido.
Asesor jurídico de la víctima	Datos de institución o despacho, cédula profesional [34].	Coadyuva con el Ministerio Público en la oferta de pruebas y en la presentación de alegatos.
Juez de control	Órgano jurisdiccional, Firma Electrónica del Poder Judicial de la Federación (FIREL) [3].	Dicta resoluciones, autoriza actos de investigación y preside la audiencia intermedia [1].
Tribunal de enjuiciamiento	Composición (unitario o colegiado), distrito judicial [34].	Emite el fallo y la sentencia basándose exclusivamente en los registros del juicio oral [1].

2.2.4 Actuaciones Procesales y el Expediente Digital

El proceso penal acusatorio genera dos conjuntos documentales estructuralmente distintos: la Carpeta de Investigación y el Expediente Judicial. Ambos difieren en origen, custodia y nivel de validación probatoria, lo que condiciona su modelado en cualquier herramienta digital.

Carpeta de Investigación versus Expediente Judicial

La **Carpeta de Investigación** es el registro del Ministerio Público. Contiene indicios, datos de prueba e información de gestión que aún no han sido validados judicialmente ni sometidos al contradictorio. Digitalmente, constituye un repositorio dinámico que se alimenta de reportes policiales, dictámenes periciales y actas ministeriales. Su acceso está restringido a los actores de la investigación y, en los términos del artículo 218 del CNPP, a la defensa en la medida necesaria para el ejercicio de sus derechos [1].

El **Expediente Judicial** reside en el Poder Judicial y contiene exclusivamente las actuaciones presentadas ante el juez y los registros de audiencias celebradas. El Acuerdo General 12/2020 del

Consejo de la Judicatura Federal establece que el expediente electrónico se integra cronológicamente con documentos digitalizados y generados electrónicamente, los cuales tienen el mismo valor probatorio que los físicos siempre que cuenten con firma electrónica y sello de tiempo (marca temporal criptográfica emitida por un tercero de confianza; véase §2.3.3.4) que acrediten su autenticidad e integridad [3].

Identificación Única: el NUC y la Carpeta Judicial

La trazabilidad entre instancias es el fundamento técnico de la cadena de custodia digital y se articula sobre dos identificadores complementarios:

- **Número Único de Caso (NUC).** Identificador nacional que permite rastrear un asunto desde que se denuncia hasta sentencia firme. Constituye la clave que garantiza la interoperabilidad entre fiscalías y tribunales [1].
- **Carpeta Judicial.** Número interno asignado por el juzgado al iniciar el proceso en sede jurisdiccional. La vinculación bidireccional NUC–Carpeta Judicial es necesaria para que el abogado pueda rastrear sus casos con independencia del identificador que utilice la autoridad en cada comunicación oficial [4].

La Cadena de Custodia Digital y su Valor Probatorio

La cadena de custodia, definida en el artículo 227 del CNPP como el sistema de control y registro que se aplica a los indicios desde su localización hasta que la autoridad ordena su conclusión [1], es el mecanismo jurídico que dota de valor probatorio a la evidencia digital. Su traslado al entorno digital exige tratar cada actuación procesal como una evidencia sujeta a tres garantías técnicas:

- **Integridad.** Hash SHA-256 calculado al momento de la carga y verificado en cada consulta posterior. Cualquier discrepancia evidencia modificación no autorizada.
- **Trazabilidad.** Registro de auditoría inmutable (append-only) que documenta por cada operación: el identificador del usuario, el tipo de operación, la marca de tiempo y el estado del documento afectado.
- **No repudio.** Firma digital con certificados X.509 y sellado de tiempo de un PSC autorizado conforme a la NOM-151-SCFI-2016, generando evidencia criptográfica verificable de forma independiente sobre la autoría y el momento de cada operación [1], [14].

2.2.5 Plazos y Términos Constitucionales

El proceso penal acusatorio está estructurado sobre plazos fatales cuyo vencimiento genera consecuencias jurídicas irreversibles, incluyendo la libertad del imputado o la preclusión de derechos procesales. El error en el cómputo de un plazo constitucional es una contingencia que ningún mecanismo criptográfico puede subsanar a posteriori, lo que convierte la gestión de plazos en una función de alta criticidad operativa.

Reglas de Cómputo según el Artículo 94 del CNPP

El artículo 94 del CNPP establece las siguientes reglas de cómputo [1]:

- **Plazos en horas:** Corren de momento a momento, sin interrupción por días inhábiles. Aplican a los plazos constitucionales más críticos, como las 72 horas para la vinculación a proceso.
- **Plazos en días:** Comienzan a contarse a partir de que surte efectos la notificación. No se contabilizan sábados, domingos ni días feriados del calendario del Poder Judicial, salvo tratándose de detención y medidas precautorias, donde todos los días y horas son hábiles [1].
- **Calendario configurable:** La correcta aplicación de estas reglas requiere un calendario de días inhábiles diferenciado por entidad federativa y por fuero, dado que los periodos de receso judicial varían entre jurisdicciones.

Términos Fatales del Proceso Penal

Tabla 2.3: Términos fatales del proceso penal y su implicación para el módulo de alertas (RF-09, RF-10).

Actuación / plazo	Término legal	Fundamento	Implicación para la gestión digital
Retención por el Ministerio Público	48 horas	Art. 16 Constitucional	Alerta roja al vencer sin judicialización del detenido.
Vinculación a proceso	72 / 144 horas	Art. 19 Constitucional; Art. 308 CNPP [1]	Agendar audiencia de continuación con prioridad máxima; alerta a las 48 h.
Investigación complementaria	2 o 6 meses	Art. 321 CNPP [1]	Recordatorio para solicitar prórroga o presentar cierre de investigación.
Presentación de acusación	15 días	Art. 324 CNPP [1]	Plazo tras el cierre; su vencimiento activa el sobreseimiento.
Recurso de apelación de sentencia	10 días	Art. 471 CNPP [1]	Plazo fatal desde la notificación; su pérdida cierra la vía impugnativa ordinaria.

2.2.6 Audiencias Tipificadas conforme al CNPP

El proceso acusatorio oral se articula en torno a audiencias formales cuya tipificación no puede reducirse a una etiqueta descriptiva: cada tipo activa validaciones procesales distintas y desencadena el cómputo de plazos derivados. Un catálogo de tipos de audiencia con semántica procesal explícita es necesario para garantizar la coherencia del expediente [1], [36].

- **Audiencia inicial (Arts. 307–313 CNPP).** Primera comparecencia del imputado ante el juez de control. En ella se realizan, en orden procesal definido: control de detención, formulación de cargos, oportunidad de declarar del imputado, resolución sobre medidas cautelares y vinculación o no vinculación a proceso con apertura del plazo de investigación complementaria. Cada hito

debe registrarse de forma independiente, ya que cada uno puede generar plazos y recursos propios [1].

- **Audiencia de medidas cautelares.** Puede solicitarse en cualquier momento de la investigación, de manera autónoma o como parte de la audiencia inicial. Las medidas impuestas —prisión preventiva, brazaletes electrónicos, firma periódica— requieren un historial con fechas de inicio, vigencia y condiciones de cumplimiento [1].
- **Audiencia intermedia (Arts. 334–347 CNPP).** Tiene por objeto depurar los hechos controvertidos y resolver sobre la admisión de medios de prueba. La gestión probatoria implica distinguir qué pruebas fueron admitidas, cuáles excluidas y los motivos de exclusión; esta etapa culmina con el auto de apertura a juicio oral como documento de transición de estado [1].
- **Audiencias de juicio oral (Arts. 348–395 CNPP).** Comprenden los alegatos de apertura, el desahogo de pruebas con interrogatorio y contrainterrogatorio, los alegatos de clausura y la deliberación del tribunal. Las incidencias de cada sesión deben vincularse a la marca de tiempo del video de sala, y el fallo debe documentarse con firma digital del tribunal inmediatamente tras su pronunciamiento [1].
- **Audiencia de individualización de sanciones y reparación del daño (Arts. 399–403 CNPP).** Realizada tras un fallo condenatorio para debatir la pena y la reparación del daño. La sentencia exacta y los montos de reparación deben vincularse al expediente con mecanismos de no repudio, dado que este documento constituye el título ejecutivo de la condena [1].

2.2.7 Normatividad Mexicana de Firma Electrónica y Datos

Para que los servicios criptográficos tengan validez en el contexto jurídico mexicano, deben alinearse con la legislación que otorga reconocimiento legal a las operaciones electrónicas. A continuación, se describen los ordenamientos aplicables.

NOM-151-SCFI-2016

La NOM-151-SCFI-2016 es la norma técnica que establece los requisitos para la conservación de mensajes de datos y la digitalización de documentos. Su disposición central establece que la integridad de un mensaje de datos se presume si este ha permanecido íntegro y sin alteraciones desde el momento en que se generó en su forma definitiva, lo cual se acredita mediante la constancia de conservación emitida por un Prestador de Servicios de Certificación autorizado. En la práctica, esto se traduce en la obtención de sellos de tiempo de un PSC autorizado para cada operación que requiera preservación probatoria.

Código de Comercio: Equivalencia Funcional

El Título Segundo del Código de Comercio (artículos 89 a 114) [13] establece el marco jurídico que otorga reconocimiento legal a las transacciones electrónicas en México. El artículo 89 define la firma electrónica como los datos en forma electrónica consignados en un mensaje de datos, o adjuntados o lógicamente asociados al mismo, que pueden ser utilizados para identificar al firmante en relación con el mensaje de datos e indicar que el firmante aprueba la información contenida en el mismo. Esta definición —denominada firma electrónica simple— no exige la intervención de un Prestador

de Servicios de Certificación y produce los mismos efectos jurídicos que la firma autógrafa, siendo admisible como prueba en juicio. Complementariamente, el artículo 89 bis consagra el principio de no discriminación: no se negarán efectos jurídicos, validez o fuerza obligatoria a cualquier tipo de información por la sola razón de que esté contenida en un mensaje de datos.

El artículo 93 establece que cuando la ley exija forma escrita para un acto jurídico, dicho requisito se cumple con un mensaje de datos siempre que la información en él contenida se mantenga íntegra y sea accesible para su ulterior consulta. A su vez, el artículo 93 bis dispone que cuando se requiera que un documento se conserve y presente en su forma original, tal requisito se satisface si el mensaje de datos se ha mantenido íntegro e inalterado a partir del momento en que se generó por primera vez en su forma definitiva, conforme a la NOM-151-SCFI-2016. Este artículo es la base legal que dota al sello de tiempo emitido por un PSC autorizado de su eficacia como constancia de conservación.

El artículo 97 establece los requisitos para que una firma electrónica sea considerada avanzada o fiable: (1) que los datos de creación de la firma correspondan exclusivamente al firmante, (2) que dichos datos estuvieran bajo su exclusivo control al momento de firmar, (3) que sea posible detectar cualquier alteración de la firma posterior a su creación, (4) que sea posible detectar cualquier alteración del mensaje de datos firmado y (5) que los datos de creación de la firma estén vinculados a un certificado emitido por un PSC autorizado. La ausencia de este último requisito es lo que distingue a la firma simple de la avanzada. No obstante, el artículo 100 introduce una cláusula de equivalencia funcional: una firma electrónica se considerará avanzada o fiable si, por cualquier otro medio, se demuestra que el método utilizado es confiable y apropiado para los fines para los cuales se utilizó el mensaje de datos [13]. Esta disposición permite argumentar la fiabilidad de una firma basada en algoritmos reconocidos internacionalmente, como RSA (Rivest-Shamir-Adleman) con SHA-256 conforme a NIST (National Institute of Standards and Technology) SP 800-57 [37], aunque el certificado no provenga de un PSC autorizado.

La distinción fundamental entre ambos tipos de firma no radica en la admisibilidad —ambas son admisibles como prueba conforme al artículo 89—, sino en la carga de la prueba. La firma electrónica avanzada goza de una presunción legal de fiabilidad: quien la impugna debe demostrar que no es confiable. La firma electrónica simple, en cambio, no goza de tal presunción: quien la invoca como prueba debe acreditar la fiabilidad del método empleado. Esta diferencia procesal es relevante para cualquier herramienta de gestión jurídica digital que pretenda sustentar el valor probatorio de sus documentos ante una instancia judicial. Adicionalmente, el artículo 33 del mismo Código obliga a los comerciantes a mantener registros mercantiles por un periodo mínimo de diez años, lo cual fundamenta los requisitos de retención y conservación de datos [13].

El valor probatorio de los documentos electrónicos en sede judicial se sustenta en disposiciones complementarias. El artículo 210-A del Código Federal de Procedimientos Civiles [38] reconoce como prueba la información generada o comunicada que conste en medios electrónicos, ópticos o en cualquier otra tecnología; el juzgador valora dicha información atendiendo a tres criterios: (1) la fiabilidad del método en que haya sido generada, comunicada, recibida o archivada, (2) la posibilidad de atribuir a las personas obligadas el contenido de la información, y (3) la posibilidad de determinar el momento en que fue generada, comunicada o archivada. Una firma digital basada en RSA con SHA-256 satisface el criterio de atribución, la función hash garantiza la integridad exigida por el criterio de fiabilidad, y un sello de tiempo emitido por un PSC autorizado provee la certeza temporal.

En materia penal, el artículo 356 del CNPP establece que el Tribunal de enjuiciamiento valora la prueba de manera libre y lógica (sistema de sana crítica), sin reglas tasadas de valor probatorio [1]. Esto significa que un documento firmado electrónicamente con criptografía robusta y respaldado por un

sello NOM-151 puede alcanzar valor probatorio pleno si se acreditan integridad, autenticidad y cadena de custodia ante el juzgador. Complementariamente, el artículo 380 del CNPP dispone que podrá incorporarse al juicio todo documento o instrumento con contenido probatorio, incluyendo registros electrónicos [1]. Finalmente, es pertinente señalar que la Ley de Firma Electrónica Avanzada (LFEA) [39], en sus artículos 1 y 2, circunscribe su ámbito de aplicación a las dependencias y entidades de la Administración Pública Federal y a los particulares cuando se relacionen con dichas dependencias; en consecuencia, las transacciones entre particulares —como es el caso de un despacho jurídico privado— se regulan exclusivamente por el Código de Comercio.

Ley Federal de Protección de Datos Personales en Posesión de los Particulares (LFPDPPP)

Dado que un despacho jurídico gestiona información personal de sus clientes, debe cumplir con la LFPDPPP. El artículo 19 de esta ley exige que el responsable del tratamiento de datos implemente medidas de seguridad administrativas, técnicas y físicas para proteger los datos personales contra daño, pérdida, alteración, destrucción, o acceso y tratamiento no autorizados. Servicios como el cifrado autenticado, el control de acceso basado en roles y la gestión segura de credenciales constituyen medidas técnicas orientadas al cumplimiento de esta obligación.

Prestadores de Servicios de Certificación en México

La NOM-151-SCFI-2016 y el Código de Comercio no otorgan a cualquier entidad la facultad de emitir constancias de conservación con valor legal; esta capacidad está reservada exclusivamente a los **Prestadores de Servicios de Certificación (PSC)**, entidades acreditadas y auditadas por la Secretaría de Economía a través de la Dirección General de Normatividad Mercantil, conforme al artículo 95 bis 6 del Código de Comercio [40]. La obtención de esta acreditación representa una barrera de entrada formidable: las instituciones privadas, notarías públicas o dependencias gubernamentales deben demostrar capacidades tecnológicas, procedimentales y financieras excepcionales para operar como terceros de confianza legalmente reconocidos [40].

En términos técnicos, el PSC nunca almacena el documento original del cliente —lo que vulneraría principios elementales de privacidad—, sino que opera sobre el principio de la abstracción criptográfica unidireccional [41]: el sistema cliente calcula el hash SHA-256 del documento y transmite únicamente esa huella a la infraestructura del PSC, la cual activa su Autoridad de Sellado de Tiempo (TSA). La TSA concatena el hash con una marca de tiempo sincronizada con el Centro Nacional de Metrología (CENAM) y aplica su propia firma electrónica avanzada sobre ese conjunto de datos, generando el Sello Digital de Tiempo (SDT) conforme al protocolo RFC 3161 [41]. El documento resultante —comúnmente en formato .asn1 o .tsr— constituye la evidencia matemática irrefutable de la existencia e integridad del documento en ese momento específico [41].

La infraestructura de clave pública (PKI) mexicana se organiza jerárquicamente bajo la Autoridad Certificadora Raíz Segunda de la Secretaría de Economía (ACR2-SE). Conforme a su Política de Certificados [42], los certificados digitales emitidos bajo esta jerarquía deben contener claves públicas RSA con longitud mínima de 4096 bits para la raíz y Autoridades Certificadoras (ACs) subordinadas, y de 2048 bits para los certificados de usuario final. El algoritmo de firma obligatorio es sha256WithRSAEncryption (RSA + SHA-256); la política no contempla curvas elípticas (ECDSA). Los módulos criptográficos de las ACs deben cumplir al menos FIPS 140-2 nivel 3. Esta restricción algorítmica condiciona cualquier integración con certificados legalmente reconocidos en México, ya que la interoperabilidad con la jerarquía ACR2-SE exige el uso exclusivo de RSA.

Cada PSC es responsable de mantener mecanismos de revocación de certificados conforme al numeral 75, fracción V, de las Reglas Generales a las que deberán sujetarse los PSC [43]. En la práctica, los principales PSC mexicanos implementan Listas de Certificados Revocados (CRL, conforme a RFC 5280 [44]) y, en la mayoría de los casos, responders del Protocolo de Estado de Certificado en Línea (OCSP). SeguriData [45] publica CRLs cada 24 horas y expone un servicio OCSP público. CECOBAN [46] mantiene CRLs y un servicio OCSP con latencia de publicación de 15 minutos. La e.firma del SAT (Servicio de Administración Tributaria) opera un responder OCSP semi-público, aunque no publica CRLs en formato X.509 estándar. La propia ACR2-SE publica su CRL mensualmente o al revocar un certificado, y mantiene un servicio OCSP v1. Las URLs específicas de cada PSC se encuentran embebidas en los campos Authority Information Access (AIA) y CRL Distribution Points de los certificados que emiten.

Ecosistema de PSC acreditados por la Secretaría de Economía La Secretaría de Economía mantiene un directorio público de entidades que han superado las evaluaciones de cumplimiento para operar como PSC [40]. Es fundamental distinguir que las acreditaciones son específicas por servicio: una entidad puede estar autorizada para emitir certificados digitales, pero no necesariamente para emitir constancias de conservación NOM-151 [40]. La [tabla 2.4](#) sintetiza los principales PSC acreditados relevantes para el contexto del prototipo:

Tabla 2.4: Principales PSC acreditados por la Secretaría de Economía relevantes para el prototipo.

PSC Acreditado	Servicios acreditados relevantes	Perfil tecnológico	Acreditación (Diario Oficial de la Federación, DOF)
CECOBAN, S.A. de C.V.	NOM-151, sellos de tiempo, digitalización.	Infraestructura bancaria sistémica; rigor metrológico con sincronización CENAM. Orientado a transacciones financieras de alta frecuencia [40].	2008, 2010, 2021
EDICOM (Edicomunicaciones México)	NOM-151, sellos de tiempo, digitalización, certificados digitales.	Plataforma global de intercambio electrónico de datos (EDI); integración con eIDAS europeo y Dropbox Sign. Orientado a corporativos multinacionales [40].	2009, 2010, 2018
SeguriData Privada, S.A. de C.V.	NOM-151, sellos de tiempo, digitalización, certificados digitales.	Legado en seguridad informática corporativa; infraestructura de respaldo para plataformas de firma como Mifiel mediante API RESTful [40].	2011, 2019
Legalex GS, S.A. de C.V.	NOM-151, sellos de tiempo.	Plataforma propietaria “Covenant” para gestión de contratos digitales con NOM-151 integrada [40].	2019, 2020
Interfactura, S.A.P.I. de C.V.	NOM-151, sellos de tiempo.	Origen en certificación de facturas fiscales (PAC); herramientas de verificación pública de constancias .tsr mediante interfaz web [40].	2021
PSC World, S.A. de C.V.	NOM-151, sellos de tiempo, certificados digitales.	Integración nativa con Zoho Sign; entrega sellos en formato ASN.1 descontados como créditos de la plataforma [40].	2005, 2020
INCODE PSC, S. de R.L. de C.V.	NOM-151, sellos de tiempo.	Convergencia de verificación biométrica de identidad (IDV/KYC) con emisión criptográfica; API RESTful con validación contra INE [40].	2024
Cincel Certificadora Digital S.A.P.I. de C.V.	NOM-151, sellos de tiempo.	Primer PSC nativo de nube en México y América Latina; infraestructura AWS con modelo Zero Trust; API-first con sandbox gratuito; precios transparentes desde \$0.029 USD/transacción [40], [47].	2023

Criterios de selección del PSC para el prototipo La selección del PSC para el prototipo no es una decisión operativa sino una decisión de diseño con implicaciones jurídicas, técnicas y de viabilidad de implementación. Los criterios evaluados son cuatro:

- **Acreditación formal ante la Secretaría de Economía.** Requisito excluyente: únicamente los PSC del directorio oficial pueden emitir constancias con valor legal conforme a la NOM-151 [40].
- **Accesibilidad para integración mediante API.** El prototipo requiere un flujo de sellado automatizado en el backend (capa lógica del servidor); un PSC sin Interfaz de Programación de Aplicaciones (API, Application Programming Interface) REST (Representational State Transfer) documentada o con acceso condicionado a contratos corporativos prolongados no es viable en el contexto de un prototipo académico.
- **Disponibilidad de entorno de pruebas (sandbox).** Indispensable para implementar y validar el flujo criptográfico durante el ciclo de desarrollo sin incurrir en costos por cada transacción de prueba.
- **Compatibilidad con el protocolo RFC 3161.** El sello debe adherirse al estándar internacional de sellado de tiempo para garantizar la verificabilidad independiente de las constancias generadas [27].

Del análisis del ecosistema de PSC conforme a estos criterios, **Cincel** es el proveedor seleccionado para el prototipo por las siguientes razones técnicas y operativas:

- **Único PSC nativo de nube en México y América Latina acreditado por la Secretaría de Economía.** Su infraestructura está desplegada sobre Amazon Web Services (AWS) bajo el modelo de Seguridad de Confianza Cero (Zero Trust), lo que garantiza alta disponibilidad y resiliencia sin dependencia de centros de datos físicos propios del proveedor [47].
- **Arquitectura API-first con sandbox gratuito.** Cincel expone su infraestructura a desarrolladores de forma inmediata, proporcionando colecciones públicas de Postman para pruebas de concepto instantáneas y un entorno de sandbox sin costo, lo que es determinante para la fase de desarrollo del prototipo [47].
- **Modelo de consumo por transacción (pay-as-you-go).** Con un costo de aproximadamente \$0.029 USD por sello sin mínimos mensuales [47], el esquema es compatible con el volumen reducido de transacciones de un prototipo de validación, a diferencia de los modelos de contrato corporativo de los PSC legados.
- **Cumplimiento nativo de RFC 3161 y NOM-151-SCFI-2016.** Los sellos digitales de tiempo emitidos por Cincel se adhieren estrictamente al protocolo RFC 3161 [27] y a los requisitos de sincronización metrológica con el CENAM, garantizando que las constancias generadas en el prototipo sean verificables de forma independiente ante cualquier instancia judicial.
- **Autorización de la Comisión Nacional Bancaria y de Valores (CNBV).** Cincel cuenta con autorización de la CNBV para prestar servicios al sector financiero mexicano [47], lo que respalda adicionalmente la solidez de su infraestructura de seguridad para el manejo de documentos con valor probatorio.

Es importante señalar que la selección de Cincel como PSC del prototipo no implica exclusividad arquitectónica: el módulo de sellado de tiempo del sistema está diseñado para abstraer al proveedor

detrás de una interfaz interna, de modo que el despacho pueda sustituir el PSC por cualquier otro del directorio de la Secretaría de Economía —como SeguriData o CECOBAN— sin modificar la lógica central del sistema, siempre que el proveedor alternativo implemente el protocolo RFC 3161. Esta decisión de diseño garantiza la soberanía tecnológica del despacho sobre su cadena de custodia digital.

2.3 Primitivas y Servicios Criptográficos

2.3.1 Integridad

La integridad es el servicio de seguridad que garantiza que la información se mantiene exacta, completa y sin modificaciones no autorizadas desde el momento de su creación. En un expediente legal, donde la alteración de una fecha, un monto o una cláusula puede modificar el curso de un procedimiento judicial, la integridad es un requisito fundamental [28].

Funciones Hash Criptográficas

El mecanismo técnico para verificar la integridad de un documento es la función hash criptográfica. Una función hash H toma una entrada de longitud arbitraria y produce una salida de longitud fija, denominada digest o huella digital. Para ser criptográficamente segura, debe cumplir tres propiedades fundamentales: resistencia a la preimagen (dado un hash, es computacionalmente inviable encontrar el mensaje original), resistencia a la segunda preimagen (dado un mensaje, es inviable encontrar otro mensaje con el mismo hash) y resistencia a colisiones (es inviable encontrar dos mensajes distintos que produzcan el mismo hash) [24], [25].

SHA-256

SHA-256 (Secure Hash Algorithm) pertenece a la familia SHA-2 estandarizada por el Instituto Nacional de Estándares y Tecnología (NIST, National Institute of Standards and Technology) en FIPS 180-4 [25]. Produce un digest de 256 bits (32 bytes) y es el estándar de facto para aplicaciones que requieren verificación de integridad, incluyendo firmas digitales, certificados X.509 y sellos de tiempo. Su resistencia a colisiones se considera computacionalmente segura con la capacidad de cómputo actual [48].

En un flujo típico de verificación de integridad, al almacenar un documento se calcula su hash SHA-256 y se conserva como referencia. En cada consulta posterior se recalcula el hash del documento almacenado y se compara con el valor de referencia. Cualquier discrepancia indica que el documento ha sido modificado.

La elección de SHA-256 se enmarca en la recomendación de niveles de fortaleza de seguridad del NIST SP 800-57 Part 1 Rev 5 [37]. Este documento define la fortaleza de seguridad (security strength) como el número de operaciones necesarias para romper un algoritmo criptográfico. SHA-256 proporciona 128 bits de fortaleza contra colisiones, lo que significa que se requieren aproximadamente 2^{128} operaciones para encontrar una colisión —un umbral considerado seguro al menos hasta 2030 para aplicaciones de uso general. El nivel de 128 bits sirve como guía para la selección coherente de todos los primitivos criptográficos de una arquitectura: AES-256 proporciona 256 bits de fortaleza, y RSA con claves de 3072 bits proporciona aproximadamente 128 bits, garantizando que ningún eslabón de la cadena criptográfica sea más débil que el nivel objetivo.

2.3.2 Confidencialidad e Integridad mediante Cifrado Autenticado

Mientras que el hash permite detectar modificaciones, no protege el contenido contra accesos no autorizados. Para expedientes y documentos almacenados se requiere un mecanismo que provea simultáneamente confidencialidad (que solo las partes autorizadas accedan al contenido) e integridad (que cualquier modificación no autorizada sea detectada). Este doble servicio lo provee el cifrado autenticado [28].

Cifrado Simétrico y el Estándar AES

El cifrado simétrico utiliza una misma clave para cifrar y descifrar. El Estándar de Cifrado Avanzado (AES, Advanced Encryption Standard) es un algoritmo de cifrado por bloques adoptado por el NIST (FIPS 197) [26] que opera sobre bloques de 128 bits con claves de 128, 192 o 256 bits. AES-256 es resistente a ataques de fuerza bruta con la capacidad computacional actual y es el estándar empleado tanto por las plataformas analizadas en el estado del arte como por agencias gubernamentales para la protección de información clasificada [24].

Modos de Operación y Cifrado Autenticado (AES-GCM)

Un algoritmo de cifrado por bloques como AES no se aplica directamente a mensajes de longitud arbitraria; requiere un modo de operación que defina cómo se procesan los bloques sucesivos. Los modos clásicos como el Encadenamiento de Bloques de Cifrado (CBC, Cipher Block Chaining) proveen confidencialidad, pero no integridad: un atacante puede modificar el texto cifrado sin que el destinatario detecte la alteración al momento del descifrado [49].

El modo GCM (Galois/Counter Mode) resuelve esta limitación al combinar el cifrado en modo Contador (CTR, Counter) con una función de autenticación basada en aritmética de campos de Galois. AES-GCM produce, además del texto cifrado, una etiqueta de autenticación (authentication tag) que permite verificar tanto la integridad del texto cifrado como la de datos adicionales no cifrados (AAD, Additional Authenticated Data, datos adicionales autenticados), tales como metadatos del expediente. Si un atacante modifica cualquier bit del texto cifrado o de los datos autenticados, la verificación de la etiqueta falla y el descifrado es rechazado [28], [50].

AES-256-GCM es el modo recomendado para el cifrado de expedientes y documentos almacenados. Cada operación de cifrado requiere un Vector de Inicialización (IV, Initialization Vector) único generado aleatoriamente, lo cual es un requisito crítico de GCM: la reutilización de un IV con la misma clave compromete tanto la confidencialidad como la autenticidad del esquema [50]. El modo GCM está especificado formalmente en NIST SP 800-38D y constituye una instancia de Cifrado Autenticado con Datos Asociados (AEAD, Authenticated Encryption with Associated Data), concepto formalizado en RFC 5116 [51].

En escenarios donde se gestionan múltiples documentos, el uso de una única clave para todo el repositorio concentra el riesgo: su compromiso expone la totalidad de la información. La arquitectura de cifrado por envoltorio (envelope encryption) mitiga este riesgo mediante dos niveles de claves. Una Clave de Cifrado de Clave (KEK, Key Encryption Key), almacenada de forma segura, se utiliza exclusivamente para envolver (cifrar) las Claves de Cifrado de Datos (DEK, Data Encryption Key) individuales, cada una generada aleatoriamente para un documento específico. El mecanismo de envolvimiento de claves está formalizado en NIST SP 800-38F [52] (Key Wrapping). Esta separación permite rotar la KEK re-cifrando únicamente las DEKs envueltas, sin necesidad de re-cifrar todos los documentos del repositorio.

2.3.3 No Repudio

El no repudio es el servicio de seguridad que impide que una entidad niegue haber realizado una operación, mediante la generación de evidencia criptográfica verificable sobre la autoría y el momento de su ejecución. A diferencia de la integridad (que protege al dato), el no repudio protege la autoría y se sustenta en dos pilares técnicos: la criptografía asimétrica y el sellado de tiempo [28].

Criptografía Asimétrica

La criptografía asimétrica emplea un par de claves matemáticamente vinculadas: una clave privada (conocida exclusivamente por su titular) y una clave pública (distribuida abiertamente). La propiedad fundamental es que lo cifrado con una clave solo puede descifrarse con la otra, y a partir de la clave pública es computacionalmente inviable derivar la clave privada. Los algoritmos de criptografía asimétrica más utilizados en el contexto de firma digital incluyen RSA (Rivest-Shamir-Adleman), basado en la dificultad de factorizar números enteros grandes, y ECDSA (Elliptic Curve Digital Signature Algorithm), basado en la dificultad del problema del logaritmo discreto sobre curvas elípticas [48], [53]. RSA define dos esquemas de firma principales en el estándar PKCS#1: la versión 1.5, ampliamente desplegada e interoperable con la infraestructura PKI existente, y PSS (Probabilistic Signature Scheme), que introduce aleatorización en el proceso de firma y ofrece una prueba de seguridad más robusta. Conforme a NIST SP 800-57 [37], una clave RSA de 3072 bits provee aproximadamente 128 bits de fortaleza de seguridad, equivalente a la de SHA-256 y AES-128.

Firma Digital

La firma digital es un esquema criptográfico que vincula la identidad del firmante con el contenido de un documento. El proceso opera en dos fases: en la generación, se calcula el hash del documento y se cifra con la clave privada del firmante, produciendo la firma; en la verificación, cualquier tercero puede descifrar la firma con la clave pública del firmante y comparar el resultado con el hash del documento. Si coinciden, se confirma que el documento no ha sido alterado y que fue firmado por el titular de la clave privada.

Este mecanismo provee simultáneamente integridad (cualquier modificación del documento invalida la firma) y no repudio de origen (solo el titular de la clave privada pudo haber generado la firma). La firma digital se distingue de la firma electrónica simple en que su validez no depende de la confianza en un proveedor de servicios, sino de propiedades matemáticas verificables de forma independiente [28], [53].

Certificados Digitales X.509

Para que una firma digital tenga valor probatorio, es necesario vincular la clave pública del firmante con su identidad legal. El estándar del Sector de Normalización de las Telecomunicaciones de la Unión Internacional de Telecomunicaciones (ITU-T) X.509 define el formato de los certificados digitales que establecen esta vinculación. Un certificado X.509 es una estructura de datos firmada por una Autoridad de Certificación (CA, Certificate Authority) que asocia una clave pública con un nombre distintivo (Distinguished Name), el cual puede incluir atributos como nombre legal, Registro Federal de Contribuyentes (RFC) o Clave Única de Registro de Población (CURP) en el contexto mexicano [54].

La cadena de confianza opera jerárquicamente: la CA raíz firma certificados de CAs intermedias, que a su vez emiten certificados a los usuarios finales. La verificación de una firma digital implica validar toda la cadena hasta una CA raíz de confianza, verificar que el certificado no haya sido revocado y confirmar su vigencia temporal [54]. El estándar RFC 5280 [44] (Internet X.509 PKI Certificate and CRL Profile) define el perfil de certificados y los dos mecanismos principales de revocación. Las Listas de Certificados Revocados (CRL, Certificate Revocation List) son documentos firmados por la CA que enumeran los certificados revocados antes de su fecha de expiración; se publican periódicamente y los verificadores las descargan para consulta local. El Protocolo de Estado de Certificado en Línea (OCSP, Online Certificate Status Protocol) permite consultar en tiempo real el estado de un certificado individual ante un responder autorizado. La elección entre ambos mecanismos depende de factores como la latencia aceptable, el volumen de certificados emitidos y la infraestructura disponible.

Sellado de Tiempo (RFC 3161)

La firma digital demuestra quién firmó un documento, pero no cuándo lo hizo. El sellado de tiempo complementa la firma al proveer evidencia criptográfica del momento en que se realizó la operación. El protocolo estándar para este servicio es RFC 3161 [27] (Internet X.509 PKI Time-Stamp Protocol), que define la interacción entre un cliente y una Autoridad de Sellado de Tiempo (TSA, Time-Stamp Authority).

El flujo opera de la siguiente manera: el cliente calcula el hash del documento y lo envía a la TSA en una solicitud de sello de tiempo (TimeStampReq). La TSA genera un token de sello de tiempo (TimeStampToken) que contiene el hash recibido, la fecha y hora precisa del sello, y la firma digital de la propia TSA sobre estos datos. El token resultante constituye prueba de que el documento existía en esa forma exacta en ese momento específico, sin que la TSA necesite conocer el contenido del documento.

En el contexto mexicano, la NOM-151-SCFI-2016 establece que la constancia de conservación debe ser emitida por un Prestador de Servicios de Certificación (PSC) autorizado, que en la práctica opera como TSA conforme al protocolo RFC 3161. La integración de este servicio en un flujo de firma digital provee evidencia temporal con validez legal.

2.3.4 Autenticación y Control de Acceso

La autenticación es el proceso de verificar la identidad de un usuario antes de permitirle el acceso a un recurso. El control de acceso determina, una vez autenticado, qué operaciones puede realizar. Ambos servicios son complementarios y su implementación adecuada es requisito para la validez de los servicios criptográficos: una firma digital carece de valor probatorio si el acceso a la clave privada del firmante no está debidamente protegido [28].

Autenticación Basada en Certificados Digitales

La autenticación mediante certificados digitales X.509 se basa en un esquema en que el usuario demuestra posesión de su clave privada firmando un desafío criptográfico generado por el servidor (challenge-response). Este mecanismo provee un nivel de aseguramiento superior a las contraseñas, ya que la clave privada nunca se transmite por la red y su compromiso requeriría acceso físico al dispositivo del usuario o la vulneración de su almacén de claves [55].

Autenticación por Múltiples Factores (MFA)

La Autenticación por Múltiples Factores (MFA) requiere la presentación de al menos dos categorías de evidencia de identidad: algo que el usuario sabe (contraseña), algo que posee (dispositivo que genera códigos temporales) o algo que es (biometría). La combinación de factores reduce significativamente el riesgo de acceso no autorizado, ya que el compromiso de un solo factor resulta insuficiente para suplantar la identidad del usuario [55]. El NIST SP 800-63B Rev 4 [56] (Digital Identity Guidelines: Authentication and Lifecycle Management) define tres Niveles de Aseguramiento de Autenticación (AAL): AAL1 (factor único), AAL2 (dos factores, uno de los cuales puede ser software) y AAL3 (dos factores con al menos uno basado en hardware criptográfico). El mecanismo TOTP (Time-Based One-Time Password), especificado en RFC 6238 [19], genera códigos temporales a partir de un secreto compartido y la hora actual, utilizando HMAC-SHA1 (Código de Autenticación de Mensajes basado en Hash con SHA-1, cuya seguridad para esta aplicación está avalada por NIST SP 800-107 Rev 1 [57]) como función base. TOTP se construye sobre HOTP (HMAC-Based One-Time Password, RFC 4226 [58]), reemplazando el contador por una marca temporal truncada. Ambos protocolos son interoperables con aplicaciones autenticadoras ampliamente adoptadas como Google Authenticator y Microsoft Authenticator.

Hashing de Contraseñas

El almacenamiento seguro de contraseñas requiere funciones de hashing especializadas, distintas de las funciones hash criptográficas de propósito general como SHA-256. Mientras que SHA-256 está diseñada para ser rápida (lo cual es deseable para verificar integridad de documentos), una función de hashing de contraseñas debe ser deliberadamente lenta y consumir recursos significativos de memoria, de modo que un atacante que obtenga la base de datos no pueda probar combinaciones masivamente [28].

Argon2, ganador de la Password Hashing Competition en 2015 y estandarizado en RFC 9106 [59], [60], fue diseñado específicamente para ser resistente a ataques con hardware especializado (GPUs y ASICs). Su propiedad distintiva es la dureza de memoria (memory-hardness): el algoritmo requiere una cantidad configurable de memoria durante su ejecución, lo que encarece proporcionalmente la construcción de hardware de ataque masivo. Argon2 define tres variantes: Argon2d (resistente a ataques de compromiso tiempo-memoria), Argon2i (resistente a ataques de canal lateral) y Argon2id (híbrido que combina las ventajas de ambas, recomendado por la OWASP (Open Worldwide Application Security Project, Proyecto Abierto de Seguridad de Aplicaciones Web) [61] para almacenamiento de contraseñas). Los tres parámetros de costo configurables son: memoria requerida (m), número de iteraciones (t) y grado de paralelismo (p). El NIST SP 800-63B Rev 4 [56] recomienda el uso de funciones de hashing de contraseñas con dureza de memoria, citando explícitamente a Argon2id como opción preferente para nuevas implementaciones. Una alternativa ampliamente utilizada es bcrypt, que incorpora un factor de costo ajustable y un salt aleatorio por contraseña, aunque carece de dureza de memoria configurable [48].

Control de Acceso Basado en Roles (RBAC)

El Control de Acceso Basado en Roles (RBAC, Role-Based Access Control) es un modelo de autorización en el que los permisos no se asignan directamente a los usuarios, sino a roles que representan funciones dentro de la organización. Cada usuario hereda los permisos del rol o roles

que tiene asignados. En el contexto del despacho, los roles típicos incluyen socio (acceso completo y capacidad de firma), abogado asociado (gestión de expedientes asignados), asistente (consulta y carga de documentos) y cliente (acceso limitado a su propio expediente mediante el portal de comunicación). Este modelo simplifica la administración de permisos y facilita el cumplimiento del principio de mínimo privilegio [62].

2.4 Gestión de Datos Híbrida

Una arquitectura de almacenamiento híbrida que combine almacenamiento relacional (SQL) y no relacional (NoSQL) se justifica por la diversidad de los datos manejados en el ámbito jurídico y las obligaciones legales de retención.

2.4.1 Almacenamiento Relacional (SQL)

El modelo relacional se utiliza para la gestión de datos estructurados con relaciones definidas: catálogo de clientes, asignación de casos, roles de acceso y registros de contratos. La integridad referencial que provee el modelo relacional —mediante restricciones de clave primaria, clave foránea y restricciones de dominio— garantiza la coherencia de los registros administrativos y procesales. Además, el modelo relacional facilita la implementación de RBAC a nivel de base de datos, asegurando que las políticas de acceso se apliquen de forma consistente.

2.4.2 Almacenamiento No Relacional (NoSQL)

Los expedientes legales contienen información de estructura variable: documentos PDF (Portable Document Format), evidencias multimedia, transcripciones de audiencias y metadatos que difieren entre tipos de caso. Un esquema NoSQL (Not Only SQL) orientado a documentos permite almacenar esta información sin la rigidez de un esquema tabular fijo, adaptando la estructura de cada registro a la naturaleza del contenido.

Desde la perspectiva de trazabilidad, el almacenamiento NoSQL se emplea para construir un registro de auditoría: cada operación sobre un documento (carga, modificación, firma, consulta) genera un registro que incluye el hash del estado del documento, el identificador del usuario, la marca de tiempo y, en su caso, el sello de tiempo de la TSA. Este registro, diseñado como estructura de solo inserción (append-only), conforma una cadena de custodia digital que permite reconstruir el historial completo de un expediente ante una auditoría o procedimiento judicial.

CAPÍTULO 3

Análisis y diseño

3.1 Metodología

Extreme Programming (XP) es una metodología ágil de desarrollo de software propuesta por Beck y Andres [63], orientada a equipos pequeños que trabajan con requisitos técnicos complejos o inciertos. Sus prácticas centrales incluyen programación en pares, desarrollo guiado por pruebas (TDD), spikes arquitectónicos para resolver incertidumbre técnica, e integración continua con propiedad colectiva del código.

Se eligió XP por tres razones vinculadas a las características del proyecto: primero, el equipo está compuesto por dos integrantes, lo que favorece la programación en pares como práctica central en lugar de ceremonias de coordinación más pesadas; segundo, la integración de mecanismos criptográficos (firma digital, sellado de tiempo, cifrado autenticado) y la vinculación con servicios externos como la Autoridad de Sellado de Tiempo introducen alta incertidumbre técnica, que XP aborda mediante *Spikes* (pruebas de concepto) y ciclos cortos de retroalimentación; tercero, el Desarrollo Guiado por Pruebas (TDD) resulta especialmente adecuado para validar la corrección de los servicios criptográficos, donde un error silencioso puede invalidar toda la evidencia generada.

Para abordar la complejidad del sistema, el proyecto estará segmentado en dos fases de iteraciones con objetivos específicos. El bloque inicial se enfocará en la planificación y la resolución de riesgos técnicos mediante *Spikes*, dejando el desarrollo iterativo continuo para el segundo bloque.

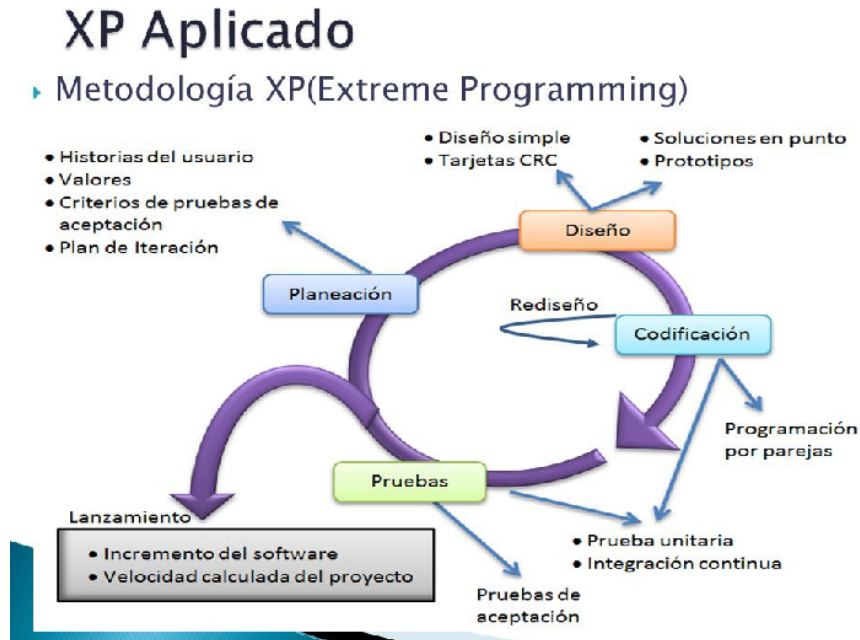


Figura 3.1: Ciclo de la metodología XP (Extreme Programming) aplicada al proyecto.

Plan de Iteraciones (10 semanas). El proyecto se estructura en dos bloques principales de 5 semanas cada uno. El primer bloque corresponde a la fase de planeación, investigación y diseño, enfocado en mitigar riesgos y modelar la solución. El segundo bloque abarca el ciclo continuo de codificación, integración y pruebas.

Fase I: Exploración, Diseño y Spikes Arquitectónicos. Durante estas 5 semanas, las iteraciones se centran en el levantamiento ágil, el análisis normativo y el diseño técnico del sistema, preparando el terreno para la implementación.

- **Iteración 1 (Semana 1) - Requerimientos y Fundamentos Criptográficos:** Investigación de la normativa mexicana referente al manejo de firmas digitales y comprobación de tiempo, y recolección de normativas sobre la Ley de Protección de Datos Personales. Investigación teórica de criptografía (Hash, RSA, Firma Digital) y levantamiento ágil de requerimientos funcionales y no funcionales.
- **Iteración 2 (Semana 2) - Análisis de Entorno y Sistemas Similares:** Investigación del Código de Procedimientos Penales Mexicanos aplicable al contexto digital. Análisis de sistemas similares en el mercado para la detección de brechas de seguridad y operativas.
- **Iteración 3 (Semana 3) - Análisis de Riesgos y Modelado Ágil:** Elaboración del análisis y matriz de riesgos. Traducción de los requerimientos mediante la redacción de Historias de Usuario priorizadas y diseño de los Casos de Uso del sistema.
- **Iteración 4 (Semana 4) - Diseño Arquitectónico y Modelo de Datos:** Diseño detallado de la arquitectura del sistema (Backend, Frontend y flujos de seguridad). Modelado de la base de datos híbrida, integrando bases de datos SQL para relaciones procesales y bases de datos Clave-Valor.
- **Iteración 5 (Semana 5) - Estrategia de Calidad y Cierre Documental:** Creación de la matriz

de pruebas (funcionales, de integración y criptográficas). Cierre y validación documental del diseño técnico para la conclusión de la primera fase.

Fase II: Construcción, Pruebas y Refactorización. Una vez validado el diseño, el desarrollo entra en un ciclo estricto de codificación iterativa mediante XP, utilizando programación en pares, Desarrollo Guiado por Pruebas (TDD) y entregas continuas.

- **Iteración 6 (Semana 6) - Base del Sistema y Control de Acceso:** Configuración del entorno de producción e implementación del esquema de base de datos híbrida. Desarrollo de la API de negocio básica y el sistema de control de acceso basado en roles (RBAC).
- **Iteración 7 (Semana 7) - Gestión Procesal y Documental:** Desarrollo de la interfaz de usuario (UI). Implementación de los módulos CRUD para expedientes, casos, contratos y documentos. Habilitación de la carga y visualización de documentos legales.
- **Iteración 8 (Semana 8) - Implementación de Confidencialidad e Integridad:** Integración de cifrado autenticado en el almacenamiento de expedientes y documentos, proporcionando confidencialidad (protección contra accesos no autorizados) e integridad (detección de modificaciones no autorizadas). Implementación de algoritmos de huella digital (Hashing) para verificación independiente de integridad en flujos que no requieran confidencialidad.
- **Iteración 9 (Semana 9) - Implementación del No Repudio (Contratos):** Integración de la firma digital (X.509) en el flujo de aceptación de contratos. Vinculación con los servicios de Autoridad de Sellado de Tiempo para el cumplimiento de la NOM-151.
- **Iteración 10 (Semana 10) - Pruebas Finales y Cierre:** Ejecución de la matriz de pruebas diseñada en la Fase I. Pruebas de usabilidad con usuarios representativos. Corrección de errores, refactorización final de código y elaboración de los manuales técnicos y de usuario.

3.2 Historias de Usuario

Las historias de usuario constituyen el instrumento de captura de requerimientos empleado por la metodología XP. Cada historia se redacta desde la perspectiva del actor que interactúa con el sistema, en lenguaje del dominio jurídico, estableciendo el rol, la necesidad y el beneficio esperado. Las historias se organizan en siete secciones funcionales que cubren la totalidad de los flujos del prototipo, desde la gestión de identidad hasta la operación y monitoreo del despacho. La formalización técnica de cada historia se realiza posteriormente en los casos de uso (sección 3.3), donde se especifican los flujos, precondiciones, postcondiciones y los mecanismos concretos de implementación.

3.2.1 Autenticación, Acceso y Gestión de Identidad

- **HU-01 — Registro de despacho.** Como socio fundador, quiero registrar mi despacho en el sistema proporcionando los datos de la firma, para disponer de un espacio propio y aislado donde gestionar los expedientes y al equipo de trabajo.
- **HU-02 — Selección de plan de servicio.** Como socio fundador, quiero elegir un plan de servicio (Starter o Professional) al momento del registro, para que el sistema habilite las funcionalidades y los límites de usuarios correspondientes al nivel contratado.

- **HU-03 — Invitación de miembros al equipo.** Como socio del despacho, quiero invitar nuevos colaboradores mediante correo electrónico asignándoles un perfil (Litigante o Paralegal), para que puedan acceder al sistema con los permisos apropiados a su función.
- **HU-04 — Aceptación de invitación.** Como colaborador invitado, quiero aceptar la invitación recibida por correo y completar mi registro, para incorporarme al despacho con el perfil que me fue asignado.
- **HU-05 — Inicio de sesión con credenciales.** Como usuario del sistema, quiero autenticarme con mi correo y contraseña, para acceder a las funciones habilitadas según mi perfil.
- **HU-06 — Inicio de sesión con certificado digital.** Como socio del despacho, quiero iniciar sesión presentando mi certificado digital, para acceder al sistema con un nivel de seguridad superior que vincule mi identidad de forma verificable con la sesión.
- **HU-07 — Verificación en dos pasos.** Como cliente del despacho, quiero confirmar mi identidad con un código temporal generado en mi dispositivo después de ingresar mi contraseña, para que mi expediente esté protegido ante el robo o filtración de la contraseña.
- **HU-08 — Recuperación de contraseña.** Como usuario del sistema, quiero solicitar la recuperación de mi contraseña mediante correo electrónico, para restablecer el acceso a mi cuenta sin necesidad de contactar al administrador.
- **HU-09 — Cierre de sesión por inactividad.** Como usuario del sistema, quiero que mi sesión se cierre automáticamente tras un periodo de inactividad, para prevenir accesos no autorizados si abandono mi equipo de trabajo sin cerrar sesión.
- **HU-10 — Restricción de acceso por perfil.** Como socio del despacho, quiero que cada miembro del equipo solo pueda acceder a los módulos y operaciones que corresponden a su perfil, para garantizar que únicamente las personas autorizadas realicen operaciones sensibles.
- **HU-11 — Baja de miembros del equipo.** Como socio del despacho, quiero dar de baja a un colaborador, para revocar de inmediato su acceso al sistema y a los expedientes del despacho.

3.2.2 Gestión Procesal Penal (Ciclo de Vida del Expediente)

- **HU-12 — Creación de expediente penal.** Como Litigante, quiero registrar un nuevo expediente ingresando el Número Único de Caso, la Carpeta Judicial, el tipo de delito y los datos generales del asunto, para que quede disponible en el sistema con estado inicial “Investigación”.
- **HU-13 — Registro de participantes del caso.** Como Litigante, quiero vincular a un expediente a las personas y autoridades que participan en el proceso (imputado, víctima, defensor, juez, Ministerio Público, entre otros) con sus datos identificadores y su rol dentro del proceso, para conformar el directorio de participantes del caso.
- **HU-14 — Avance de etapa procesal.** Como Litigante, quiero avanzar un expediente a la siguiente etapa procesal cargando el documento que lo habilita (escrito de acusación para pasar a Intermedia, auto de apertura para pasar a Juicio Oral), para que el sistema registre el cambio y habilite las funciones correspondientes a la nueva etapa.

- **HU-15 — Bloqueo de avance sin documento habilitante.** Como Litigante, quiero que el sistema no permita avanzar de etapa si no se ha cargado el documento procesal requerido, para evitar inconsistencias en la secuencia del expediente que comprometan su validez.
- **HU-16 — Historial de transiciones del expediente.** Como Litigante, quiero consultar la línea de tiempo completa de las transiciones de etapa de un expediente, con la fecha, el responsable y el documento asociado a cada cambio, para verificar que la secuencia procesal esté íntegra.
- **HU-17 — Actualización de datos del expediente.** Como Litigante, quiero actualizar los datos generales de un expediente (delitos, identificadores complementarios, información general), para mantener la información vigente sin alterar el historial de transiciones.
- **HU-18 — Vista de expedientes asignados.** Como Paralegal, quiero visualizar únicamente los expedientes que me han sido asignados, para concentrarme en los casos relevantes a mi trabajo sin exposición a información de otros asuntos.

3.2.3 Calendario Jurídico, Plazos y Alertas

- **HU-19 — Programación de audiencia.** Como Litigante, quiero agendar una audiencia seleccionando su tipo (inicial, intermedia, juicio oral, individualización de sanciones), fecha, hora, participantes y modalidad, para que quede vinculada al expediente correspondiente.
- **HU-20 — Activación automática de plazos tras audiencia.** Como Litigante, quiero que al registrar el resultado de una audiencia (por ejemplo, vinculación a proceso), el sistema calcule y active automáticamente los plazos derivados (como el de investigación complementaria), para no depender del cálculo manual de los términos.
- **HU-21 — Cómputo de plazos con días inhábiles.** Como Litigante, quiero que el sistema calcule las fechas de vencimiento descontando correctamente sábados, domingos y días inhábiles del calendario judicial de la entidad federativa, para obtener fechas precisas conforme a las reglas de cómputo del CNPP.
- **HU-22 — Configuración del calendario judicial.** Como socio del despacho, quiero configurar los días inhábiles por entidad federativa y fuero, para que los cómputos de plazos reflejen los periodos de receso de cada jurisdicción donde litiga el despacho.
- **HU-23 — Alertas de vencimiento próximo.** Como Litigante, quiero recibir notificaciones automáticas por correo y en el sistema cuando un plazo esté próximo a vencer, para tomar acciones oportunas y evitar consecuencias procesales irreversibles.
- **HU-24 — Calendario unificado del despacho.** Como Litigante, quiero visualizar en un calendario interactivo todas las audiencias programadas y los plazos límite de mis casos, con colores diferenciados por tipo de evento y acceso directo al expediente, para gestionar mi agenda procesal desde una sola vista.

3.2.4 Gestión Documental y Cadena de Custodia

- **HU-25 — Carga de documento al expediente.** Como Litigante, quiero cargar un documento procesal asociándolo a un expediente, para que quede almacenado de forma protegida y disponible para consulta por las personas autorizadas.

- **HU-26 — Clasificación de documentos.** Como Litigante, quiero asignar tipo documental, clasificación y etiquetas a cada documento cargado, para facilitar su organización, búsqueda y recuperación dentro del expediente.
- **HU-27 — Consulta de documentos según asignación.** Como Paralegal, quiero consultar y descargar los documentos de los expedientes que tengo asignados, para apoyar la gestión del caso sin acceder a información de asuntos no relacionados.
- **HU-28 — Registro automático de movimientos sobre documentos.** Como Litigante, quiero que cada operación sobre un documento o evidencia (carga, consulta, descarga, movimiento) quede registrada automáticamente con la fecha, la persona responsable y el tipo de operación, para contar con un historial completo que respalde la cadena de custodia del expediente.
- **HU-29 — Protección del historial de movimientos.** Como Litigante, quiero que ningún usuario, incluido el socio del despacho, pueda modificar ni eliminar los registros del historial de movimientos de documentos, para garantizar que la trazabilidad sea confiable ante cualquier requerimiento judicial.

3.2.5 Servicios de Protección de la Información

- **HU-30 — Huella digital del documento al momento de carga.** Como Litigante, quiero que al cargar un documento al sistema, se genere automáticamente una huella digital única del archivo, para contar con una referencia que permita comprobar en el futuro si el documento fue alterado.
- **HU-31 — Alerta de alteración en consulta posterior.** Como Litigante, quiero que cada vez que consulte un documento, el sistema verifique automáticamente que no haya sido modificado desde su carga y me alerte de inmediato si detecta alguna discrepancia, para tener certeza de la inalterabilidad de mis expedientes.
- **HU-32 — Protección del contenido almacenado.** Como Litigante, quiero que los documentos de mis expedientes se almacenen protegidos de forma que solo las partes autorizadas puedan acceder a su contenido, para que una intrusión al sistema no exponga la información de mis clientes.
- **HU-33 — Detección de manipulación en el almacenamiento.** Como Litigante, quiero que si alguien manipula directamente los archivos almacenados en el servidor, el sistema lo detecte y rechace la entrega del documento afectado notificándome la anomalía, para saber que cualquier intento de alteración será evidenciado.

3.2.6 Firma de Contratos y Constancia de Fecha

- **HU-34 — Firma de contrato con identidad verificable.** Como Litigante, quiero firmar un contrato de manera que mi identidad quede vinculada de forma verificable con el contenido del documento, para que ninguna de las partes pueda negar posteriormente haber suscrito el acuerdo.
- **HU-35 — Constancia de fecha y hora de la firma.** Como Litigante, quiero que al firmar un contrato, el sistema obtenga automáticamente una constancia emitida por una autoridad

certificadora que acredite la fecha y hora exacta de la firma, para que el documento tenga valor probatorio conforme a la normatividad mexicana.

- **HU-36 — Verificación de firma y constancia de un contrato.** Como usuario con acceso al contrato, quiero poder ejecutar una verificación que me indique si la firma es válida, si el certificado del firmante está vigente y si la constancia de fecha es auténtica, para evaluar la confiabilidad del documento sin depender de un tercero.
- **HU-37 — Detección de alteración en contrato firmado.** Como usuario con acceso al contrato, quiero que si el documento fue modificado después de firmado, la verificación me indique claramente que la firma ya no es válida y me explique la causa, para disponer de evidencia de que el contrato fue alterado.

3.2.7 Operación y Monitoreo

- **HU-38 — Tablero de control del despacho.** Como socio del despacho, quiero consultar un tablero con indicadores clave (casos activos, plazos por vencer próximamente, contratos pendientes de firma, carga de trabajo por abogado), para tener visibilidad del estado general de la operación.
- **HU-39 — Generación de informes.** Como socio del despacho, quiero generar informes filtrados por periodo, abogado responsable o estado de los casos, exportables en formato descargable, para analizar el desempeño y las métricas operativas de la firma.
- **HU-40 — Registro general de actividad.** Como socio del despacho, quiero consultar un registro completo e inalterable de todas las acciones realizadas en el sistema (quién realizó la acción, qué hizo, sobre qué recurso y cuándo), para disponer de trazabilidad ante auditorías internas o requerimientos judiciales.

3.3 Casos de Uso

Los casos de uso formalizan las historias de usuario definidas en la [sección 3.2](#), especificando los flujos de interacción entre los actores y el sistema, las condiciones que deben cumplirse antes y después de cada operación, y los escenarios alternos que el prototipo debe manejar. Cada caso de uso agrupa una o más historias de usuario en un flujo funcional cohesivo e incluye la trazabilidad hacia los requerimientos funcionales y no funcionales que lo respaldan. La especificación técnica de los mecanismos criptográficos (algoritmos, estándares y protocolos) se detalla en los requerimientos de la [sección 3.4](#); los casos de uso se limitan a describir el comportamiento observable del sistema desde la perspectiva del actor.

3.3.1 Autenticación, Acceso y Gestión de Identidad

CU-01 — Registro de despacho y selección de plan

Tabla 3.1: Caso de uso CU-01: Registro de despacho y selección de plan.

ID	CU-01
Nombre	Registro de despacho y selección de plan
Actor principal	Socio fundador
Actores secundarios	Sistema de correo transaccional
Precondiciones	El usuario no posee una cuenta activa en el sistema.
Flujo principal	1. El usuario accede al formulario de registro. 2. Ingresa los datos del despacho (nombre de la firma, domicilio fiscal, datos de contacto). 3. Selecciona un plan de servicio (Starter o Professional). 4. Establece sus credenciales de acceso (correo y contraseña). 5. El sistema valida los datos ingresados y crea un tenant aislado con el plan seleccionado. 6. El sistema envía un correo de confirmación al socio fundador. 7. El socio fundador confirma su correo electrónico mediante el enlace recibido. 8. El sistema activa la cuenta y redirige al tablero de control del despacho.
Flujos alternos	4a. La contraseña no cumple las políticas de complejidad → el sistema indica los requisitos faltantes. 5a. El correo electrónico ya está registrado → el sistema informa que la cuenta existe y ofrece la opción de recuperación. 7a. El enlace de confirmación ha expirado → el sistema permite reenviar el correo de confirmación.
Postcondiciones	El tenant queda creado con aislamiento lógico, el plan activo y el socio fundador autenticado con rol Owner. Las credenciales se almacenan mediante funciones de hashing resistentes.
Derivado de	HU-01, HU-02
RF relacionados	RF-01, RF-02
RNF relacionados	RNF-01, RNF-02

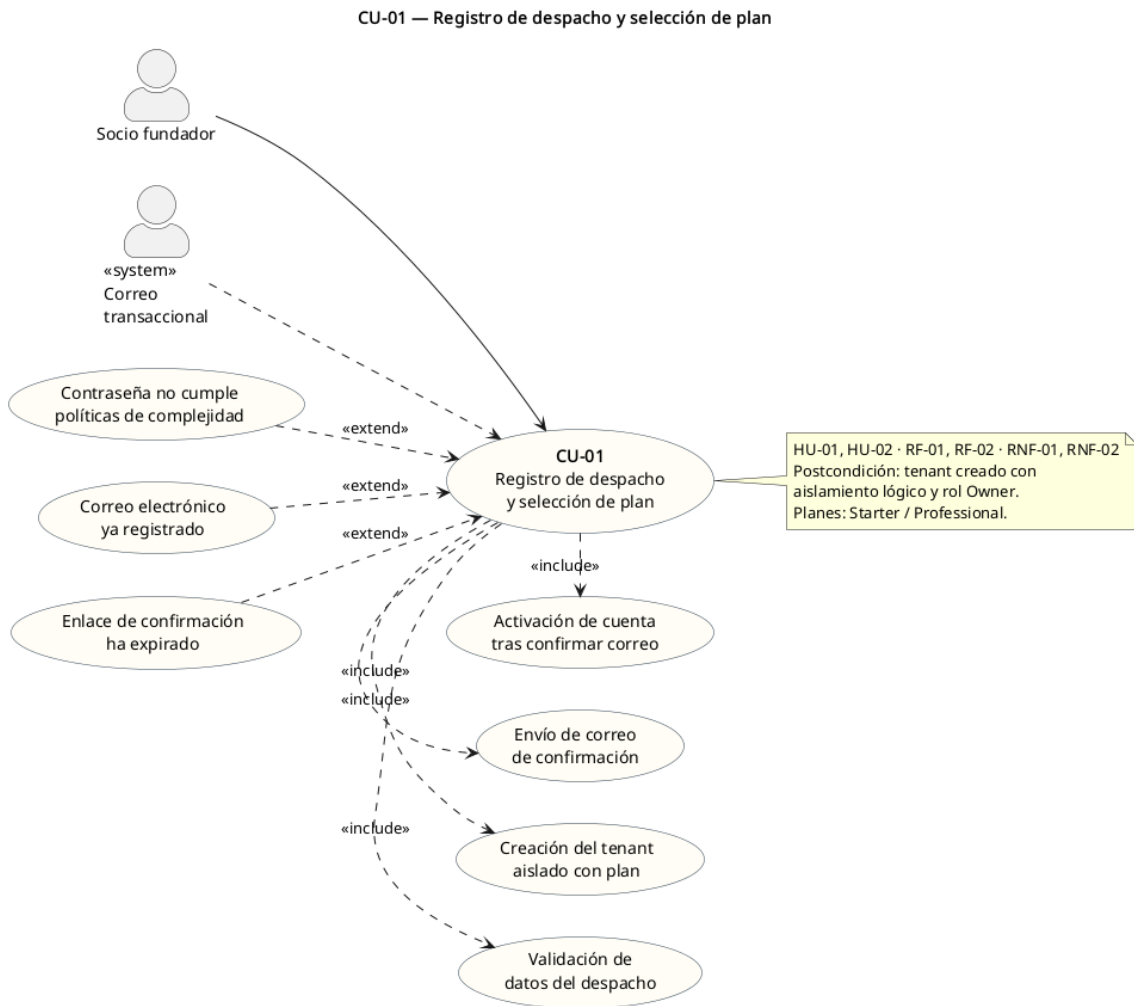


Figura 3.2: Diagrama CU-01. Registro de despacho y selección de plan.

CU-02 — Gestión del ciclo de vida de miembros del equipo**Tabla 3.2:** Caso de uso CU-02: Gestión del ciclo de vida de miembros del equipo.

ID	CU-02
Nombre	Gestión del ciclo de vida de miembros del equipo
Actor principal	Owner
Actores secundarios	Colaborador invitado, sistema de correo transaccional
Precondiciones	El Owner tiene sesión activa.
Flujo principal (alta)	1. El Owner accede al módulo de gestión de equipo. 2. Ingresa el correo electrónico del nuevo miembro y selecciona el perfil a asignar (Litigante o Paralegal). 3. El sistema verifica que el tenant no ha alcanzado el límite de usuarios del plan contratado. 4. El sistema genera un enlace de invitación con vigencia limitada y lo envía por correo. 5. El colaborador invitado accede al enlace, completa su registro con sus datos personales y establece su contraseña. 6. El sistema valida los datos, crea la cuenta asociada al tenant con el perfil indicado y registra la operación en la bitácora. 7. El nuevo miembro accede al sistema con las funciones habilitadas según su perfil.
Flujo principal (baja)	1. El Owner accede al módulo de gestión de equipo. 2. Selecciona al miembro que desea dar de baja. 3. El sistema solicita confirmación de la acción. 4. El Owner confirma la baja. 5. El sistema revoca de inmediato el acceso del colaborador, invalida sus sesiones activas y registra la operación en la bitácora. 6. Los expedientes y documentos asociados al colaborador permanecen en el sistema sin modificación; únicamente se revoca el acceso.
Flujos alternos	2a. (Alta) El correo ya pertenece a un miembro activo del despacho → el sistema rechaza la invitación e informa el motivo. 3a. (Alta) El tenant ha alcanzado el límite de usuarios → el sistema bloquea la invitación e indica la necesidad de actualizar el plan. 5a. (Alta) El enlace de invitación ha expirado → el sistema muestra un mensaje informativo; el Owner debe reenviar la invitación. 2b. (Baja) El Owner intenta darse de baja a sí mismo → el sistema rechaza la operación, ya que el tenant requiere al menos un Owner activo.
Postcondiciones	(Alta) El colaborador queda registrado en el tenant con el perfil asignado. (Baja) El acceso del colaborador queda revocado de inmediato. En ambos casos, la operación se registra en la bitácora de actividad.
Derivado de	HU-03, HU-04, HU-11
RF relacionados	RF-04
RNF relacionados	RNF-01, RNF-02

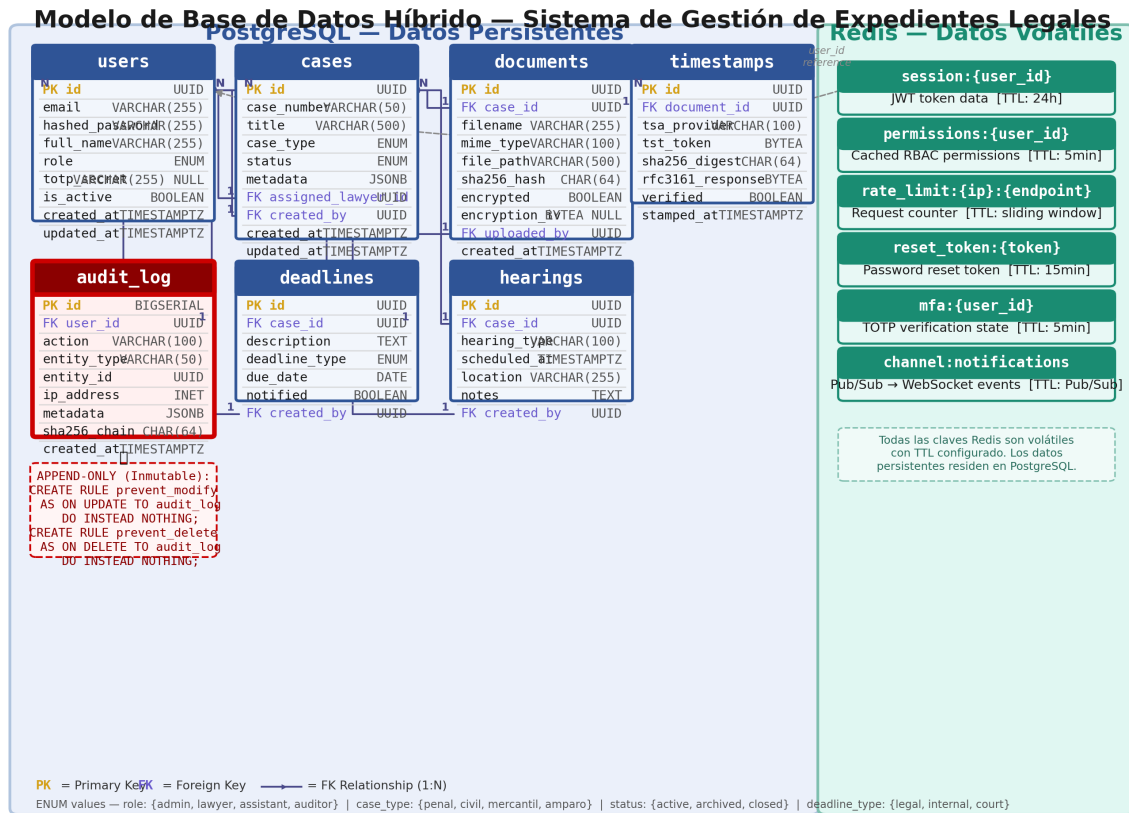


Figura 3.3: Diagrama CU-02. Gestión del ciclo de vida de miembros del equipo.

CU-03 — Inicio de sesión y gestión de sesiones**Tabla 3.3:** Caso de uso CU-03: Inicio de sesión y gestión de sesiones.

ID	CU-03
Nombre	Inicio de sesión y gestión de sesiones
Actor principal	Usuario del sistema (Owner, Litigante, Paralegal, Cliente)
Actores secundarios	—
Precondiciones	El usuario posee una cuenta activa en el sistema.
Flujo principal	1. El usuario accede a la pantalla de inicio de sesión. 2. Ingresa su correo electrónico y contraseña. 3. El sistema verifica las credenciales contra el hash almacenado. 4. Si el usuario tiene habilitada la verificación en dos pasos, el sistema solicita el código temporal generado en su dispositivo. 5. El usuario ingresa el código y el sistema lo valida. 6. El sistema crea una sesión autenticada, registra el inicio de sesión en la bitácora y redirige al usuario al módulo correspondiente a su perfil.
Flujos alternos	3a. Las credenciales son incorrectas → el sistema informa el error sin revelar cuál campo es inválido. 3b. El usuario es Owner y elige autenticarse con certificado digital → el sistema genera un desafío criptográfico; el usuario firma con su clave privada; el sistema verifica la firma contra el certificado registrado. 1a. El usuario selecciona la opción de recuperación de contraseña → el sistema solicita el correo electrónico asociado a la cuenta → envía un enlace de restablecimiento con vigencia limitada → el usuario accede al enlace y establece una nueva contraseña → el sistema la almacena mediante funciones de hashing resistentes, invalida las sesiones activas previas y confirma el restablecimiento. 5a. El código temporal es inválido o ha expirado → el sistema rechaza el acceso y permite reintentar. 6a. La sesión permanece inactiva por el tiempo configurado → el sistema la invalida y requiere nueva autenticación, preservando los datos no guardados.
Postcondiciones	El usuario queda autenticado con una sesión activa. El inicio de sesión, incluyendo método de autenticación utilizado y dirección IP, se registra en la bitácora.
Derivado de	HU-05, HU-06, HU-07, HU-08, HU-09
RF relacionados	RF-01, RF-03
RNF relacionados	RNF-02, RNF-05

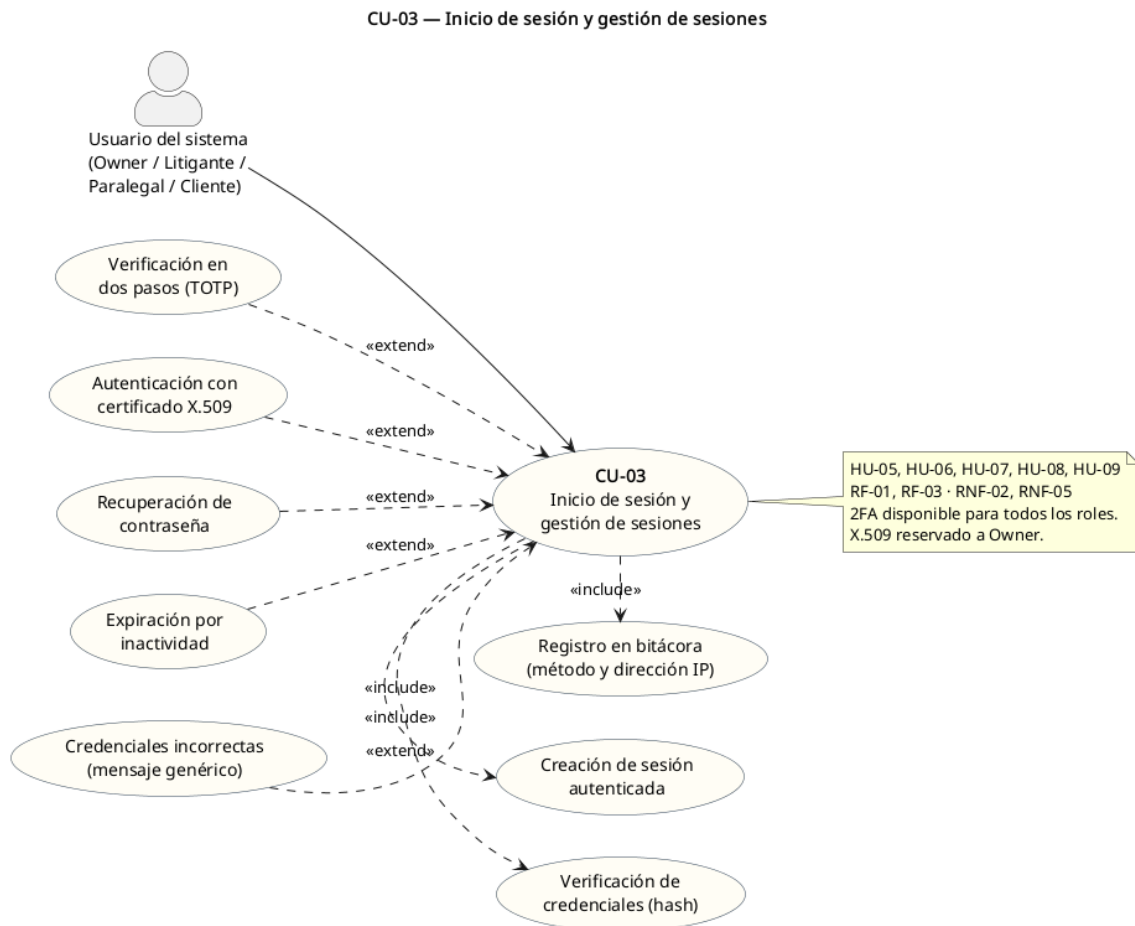
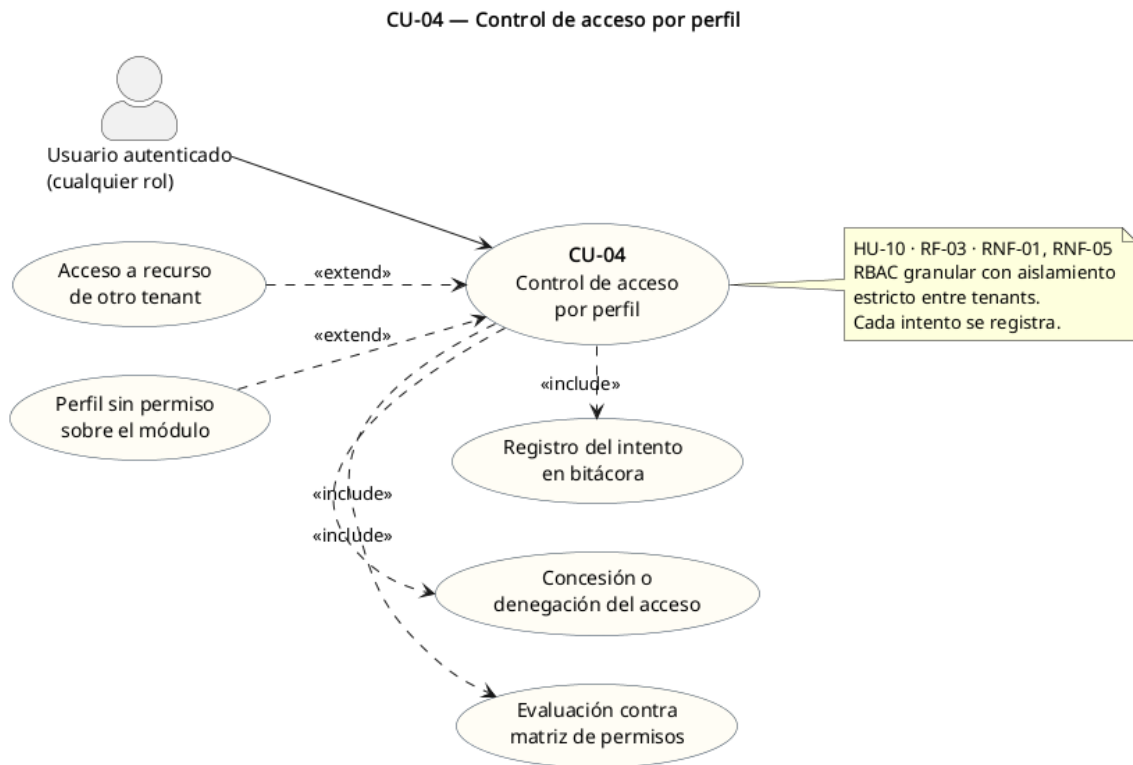


Figura 3.4: Diagrama CU-03. Inicio de sesión y gestión de sesiones.

CU-04 — Control de acceso por perfil**Tabla 3.4:** Caso de uso CU-04: Control de acceso por perfil.

ID	CU-04
Nombre	Control de acceso por perfil
Actor principal	Usuario autenticado (cualquier rol)
Actores secundarios	—
Precondiciones	El usuario tiene sesión activa.
Flujo principal	1. El usuario solicita acceso a un módulo o recurso del sistema. 2. El sistema evalúa el perfil del usuario contra la matriz de permisos del módulo solicitado. 3. Si el perfil tiene permiso, el sistema concede el acceso y presenta la interfaz correspondiente.
Flujos alternos	3a. El perfil no tiene permiso sobre el módulo solicitado → el sistema deniega el acceso con un mensaje explicativo y registra el intento en la bitácora. 3b. El usuario intenta acceder a un expediente de un tenant diferente al suyo → el sistema devuelve un error de autorización sin revelar la existencia del recurso.
Postcondiciones	El acceso queda concedido o denegado. Cada intento de acceso, exitoso o fallido, se registra en la bitácora.
Derivado de	HU-10
RF relacionados	RF-03
RNF relacionados	RNF-01, RNF-05

**Figura 3.5:** Diagrama CU-04. Control de acceso por perfil.

3.3.2 Gestión Procesal Penal (Ciclo de Vida del Expediente)

CU-05 — Registro y administración de expediente penal

Tabla 3.5: Caso de uso CU-05: Registro y administración de expediente penal.

ID	CU-05
Nombre	Registro y administración de expediente penal
Actor principal	Litigante
Actores secundarios	Paralegal (consulta)
Precondiciones	El Litigante tiene sesión activa y pertenece al tenant.
Flujo principal	1. El Litigante accede al módulo de gestión procesal y selecciona la opción de nuevo expediente. 2. Ingresa los identificadores oficiales: Número Único de Caso (NUC) y Carpeta Judicial. 3. Registra el tipo de delito, los datos generales del asunto y los metadatos asociados. 4. El sistema valida que los campos obligatorios estén completos y que los identificadores no estén duplicados dentro del tenant. 5. El sistema persiste el expediente con estado inicial “Investigación”, genera la marca de tiempo de creación y registra la operación en la bitácora.
Flujos alternos	4a. Faltan campos obligatorios (NUC o Carpeta Judicial) → el sistema rechaza el registro e indica los campos faltantes. 4b. El NUC ya existe en el tenant → el sistema informa la duplicidad.
Postcondiciones	El expediente queda registrado con estado “Investigación”, disponible para los usuarios autorizados del tenant.
Derivado de	HU-12, HU-17, HU-18
RF relacionados	RF-05
RNF relacionados	RNF-04, RNF-10

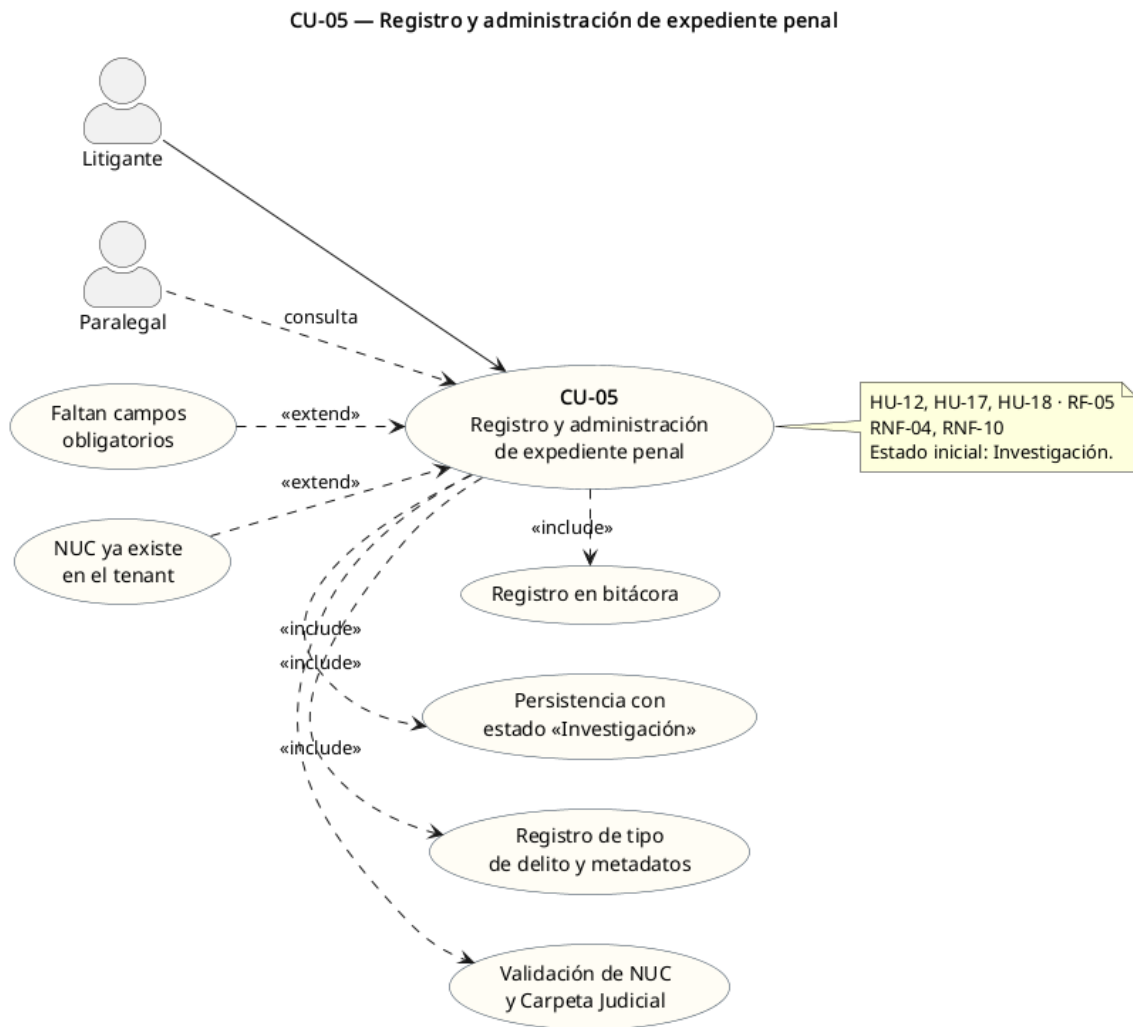


Figura 3.6: Diagrama CU-05. Registro y administración de expediente penal.

CU-06 — Gestión del directorio de participantes**Tabla 3.6:** Caso de uso CU-06: Gestión del directorio de participantes.

ID	CU-06
Nombre	Gestión del directorio de participantes
Actor principal	Litigante
Actores secundarios	—
Precondiciones	Existe un expediente activo al cual vincular participantes.
Flujo principal	1. El Litigante accede al expediente y selecciona el módulo de directorio de participantes. 2. Selecciona el tipo de sujeto procesal (imputado, víctima, defensor, juez de control, Ministerio Público, entre otros). 3. Ingresa los datos identificadores del participante según su tipo (nombre, CURP, cédula profesional, órgano jurisdiccional, según aplique). 4. El sistema valida los datos requeridos según el tipo de sujeto procesal y registra al participante vinculado al expediente.
Flujos alternos	3a. Para un juez de control, no se proporciona el órgano jurisdiccional ni la FIREL → el sistema rechaza el registro e indica los campos faltantes. 4a. El participante ya existe en el directorio del caso con el mismo rol → el sistema informa la duplicidad.
Postcondiciones	El participante queda vinculado al expediente con su rol procesal. Un mismo individuo puede tener roles distintos en expedientes diferentes.
Derivado de	HU-13
RF relacionados	RF-07
RNF relacionados	RNF-10

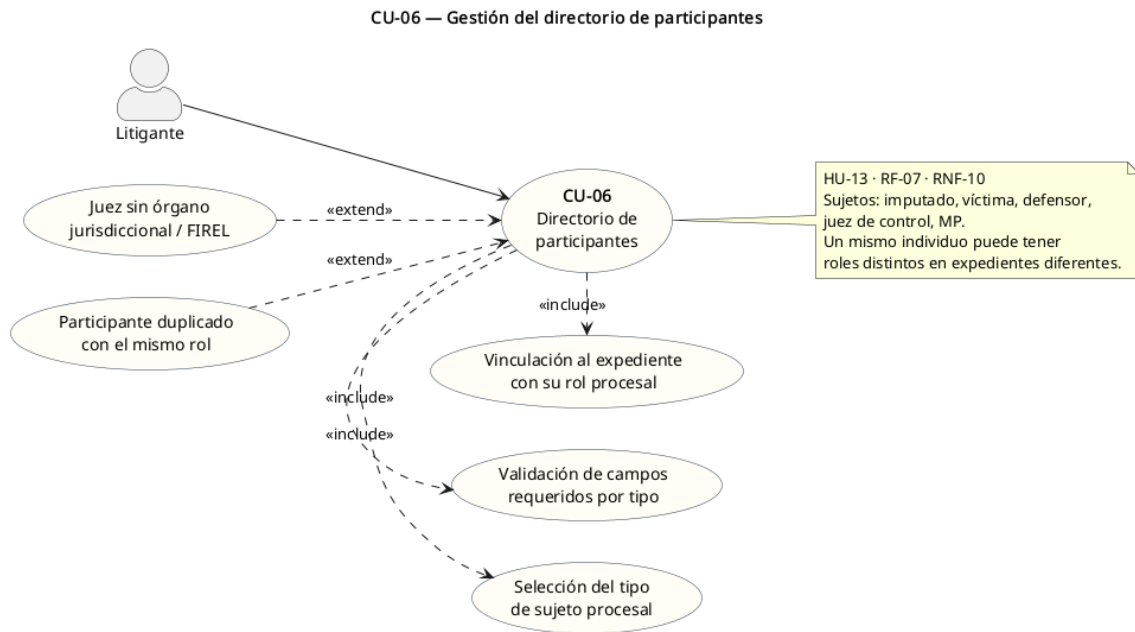


Figura 3.7: Diagrama CU-06. Gestión del directorio de participantes.

CU-07 — Transición de etapa procesal**Tabla 3.7:** Caso de uso CU-07: Transición de etapa procesal.

ID	CU-07
Nombre	Transición de etapa procesal
Actor principal	Litigante
Actores secundarios	—
Precondiciones	El expediente se encuentra en una etapa procesal que admite transición (Investigación, Intermedia o Juicio Oral).
Flujo principal	1. El Litigante accede al expediente y solicita avanzar a la siguiente etapa procesal. 2. El sistema solicita la carga del documento habilitante correspondiente (escrito de acusación para Investigación → Intermedia; auto de apertura para Intermedia → Juicio Oral). 3. El Litigante carga el documento procesal. 4. El sistema almacena el documento con las protecciones de integridad y confidencialidad correspondientes. 5. El sistema registra la transición de forma inmutable: marca de tiempo, usuario responsable y documento asociado. 6. El sistema habilita los módulos correspondientes a la nueva etapa.
Flujos alternos	2a. El Litigante intenta avanzar de etapa sin cargar el documento habilitante → el sistema rechaza la transición e indica el documento requerido. 3a. El documento cargado no corresponde al formato admitido → el sistema rechaza la carga.
Postcondiciones	El expediente se encuentra en la nueva etapa procesal. La transición queda registrada de forma inmutable en el historial del expediente y no puede revertirse.
Derivado de	HU-14, HU-15, HU-16
RF relacionados	RF-06
RNF relacionados	RNF-04, RNF-10

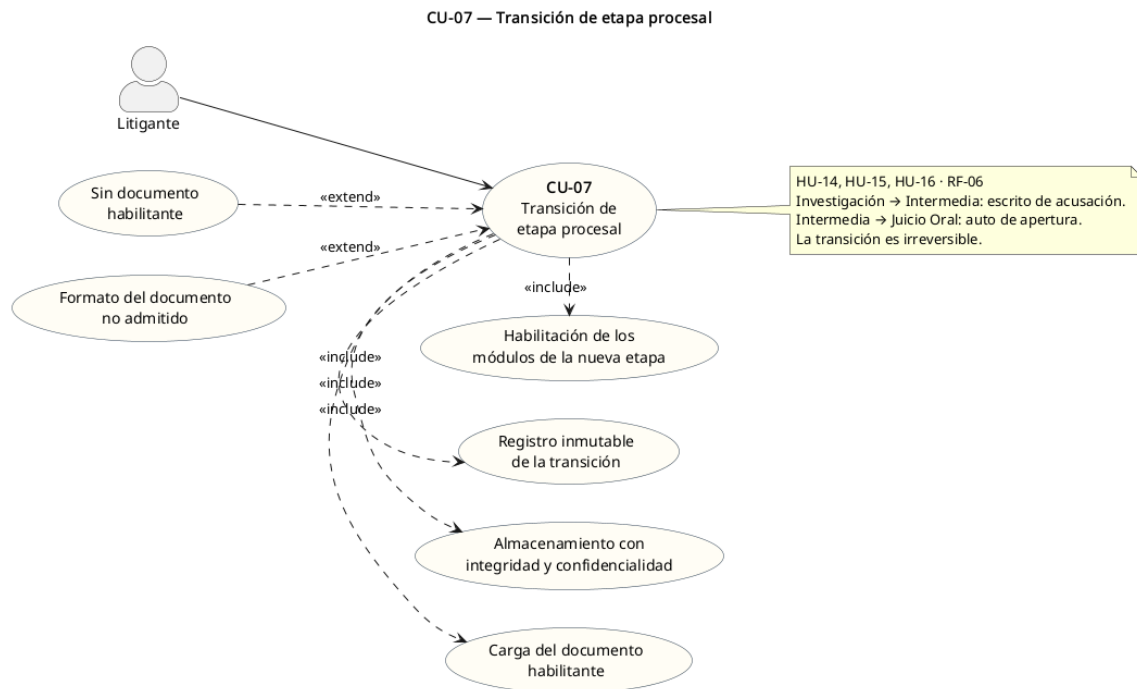


Figura 3.8: Diagrama CU-07. Transición de etapa procesal.

3.3.3 Calendario Jurídico, Plazos y Alertas

CU-08 — Programación de audiencia y activación de plazos

Tabla 3.8: Caso de uso CU-08: Programación de audiencia y activación de plazos.

ID	CU-08
Nombre	Programación de audiencia y activación de plazos
Actor principal	Litigante
Actores secundarios	Sistema de cómputo de plazos
Precondiciones	Existe un expediente activo con una etapa procesal que admite la audiencia a programar.
Flujo principal	1. El Litigante accede al expediente y selecciona la opción de programar audiencia. 2. Selecciona el tipo de audiencia del catálogo tipificado conforme al CNPP (inicial, intermedia, juicio oral, individualización de sanciones). 3. Ingresa fecha, hora, participantes y modalidad (presencial o videoconferencia). 4. El sistema valida la coherencia procesal (el tipo de audiencia corresponde a la etapa vigente del expediente). 5. El sistema registra la audiencia vinculada al expediente. 6. Al registrar el resultado de la audiencia (por ejemplo, vinculación a proceso), el sistema activa automáticamente los plazos derivados, calculando las fechas de vencimiento conforme a las reglas del artículo 94 del CNPP (véase §2.2.5) y al calendario de días inhábiles configurado.
Flujos alternos	4a. El tipo de audiencia no corresponde a la etapa procesal vigente → el sistema rechaza la programación. 6a. El resultado de la audiencia no genera plazos derivados → el sistema registra el resultado sin activar cálculos adicionales.
Postcondiciones	La audiencia queda registrada y visible en el calendario del despacho. Los plazos derivados, si los hay, quedan activos con sus fechas de vencimiento calculadas y las alertas preventivas programadas.
Derivado de	HU-19, HU-20, HU-21
RF relacionados	RF-08, RF-09
RNF relacionados	RNF-10

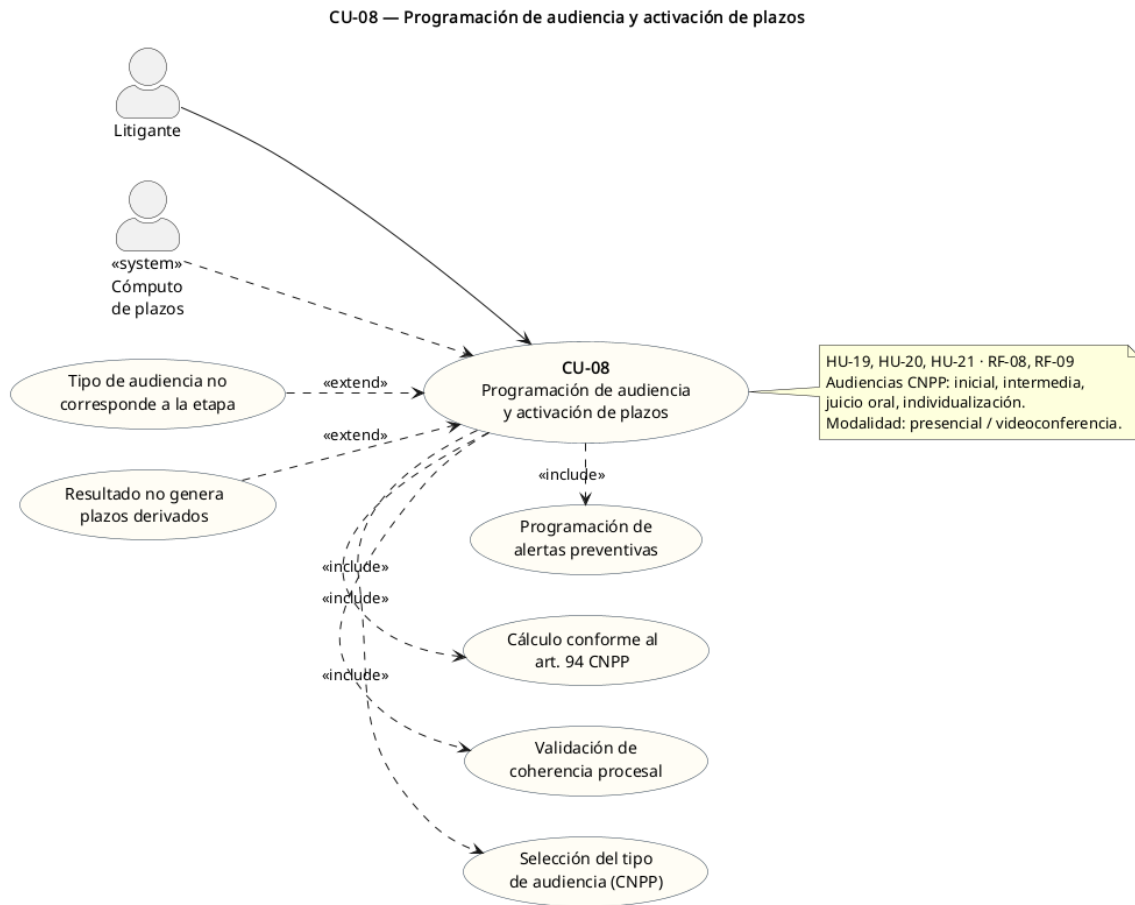
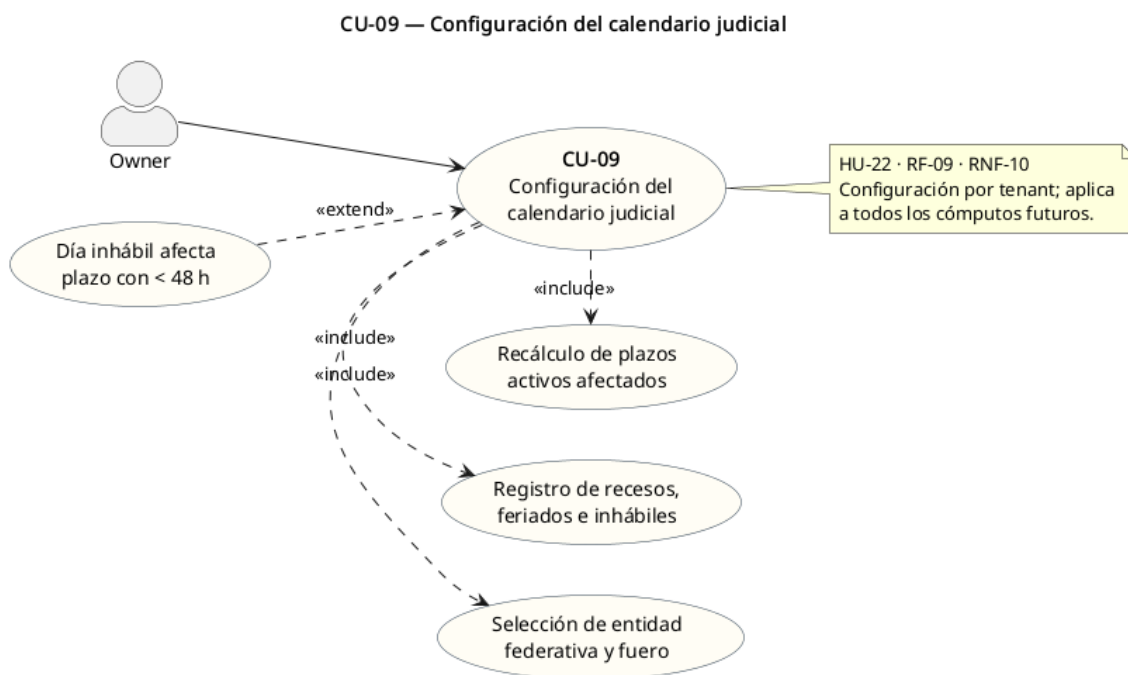


Figura 3.9: Diagrama CU-08. Programación de audiencia y activación de plazos.

CU-09 — Configuración del calendario judicial**Tabla 3.9:** Caso de uso CU-09: Configuración del calendario judicial.

ID	CU-09
Nombre	Configuración del calendario judicial
Actor principal	Owner
Actores secundarios	—
Precondiciones	El Owner tiene sesión activa.
Flujo principal	1. El Owner accede al módulo de configuración del despacho. 2. Selecciona la entidad federativa y el fuero para los cuales configurará los días inhábiles. 3. Registra los periodos de receso judicial, días feriados y días inhábiles específicos de la jurisdicción. 4. El sistema almacena la configuración y recalcula los plazos activos que dependan de ese calendario.
Flujos alternos	3a. Se registra un día inhábil que afecta un plazo con vencimiento inminente (menos de 48 horas) → el sistema recalcula la fecha y emite una alerta al Litigante responsable.
Postcondiciones	El calendario judicial del tenant queda actualizado. Todos los cálculos de plazos futuros utilizan la configuración vigente.
Derivado de	HU-22
RF relacionados	RF-09
RNF relacionados	RNF-10

**Figura 3.10:** Diagrama CU-09. Configuración del calendario judicial.

CU-10 — Monitoreo de plazos y emisión de alertas**Tabla 3.10:** Caso de uso CU-10: Monitoreo de plazos y emisión de alertas.

ID	CU-10
Nombre	Monitoreo de plazos y emisión de alertas
Actor principal	Sistema (proceso automático)
Actores secundarios	Litigante (receptor de alertas), sistema de correo transaccional
Precondiciones	Existen plazos activos en el sistema.
Flujo principal	1. El sistema ejecuta periódicamente la verificación de plazos activos. 2. Para cada plazo próximo a vencer (dentro del umbral configurado: 48 h y 24 h por defecto), el sistema genera una notificación. 3. La notificación se envía al Litigante responsable por correo electrónico y se muestra como alerta en el tablero de control. 4. El envío de la notificación se registra en la bitácora de actividad.
Flujos alternos	2a. El plazo ya venció sin que se registrara la actuación correspondiente → el sistema emite una alerta de nivel crítico.
Postcondiciones	El Litigante ha sido notificado de la proximidad del vencimiento. El envío queda registrado en la bitácora.
Derivado de	HU-23, HU-24
RF relacionados	RF-10, RF-11
RNF relacionados	RNF-06

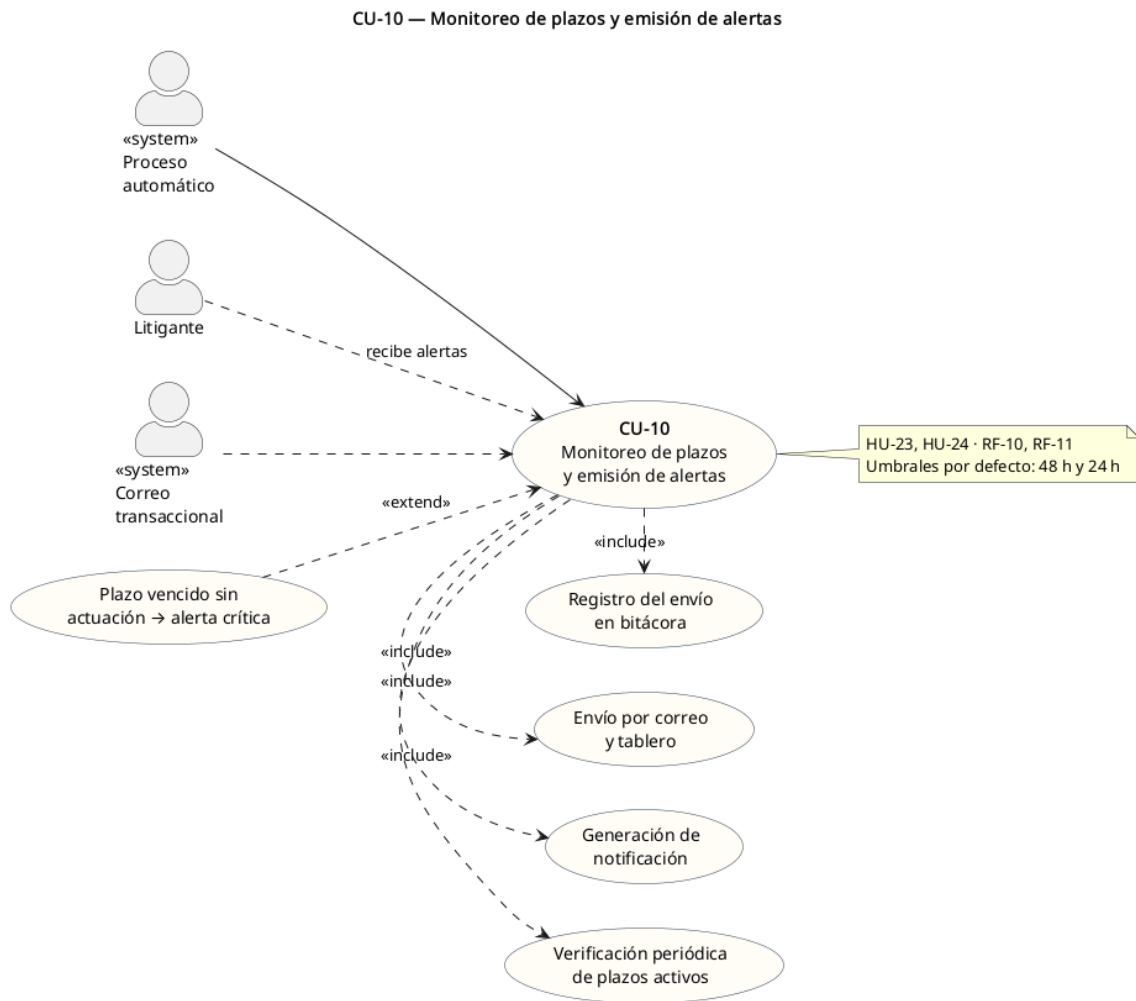


Figura 3.11: Diagrama CU-10. Monitoreo de plazos y emisión de alertas.

3.3.4 Gestión Documental y Cadena de Custodia

CU-11 — Carga y clasificación de documentos

Tabla 3.11: Caso de uso CU-11: Carga y clasificación de documentos.

ID	CU-11
Nombre	Carga y clasificación de documentos
Actor principal	Litigante
Actores secundarios	Paralegal (consulta posterior)
Precondiciones	Existe un expediente al cual asociar el documento. El usuario tiene perfil con permisos de carga.
Flujo principal	1. El Litigante accede al repositorio documental del expediente. 2. Selecciona el archivo a cargar (PDF, DOCX u otro formato admitido). 3. Asigna tipo documental, clasificación y etiquetas al documento. 4. El sistema calcula la huella digital del archivo al momento de la carga. 5. El sistema cifra el documento y lo almacena en el repositorio. 6. El sistema registra en la cadena de custodia: tipo de operación (carga), usuario responsable, marca de tiempo, huella digital del documento y estado del documento.
Flujos alternos	2a. El formato del archivo no está admitido → el sistema rechaza la carga e informa los formatos permitidos. 2b. El archivo excede el tamaño máximo admitido → el sistema rechaza la carga.
Postcondiciones	El documento queda almacenado cifrado, indexado con su huella digital y disponible para consulta por los perfiles autorizados. La operación queda registrada en la cadena de custodia.
Derivado de	HU-25, HU-26, HU-28, HU-30, HU-32
RF relacionados	RF-13, RF-14, RF-15
RNF relacionados	RNF-03, RNF-04

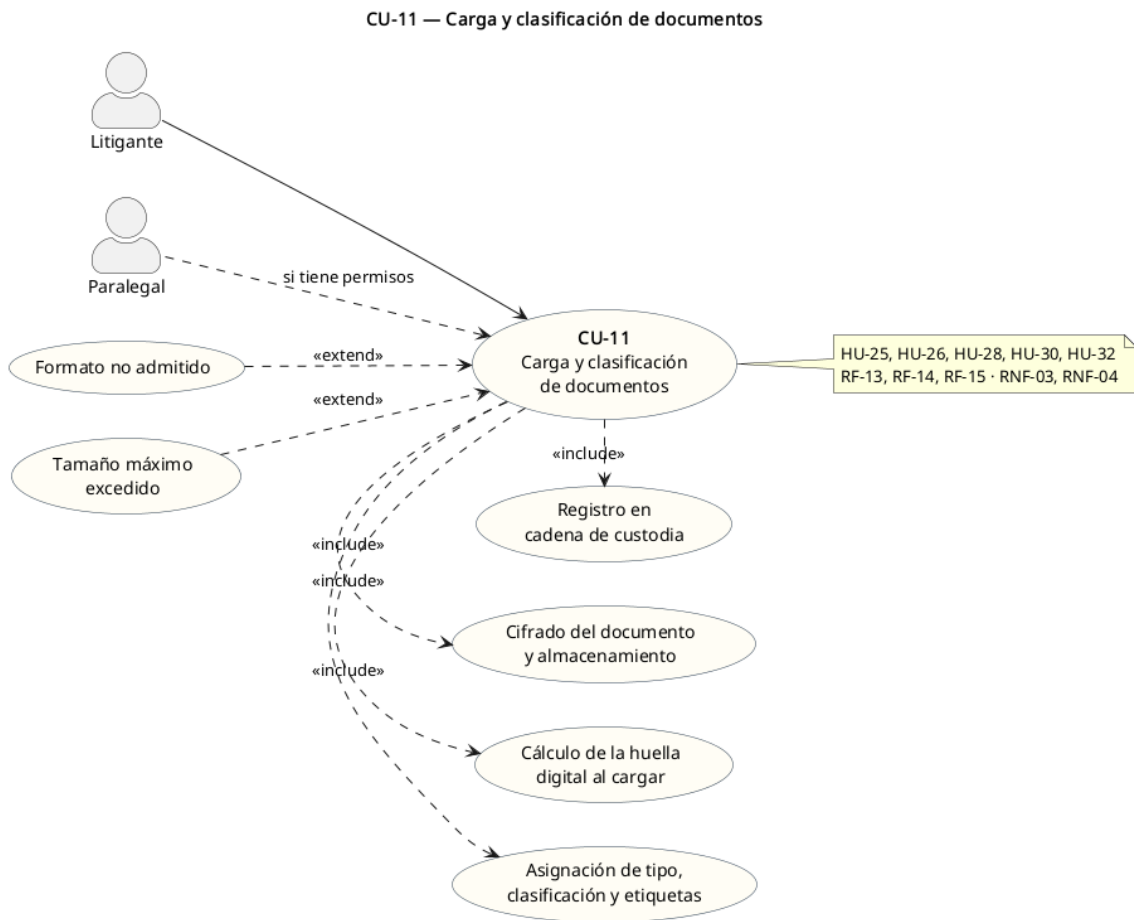


Figura 3.12: Diagrama CU-11. Carga y clasificación de documentos.

CU-12 — Consulta de documentos con verificación de integridad**Tabla 3.12:** Caso de uso CU-12: Consulta de documentos con verificación de integridad.

ID	CU-12
Nombre	Consulta de documentos con verificación de integridad
Actor principal	Litigante o Paralegal
Actores secundarios	—
Precondiciones	El usuario tiene perfil con acceso al expediente que contiene el documento.
Flujo principal	1. El usuario accede al repositorio documental del expediente. 2. Selecciona el documento a consultar. 3. El sistema verifica que el perfil del usuario tiene permiso de acceso al expediente. 4. El sistema descifra el documento. 5. El sistema recalcula la huella digital del documento descifrado y la compara con el valor de referencia almacenado al momento de la carga. 6. Si las huellas coinciden, el sistema entrega el documento al usuario. 7. La operación de consulta se registra en la cadena de custodia.
Flujos alternos	3a. El usuario no tiene permiso sobre el expediente → el sistema deniega el acceso. 4a. La verificación de la etiqueta de autenticación del cifrado falla (el contenido cifrado fue manipulado en el almacenamiento) → el sistema rechaza el descifrado, notifica al usuario y al Owner, y registra el incidente como alerta de seguridad. 5a. La huella digital recalculada no coincide con la referencia → el sistema alerta al usuario de que el documento fue modificado, bloquea la entrega y registra la discrepancia.
Postcondiciones	El usuario recibe el documento íntegro, o recibe una alerta explícita de alteración. La consulta y su resultado quedan registrados en la cadena de custodia.
Derivado de	HU-27, HU-29, HU-31, HU-33
RF relacionados	RF-12, RF-13, RF-14, RF-15
RNF relacionados	RNF-03, RNF-04

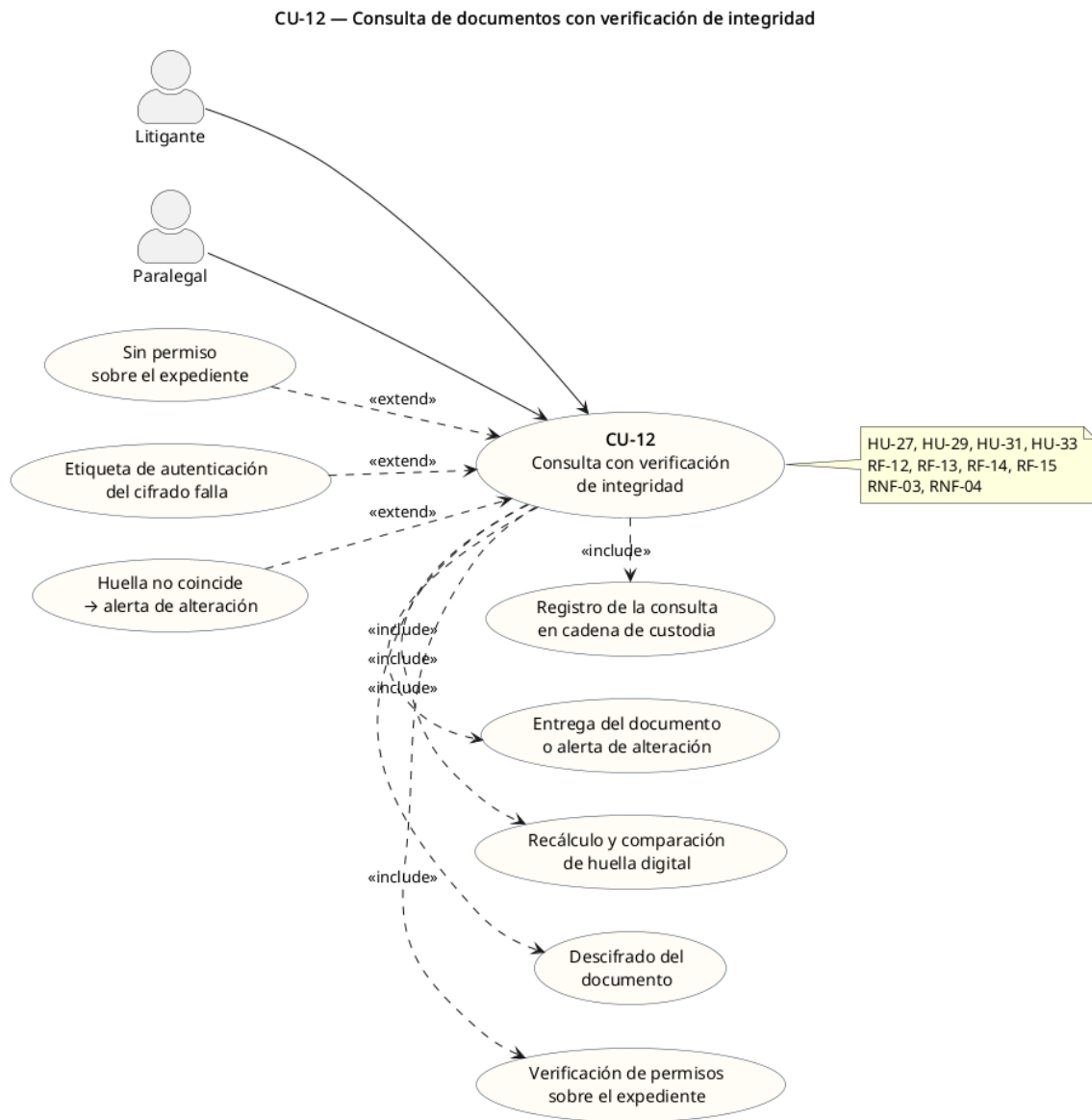


Figura 3.13: Diagrama CU-12. Consulta de documentos con verificación de integridad.

3.3.5 Firma de Contratos y Constancia de Fecha

CU-13 — Firma digital de contrato con sellado de tiempo

Tabla 3.13: Caso de uso CU-13: Firma digital de contrato con sellado de tiempo.

ID	CU-13
Nombre	Firma digital de contrato con sellado de tiempo
Actor principal	Litigante (firmante)
Actores secundarios	PSC autorizado (Cincel, como Autoridad de Sellado de Tiempo)
Precondiciones	El contrato existe en el repositorio en formato PDF y está listo para firma. El firmante tiene un certificado digital X.509 vigente registrado en el sistema.
Flujo principal	1. El Litigante accede al contrato y selecciona la opción de firma digital. 2. El sistema presenta el contenido del contrato y solicita confirmación explícita de la acción de firma. 3. El Litigante confirma la firma. 4. El sistema calcula la huella digital del contrato. 5. El sistema firma la huella digital con la clave privada del certificado X.509 del firmante, vinculando criptográficamente su identidad con el contenido del documento. 6. El sistema envía la huella digital al PSC autorizado mediante el protocolo de sellado de tiempo. 7. El PSC retorna el token de sello de tiempo que acredita la fecha y hora exacta de la operación. 8. El sistema almacena el contrato firmado junto con la firma digital, los metadatos del certificado y el token de sello de tiempo. 9. La operación se registra en la bitácora de actividad y en la cadena de custodia del expediente.
Flujos alternos	2a. El certificado del firmante ha expirado o está revocado → el sistema informa la situación e impide la firma. 6a. El PSC no responde dentro del tiempo límite → el sistema encola la solicitud para reintento automático y notifica al Litigante del retraso en la constancia. 7a. El token recibido no supera la validación de formato → el sistema rechaza el sello, registra el error y reintenta con el PSC.
Postcondiciones	El contrato queda firmado con evidencia criptográfica verificable de la identidad del firmante y del momento exacto de la firma. La constancia tiene validez conforme a la NOM-151-SCFI-2016.
Derivado de	HU-34, HU-35
RF relacionados	RF-16, RF-17
RNF relacionados	RNF-03, RNF-11

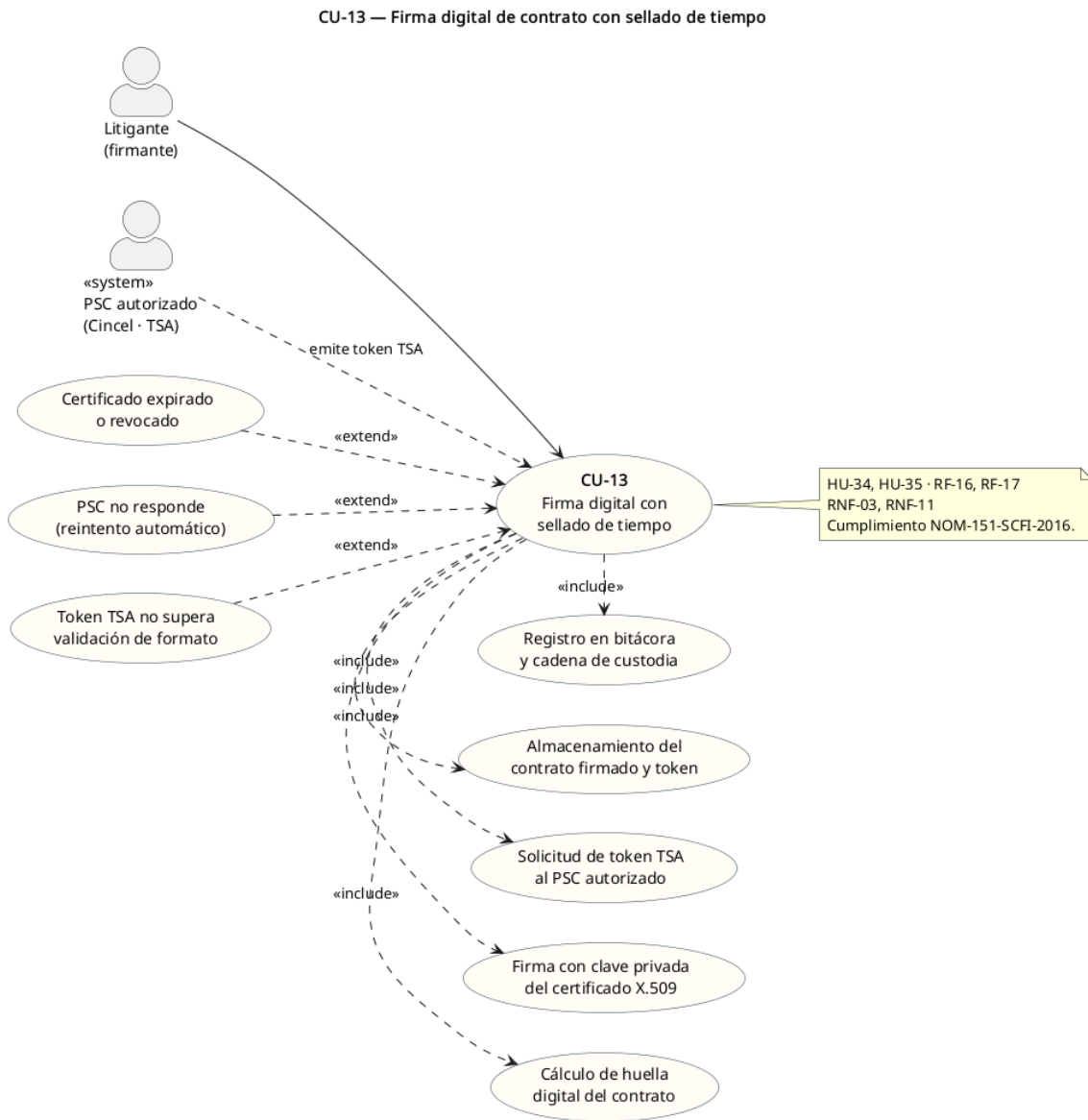


Figura 3.14: Diagrama CU-13. Firma digital de contrato con sellado de tiempo.

CU-14 — Verificación de firma digital y sello de tiempo**Tabla 3.14:** Caso de uso CU-14: Verificación de firma digital y sello de tiempo.

ID	CU-14
Nombre	Verificación de firma digital y sello de tiempo
Actor principal	Usuario autenticado con acceso al contrato
Actores secundarios	—
Precondiciones	El contrato ha sido firmado digitalmente y posee un token de sello de tiempo asociado.
Flujo principal	1. El usuario accede al contrato firmado y selecciona la opción de verificación. 2. El sistema recalcula la huella digital del contrato actual. 3. El sistema verifica la firma digital: descifra la firma con la clave pública del certificado X.509 del firmante y compara el resultado con la huella digital recalculada. 4. El sistema valida el estado del certificado del firmante (vigente, revocado o expirado) consultando la cadena de certificación. 5. El sistema verifica la autenticidad del token de sello de tiempo validando la firma del PSC. 6. El sistema presenta al usuario un reporte de verificación con el resultado de cada componente.
Flujos alternos	3a. La huella digital recalculada no coincide con la contenida en la firma → el sistema reporta que el documento fue modificado después de firmado e indica la causa de la invalidación. 4a. El certificado del firmante ha expirado o fue revocado → el sistema lo indica en el reporte sin invalidar necesariamente la firma (la firma era válida al momento del sellado). 5a. El token de sello de tiempo no supera la validación → el sistema reporta que la constancia de fecha no es verificable.
Postcondiciones	El usuario dispone de un reporte de verificación con el estado de cada componente: validez de la firma, estado del certificado, validez del sello de tiempo e integridad del documento.
Derivado de	HU-36, HU-37
RF relacionados	RF-18
RNF relacionados	RNF-11

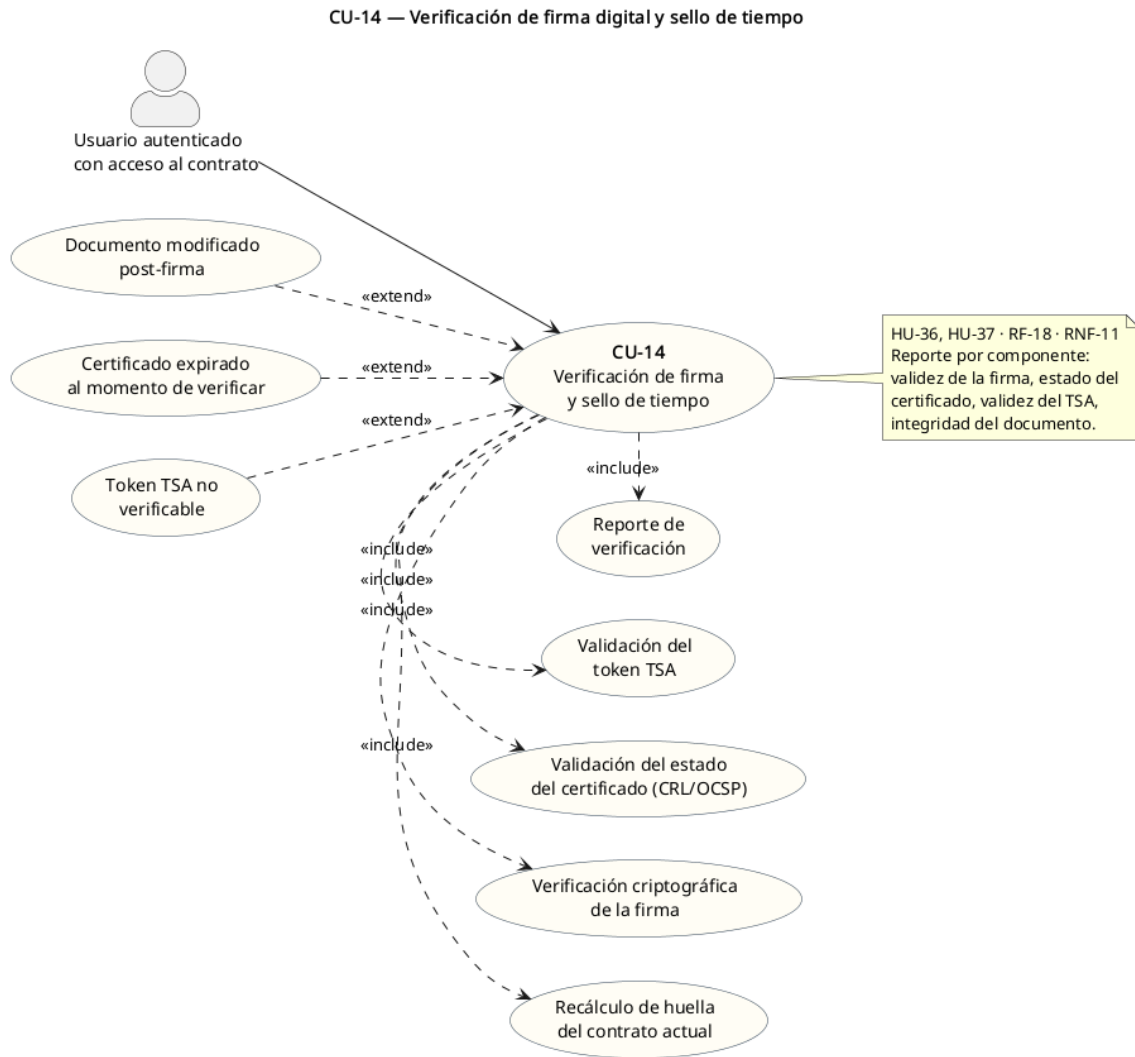


Figura 3.15: Diagrama CU-14. Verificación de firma digital y sello de tiempo.

3.3.6 Operación y Monitoreo

CU-15 — Consulta del tablero de control

Tabla 3.15: Caso de uso CU-15: Consulta del tablero de control.

ID	CU-15
Nombre	Consulta del tablero de control
Actor principal	Owner o Litigante
Actores secundarios	—
Precondiciones	El usuario tiene sesión activa.
Flujo principal	1. El usuario accede al tablero de control del despacho. 2. El sistema consulta los indicadores operativos del tenant: casos activos, plazos por vencer en 48 h y 7 días, contratos pendientes de firma y carga de trabajo por abogado. 3. El sistema presenta los indicadores con diferenciación visual por nivel de urgencia.
Flujos alternos	2a. Existen plazos fatales por vencer en menos de 48 horas → el sistema los destaca con indicador de alerta de nivel crítico, diferenciado visualmente del resto de elementos.
Postcondiciones	El usuario visualiza el estado actual del despacho.
Derivado de	HU-38
RF relacionados	RF-19
RNF relacionados	RNF-07

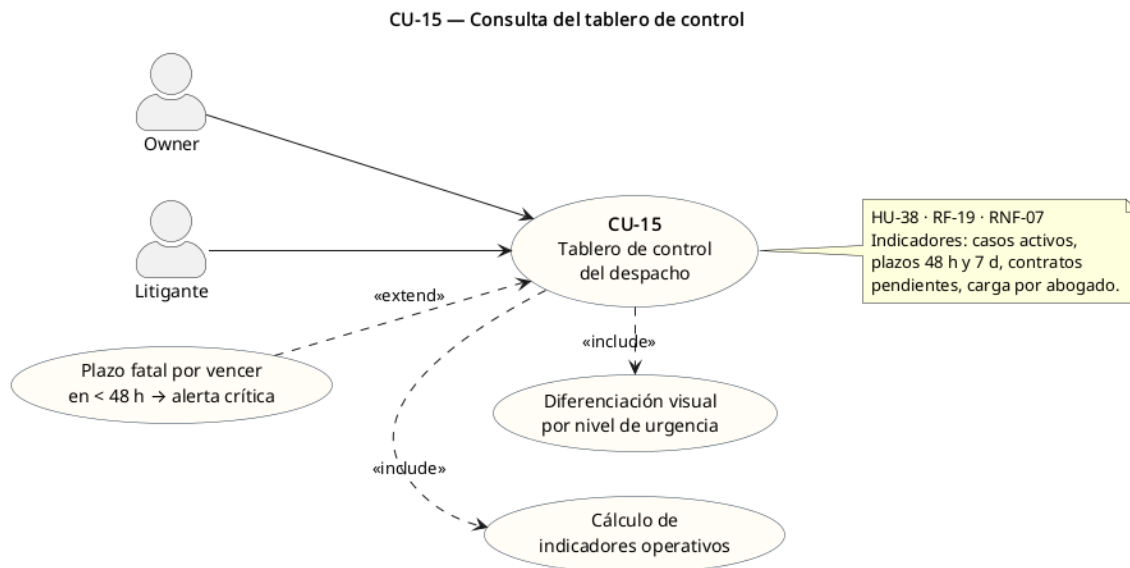
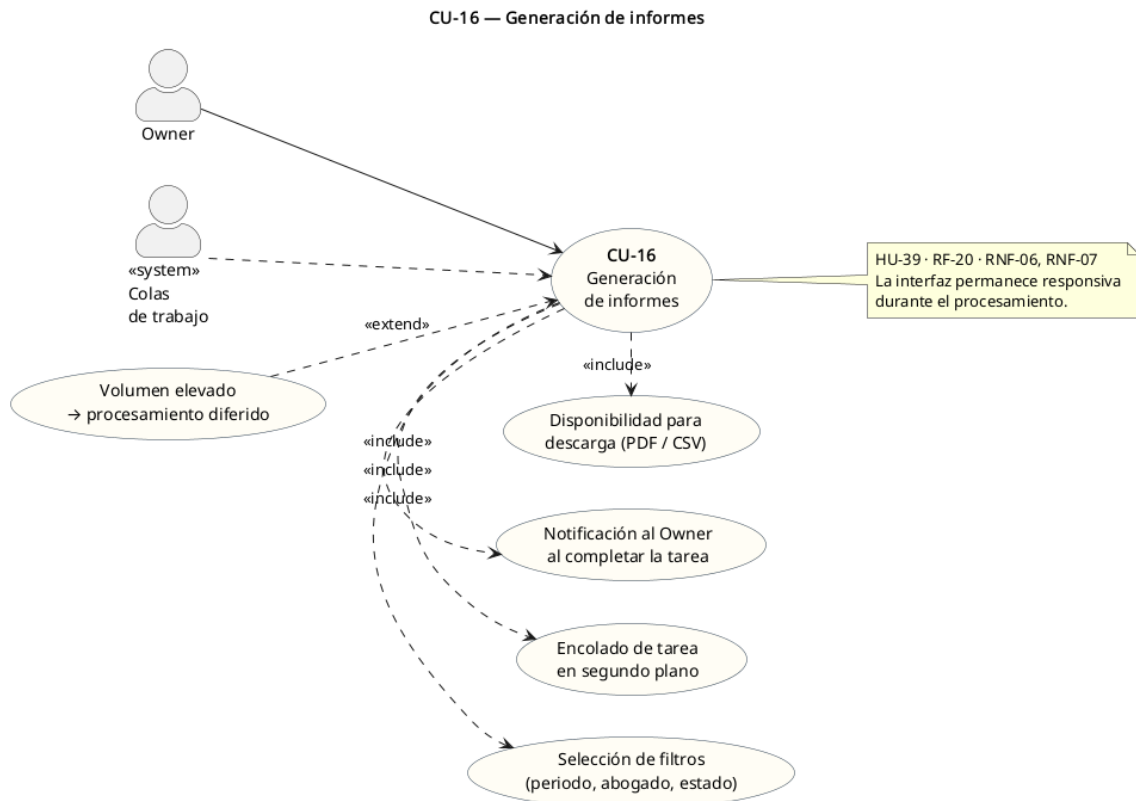


Figura 3.16: Diagrama CU-15. Consulta del tablero de control.

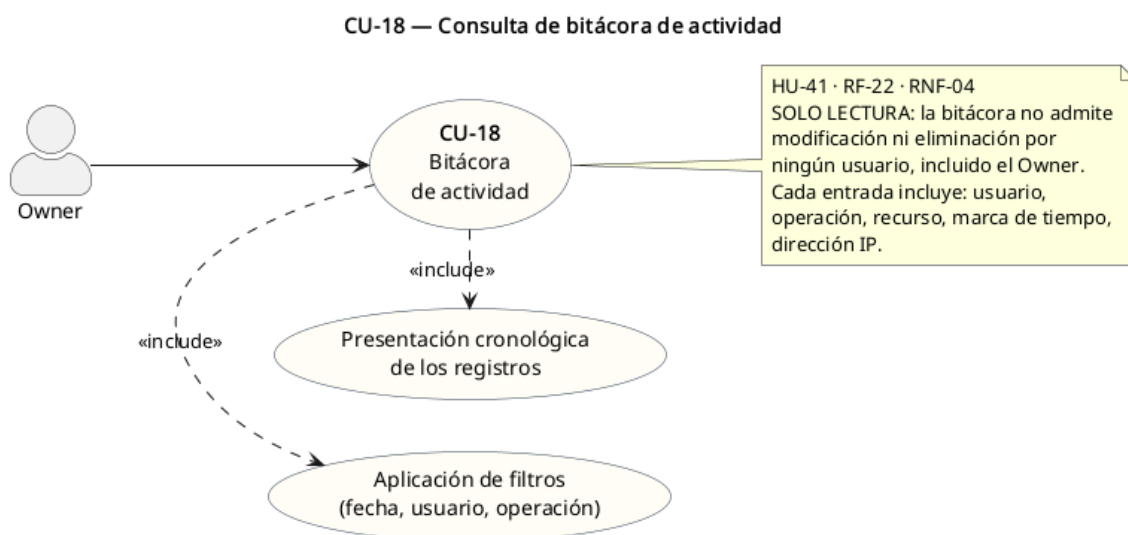
CU-16 — Generación de informes**Tabla 3.16:** Caso de uso CU-16: Generación de informes.

ID	CU-16
Nombre	Generación de informes
Actor principal	Owner
Actores secundarios	Sistema de colas de trabajo
Precondiciones	El Owner tiene sesión activa.
Flujo principal	1. El Owner accede al módulo de reportes. 2. Selecciona el tipo de informe y los filtros aplicables (rango de fechas, abogado responsable, estado de los casos). 3. El sistema encola la solicitud de generación como tarea en segundo plano. 4. El sistema confirma la recepción de la solicitud y muestra un indicador de progreso. 5. Al completar la generación, el sistema notifica al Owner y pone el informe disponible para descarga en formato PDF o CSV.
Flujos alternos	3a. El volumen de datos supera el umbral de procesamiento inmediato → el sistema informa el tiempo estimado y envía notificación por correo cuando el reporte esté listo.
Postcondiciones	El informe queda disponible para descarga. La interfaz permanece responsiva durante el procesamiento.
Derivado de	HU-39
RF relacionados	RF-20
RNF relacionados	RNF-06, RNF-07

**Figura 3.17:** Diagrama CU-16. Generación de informes.

CU-17 — Consulta de bitácora de actividad**Tabla 3.17:** Caso de uso CU-17: Consulta de bitácora de actividad.

ID	CU-17
Nombre	Consulta de bitácora de actividad
Actor principal	Owner
Actores secundarios	—
Precondiciones	El Owner tiene sesión activa.
Flujo principal	1. El Owner accede al módulo de bitácora de actividad. 2. Aplica filtros de búsqueda (rango de fechas, usuario, tipo de operación, recurso afectado). 3. El sistema presenta los registros cronológicamente, mostrando para cada entrada: identificador del usuario, tipo de operación, recurso afectado, marca de tiempo y dirección IP.
Flujos alternos	— (la bitácora es de solo lectura; no existen operaciones de modificación o eliminación).
Postcondiciones	El Owner visualiza los registros solicitados. Los registros de la bitácora no pueden modificarse ni eliminarse por ningún usuario del sistema, incluido el Owner.
Derivado de	HU-41
RF relacionados	RF-22
RNF relacionados	RNF-04

**Figura 3.18:** Diagrama CU-17. Consulta de bitácora de actividad.

3.4 Requerimientos del Sistema

Los requerimientos se derivan de los objetivos definidos anteriormente y se organizan en funcionales y no funcionales. Los requerimientos funcionales definen los servicios que el sistema debe proporcionar y cómo debe reaccionar ante entradas particulares. Los requerimientos no funcionales describen restricciones y atributos de calidad que limitan las decisiones de diseño e implementación.

3.4.1 Requerimientos Funcionales

Los requerimientos funcionales especifican los servicios que el sistema debe proporcionar, las entradas que acepta, las salidas que produce y el comportamiento esperado ante condiciones particulares. Cada requerimiento se deriva de las historias de usuario definidas en la [sección 3.2](#) y se formaliza mediante una estructura que incluye descripción, entradas, salidas, actores involucrados y criterio de aceptación verificable. Los requerimientos se agrupan en cinco categorías funcionales alineadas con los módulos del prototipo.

Autenticación y Control de Acceso

Tabla 3.18: RF-01: Autenticación y gestión de sesiones

ID	RF-01
Nombre	Autenticación y gestión de sesiones
Descripción	El sistema debe proveer mecanismos seguros de inicio de sesión, recuperación de contraseñas, expiración de sesiones por inactividad y protección contra fijación de sesión.
Entrada	Credenciales del usuario (usuario/contraseña o certificado digital); solicitud de recuperación de contraseña.
Salida	Sesión autenticada con token de acceso; notificación de expiración; redireccionamiento al inicio de sesión tras inactividad sin pérdida de datos no guardados.
Actores involucrados	Todos los roles (Owner, Litigante, Paralegal); sistema de gestión de sesiones.
Criterio de aceptación	Dado un usuario inactivo por el tiempo configurado, cuando vence la sesión, entonces el sistema la invalida automáticamente y requiere nueva autenticación sin pérdida de datos no guardados.

Tabla 3.19: RF-02: Control de acceso basado en roles (RBAC)

ID	RF-02
Nombre	Control de acceso basado en roles (RBAC)
Descripción	El sistema debe asignar permisos de forma granular a través de roles predefinidos (Owner, Litigante, Paralegal) para restringir el acceso a módulos y operaciones sensibles.
Entrada	Rol asignado al usuario; recurso o módulo al que se intenta acceder.
Salida	Permiso concedido o denegado; registro en bitácora del intento de acceso.
Actores involucrados	Owner (configuración de roles); todos los usuarios como sujetos de control; sistema de autorización.
Criterio de aceptación	Dado un usuario con rol Paralegal, cuando intenta acceder a un módulo restringido a Owner o Litigante, entonces el sistema deniega el acceso con mensaje explicativo y registra el intento en la bitácora.

Tabla 3.20: RF-03: Gestión de equipos colaborativos

ID	RF-03
Nombre	Gestión de equipos colaborativos
Descripción	El sistema debe permitir invitar nuevos miembros al despacho mediante correo electrónico, gestionar la aceptación de invitaciones y administrar el alta y baja de usuarios en el equipo.
Entrada	Correo electrónico del nuevo miembro; rol a asignar; acción de aceptación del invitado.
Salida	Invitación enviada; usuario creado y asociado al tenant; acceso habilitado según el rol asignado.
Actores involucrados	Owner (invita y da de baja); usuario invitado; sistema de correo transaccional.
Criterio de aceptación	Dado un Owner que envía una invitación, cuando el invitado la acepta dentro del periodo de validez del enlace, entonces queda registrado con el rol indicado; si el enlace vence, la invitación queda inactiva automáticamente.

Gestión Procesal Penal

Tabla 3.21: RF-04: Expediente penal digital

ID	RF-04
Nombre	Expediente penal digital
Descripción	El sistema debe permitir el registro y administración integral de casos penales, incluyendo identificadores oficiales (NUC, Carpeta Judicial), delitos y metadatos asociados.
Entrada	NUC, Carpeta Judicial, tipo de delito, datos del caso y metadatos ingresados por el Litigante.
Salida	Expediente registrado con identificadores únicos, estado inicial ‘Investigación’ y timestamp de creación.
Actores involucrados	Litigante, Paralegal; base de datos relacional.
Criterio de aceptación	Dado un Litigante que registra un nuevo caso, cuando omite el NUC o la Carpeta Judicial, entonces el sistema rechaza el registro con indicación del campo faltante; cuando los datos son completos, el expediente queda persistido y disponible en el módulo de gestión procesal.

Tabla 3.22: RF-05: Control de etapas procesales (CNPP)

ID	RF-05
Nombre	Control de etapas procesales (CNPP)
Descripción	El sistema debe gestionar la transición entre etapas procesales (Investigación, Intermedia, Juicio Oral) conforme al CNPP, manteniendo un historial inmutable de cambios y validaciones procesales.
Entrada	Documento procesal habilitante cargado por el usuario (ej. escrito de acusación para transitar de Investigación a Intermedia).
Salida	Registro inmutable de la transición con marca de tiempo, identificador de usuario y documento asociado; módulo de la siguiente etapa habilitado.
Actores involucrados	Litigante (Owner); sistema de gestión procesal; bitácora de auditoría.
Criterio de aceptación	Dado un expediente en etapa de Investigación, cuando se intenta avanzar sin cargar el escrito de acusación, entonces el sistema rechaza la transición; cuando se carga el documento habilitante, la transición se registra de forma inmutable y no puede revertirse.

Tabla 3.23: RF-06: Directorio de participantes

ID	RF-06
Nombre	Directorio de participantes
Descripción	El sistema debe permitir la gestión de sujetos procesales vinculados a cada caso (imputados, víctimas, jueces, peritos), definiendo su rol procesal y estatus jurídico.
Entrada	Datos del sujeto procesal (nombre, rol, cédula, CURP u otros identificadores según tipo); caso al que se vincula.
Salida	Participante registrado y vinculado al expediente con su rol procesal; historial de cambios de rol disponible.
Actores involucrados	Litigante; sistema de gestión de directorio.
Criterio de aceptación	Dado un caso activo, cuando se registra un participante con rol ‘Juez de control’, entonces el sistema valida que se proporcione el órgano jurisdiccional y la firma electrónica (FIREL); un mismo usuario puede tener roles distintos en casos diferentes sin conflicto.

Tabla 3.24: RF-07: Gestión de audiencias especializadas

ID	RF-07
Nombre	Gestión de audiencias especializadas
Descripción	El sistema debe permitir la programación y seguimiento de audiencias tipificadas según el CNPP, registrando resultados, asistentes y acuerdos derivados.
Entrada	Tipo de audiencia (del catálogo CNPP), fecha, hora, participantes y modalidad (presencial o videoconferencia).
Salida	Audiencia agendada vinculada al expediente; activación automática del cómputo de plazos derivados; registro de resultados y acuerdos.
Actores involucrados	Litigante; sistema de calendario; módulo de plazos.
Criterio de aceptación	Dado el registro de una ‘Audiencia inicial’ con vinculación a proceso, cuando se confirma, entonces el sistema activa automáticamente el plazo de investigación complementaria (2 o 6 meses) y genera la alerta preventiva correspondiente.

Tabla 3.25: RF-08: Blindaje de plazos procesales

ID	RF-08
Nombre	Blindaje de plazos procesales
Descripción	El sistema debe permitir el registro y cálculo de términos constitucionales y plazos fatales, con derivación automática a partir de actuaciones o audiencias registradas.
Entrada	Actuación o audiencia registrada que activa un plazo constitucional; calendario de días inhábiles configurado por entidad federativa.
Salida	Plazo calculado con fecha y hora de vencimiento; alerta programada; registro en el módulo de plazos del expediente.
Actores involucrados	Litigante; sistema de cómputo de plazos; calendario judicial configurable.
Criterio de aceptación	Dado el registro de vinculación a proceso con plazo de 6 meses de investigación complementaria, entonces el sistema calcula la fecha de vencimiento excluyendo correctamente los días inhábiles del calendario configurado para la entidad federativa correspondiente.

Tabla 3.26: RF-09: Sistema de alertas preventivas

ID	RF-09
Nombre	Sistema de alertas preventivas
Descripción	El sistema debe generar notificaciones automáticas ante la proximidad de vencimientos de plazos o audiencias programadas.
Entrada	Plazos activos registrados; reglas de anticipación configurables (ej. alerta a 48 h y a 24 h del vencimiento).
Salida	Notificación enviada al Litigante responsable por correo y visible en el dashboard del sistema.
Actores involucrados	Litigante; sistema de notificaciones; módulo de colas de trabajo.
Criterio de aceptación	Dado un plazo de vinculación a proceso con vencimiento en 48 horas, cuando el sistema ejecuta la verificación periódica de plazos, entonces envía una notificación de alerta roja al Litigante responsable; el envío se registra en la bitácora.

Tabla 3.27: RF-10: Calendario jurídico integrado

ID	RF-10
Nombre	Calendario jurídico integrado
Descripción	El sistema debe proveer una visualización unificada de la agenda del despacho, integrando audiencias y plazos límite en un calendario interactivo.
Entrada	Audiencias programadas; plazos activos; configuración de la vista seleccionada (día, semana o mes).
Salida	Calendario unificado con codificación de color por tipo de evento y acceso directo al expediente relacionado desde cada entrada.
Actores involucrados	Litigante, Paralegal, Owner.
Criterio de aceptación	Dado un despacho con 5 o más casos activos, cuando el Litigante accede al calendario, entonces visualiza todos los vencimientos y audiencias de sus casos en una sola vista sin necesidad de navegar por cada expediente individualmente.

Gestión Documental y Evidencias

Tabla 3.28: RF-11: Cadena de custodia digital

ID	RF-11
Nombre	Cadena de custodia digital
Descripción	El sistema debe proveer un módulo para el registro de evidencias físicas y digitales, garantizando la trazabilidad de sus movimientos y resguardos mediante un registro cronológico inmutable.
Entrada	Evidencia física o digital ingresada al sistema; operación de movimiento o consulta de la evidencia.
Salida	Registro cronológico append-only con: tipo de operación, identificador de la evidencia, usuario responsable, timestamp y estado de la evidencia.
Actores involucrados	Litigante, Paralegal; sistema de almacenamiento NoSQL (registro de auditoría).
Criterio de aceptación	Dado un registro de evidencia existente, cuando cualquier usuario intenta modificar o eliminar una entrada de la cadena de custodia, entonces el sistema rechaza la operación; cada nuevo movimiento genera únicamente un registro de inserción nuevo.

Tabla 3.29: RF-12: Repositorio documental

ID	RF-12
Nombre	Repositorio documental
Descripción	El sistema debe permitir cargar, clasificar, consultar y compartir documentos procesales asociados a expedientes, asegurando su organización, disponibilidad y control de versiones.
Entrada	Archivo digital (PDF, DOCX, multimedia); clasificación y metadatos ingresados por el usuario; expediente al que se asocia.
Salida	Documento almacenado cifrado (AES-256-GCM), indexado con su hash SHA-256 y disponible para consulta por los roles autorizados.
Actores involucrados	Litigante, Paralegal; sistema de almacenamiento cifrado.
Criterio de aceptación	Dado un documento cargado al repositorio, cuando un Paralegal intenta acceder a un documento de un expediente no asignado, entonces el sistema deniega el acceso; el documento debe ser recuperable en menos de 3 segundos para archivos de hasta 10 MB.

Servicios Criptográficos

Tabla 3.30: RF-13: Verificación de integridad de documentos

ID	RF-13
Nombre	Verificación de integridad de documentos
Descripción	El sistema debe calcular y almacenar el hash SHA-256 (véase §2.3.1) de cada documento al momento de su carga. En cada consulta posterior, debe recalcular el hash y compararlo con el valor de referencia, notificando al usuario si se detecta una discrepancia.
Entrada	Archivo digital cargado al sistema (PDF, DOCX u otro formato admitido).
Salida	Hash SHA-256 almacenado en base de datos; alerta visible al usuario en caso de discrepancia detectada en consulta posterior.
Actores involucrados	Litigante, Paralegal; sistema de almacenamiento (backend).
Criterio de aceptación	Dado un documento cargado, cuando se modifica 1 byte del archivo almacenado, entonces el sistema detecta la discrepancia y muestra una alerta en la siguiente consulta sin requerir intervención manual.

Tabla 3.31: RF-14: Cifrado autenticado de expedientes y documentos

ID	RF-14
Nombre	Cifrado autenticado de expedientes y documentos
Descripción	El sistema debe cifrar los documentos y expedientes almacenados mediante AES-256-GCM (véase §2.3.2), proveyendo simultáneamente confidencialidad e integridad. Cada operación de cifrado debe emplear un vector de inicialización (IV) único generado aleatoriamente.
Entrada	Documento o expediente a cifrar; clave maestra del tenant; IV generado aleatoriamente por operación.
Salida	Contenido cifrado con AES-256-GCM almacenado en el repositorio; IV almacenado de forma separada de los datos cifrados.
Actores involucrados	Sistema de cifrado (backend); módulo de gestión de claves.
Criterio de aceptación	Dado un documento cifrado almacenado, cuando se modifica 1 byte del texto cifrado directamente en el almacenamiento, entonces la verificación de la etiqueta de autenticación GCM falla y el sistema rechaza el descifrado; cada operación debe utilizar un IV único, verificable mediante pruebas TDD.

Tabla 3.32: RF-15: Firma digital de contratos

ID	RF-15
Nombre	Firma digital de contratos
Descripción	El sistema debe permitir la firma digital de contratos mediante certificados X.509 (véase §2.3.3), vinculando criptográficamente la identidad del firmante con el contenido del documento.
Entrada	Contrato en formato PDF listo para firmar; certificado X.509 del firmante; confirmación de la acción de firma por el usuario.
Salida	Documento firmado con hash SHA-256 cifrado con la clave privada del firmante; metadatos de firma (timestamp local, identificador del certificado) almacenados junto al documento.
Actores involucrados	Litigante (firmante); sistema de firma digital; módulo de certificados X.509.
Criterio de aceptación	Dado un contrato firmado digitalmente, cuando se modifica cualquier byte del documento posterior a la firma, entonces la verificación retorna inválida; la firma solo puede verificarse exitosamente con la clave pública del certificado X.509 del firmante.

Tabla 3.33: RF-16: Sellado de tiempo (NOM-151)

ID	RF-16
Nombre	Sellado de tiempo (NOM-151)
Descripción	El sistema debe obtener una constancia de conservación mediante un PSC autorizado para cada contrato firmado, conforme al protocolo RFC 3161 (véase §2.3.3.4), acreditando la existencia del documento en un momento determinado.
Entrada	Hash SHA-256 del contrato firmado; solicitud al PSC autorizado (Cincel) mediante API RFC 3161.
Salida	Token de sello de tiempo (TimeStampToken) en formato ASN.1/.tsr almacenado y vinculado al contrato; constancia de conservación NOM-151 emitida.
Actores involucrados	Sistema backend (cliente TSA); PSC autorizado (Cincel como TSA); módulo de firma digital.
Criterio de aceptación	Dado un contrato firmado, cuando se solicita el sello al PSC, entonces el sistema recibe y almacena un token RFC 3161 válido en menos de 10 segundos; el token debe ser verificable de forma independiente con OpenSSL sin requerir acceso al sistema.

Tabla 3.34: RF-17: Verificación de firmas y sellos de tiempo

ID	RF-17
Nombre	Verificación de firmas y sellos de tiempo
Descripción	El sistema debe permitir verificar la validez de las firmas digitales y los sellos de tiempo asociados a un contrato, incluyendo la cadena de certificados X.509, vigencia del certificado e integridad del documento.
Entrada	Contrato firmado con su token de sello de tiempo; cadena de certificados X.509 del firmante.
Salida	Resultado de verificación con detalle de: validez de la firma, estado del certificado (vigente/revocado/expirado), validez del sello de tiempo e integridad del documento.
Actores involucrados	Cualquier usuario autenticado con acceso al contrato; sistema de verificación criptográfica.
Criterio de aceptación	Dado un contrato con firma válida e integridad verificada, cuando se ejecuta la verificación, entonces todos los componentes se reportan como válidos; dado un contrato modificado, cuando se verifica, entonces el sistema reporta la firma como inválida con indicación explícita de la causa.

Operación y Monitoreo

Tabla 3.35: RF-18: Dashboard ejecutivo

ID	RF-18
Nombre	Dashboard ejecutivo
Descripción	El sistema debe proveer un tablero de control que visualice indicadores operativos clave: casos activos, plazos próximos y carga de trabajo por abogado.
Entrada	Datos de casos activos, plazos próximos y asignación de carga del tenant activo.
Salida	Tablero visual con indicadores actualizados: número de casos activos, plazos por vencer en 48 h/7 días, contratos pendientes de firma.
Actores involucrados	Owner, Litigante; sistema de consulta de datos agregados.
Criterio de aceptación	Dado un Owner que accede al dashboard, cuando existen plazos fatales por vencer en menos de 48 horas, entonces el sistema los destaca visualmente con indicador de alerta roja diferenciado del resto de elementos del tablero.

Tabla 3.36: RF-19: Generación de reportes

ID	RF-19
Nombre	Generación de reportes
Descripción	El sistema debe permitir generar informes sobre el estado de los casos, desempeño de abogados y métricas operativas del despacho.
Entrada	Parámetros de filtrado seleccionados por el usuario (rango de fechas, abogado, estado del caso, tipo de reporte).
Salida	Reporte generado en formato PDF o exportable a CSV con los datos solicitados.
Actores involucrados	Owner, Litigante; sistema de generación de reportes asíncrono (cola de trabajo).
Criterio de aceptación	Dado un Owner que solicita un reporte mensual, cuando el procesamiento supera 3 segundos, entonces la interfaz permanece responsiva, muestra indicador de progreso y entrega el reporte mediante notificación sin bloquear la sesión.

Tabla 3.37: RF-20: Bitácora de actividad (Audit Trail)

ID	RF-20
Nombre	Bitácora de actividad (Audit Trail)
Descripción	El sistema debe mantener un registro cronológico inmutable de todas las acciones realizadas, incluyendo el identificador del usuario, la operación realizada, la marca de tiempo y el recurso afectado.
Entrada	Cualquier operación realizada por un usuario autenticado (consulta, carga, firma, modificación de rol, etc.).
Salida	Registro append-only en base de datos NoSQL con los campos: <code>user_id</code> , <code>action_type</code> , <code>resource_id</code> , <code>timestamp</code> , <code>ip_address</code> .
Actores involucrados	Todos los roles del sistema; motor NoSQL de auditoría.
Criterio de aceptación	Dado cualquier usuario autenticado, cuando ejecuta cualquier operación en el sistema, entonces se genera un registro en la bitácora en menos de 500 ms; el registro no puede eliminarse ni modificarse por ningún rol, incluido Owner.

3.4.2 Requerimientos No Funcionales

Los requerimientos no funcionales describen las restricciones y atributos de calidad que el sistema debe satisfacer de forma transversal a todas sus funcionalidades. Se formulan en términos del atributo de calidad, no de la tecnología específica que lo implementa, y se agrupan en cuatro categorías: seguridad y protección de datos, rendimiento y operación, usabilidad y experiencia de usuario, y cumplimiento normativo y mantenibilidad.

Seguridad y Protección de Datos

Tabla 3.38: RNF-01: Aislamiento lógico multi-tenant

ID	RNF-01
Nombre	Aislamiento lógico multi-tenant
Descripción	El sistema debe garantizar la segregación estricta de datos entre despachos, impidiendo que cualquier consulta, operación o error de lógica exponga información de un tenant a otro.
Entrada	Consulta o operación de cualquier usuario autenticado sobre cualquier recurso del sistema.
Salida	Respuesta que contiene únicamente datos del tenant al que pertenece el usuario autenticado.
Actores involucrados	Todos los usuarios; capa de middleware de aislamiento; base de datos relacional.
Criterio de aceptación	Dado un usuario de tenant A, cuando realiza cualquier consulta (incluso manipulando parámetros), entonces el sistema nunca devuelve datos de tenant B; verificable mediante pruebas automatizadas que simulen inyección de <code>tenant_id</code> ajeno.

Tabla 3.39: RNF-02: Gestión segura de credenciales

ID	RNF-02
Nombre	Gestión segura de credenciales
Descripción	Las contraseñas de los usuarios deben almacenarse mediante funciones de hashing resistentes (Argon2 o bcrypt) con salt (sal) aleatorio por contraseña. El sistema no debe almacenar contraseñas en texto plano ni usar SHA-256/MD5 para este fin.
Entrada	Contraseña en texto plano proporcionada durante el registro o cambio de contraseña.
Salida	Hash de la contraseña almacenado con Argon2 o bcrypt con salt aleatorio; contraseña original descartada inmediatamente.
Actores involucrados	Sistema de autenticación; base de datos de credenciales.
Criterio de aceptación	Dado el acceso directo a la base de datos, cuando se inspeccionan las credenciales almacenadas, entonces ninguna contraseña aparece en texto plano ni como hash SHA-256 o MD5; el tiempo de verificación debe superar los 100 ms para dificultar ataques de fuerza bruta.

Tabla 3.40: RNF-03: Gestión de material criptográfico

ID	RNF-03
Nombre	Gestión de material criptográfico
Descripción	El sistema debe garantizar que las claves de cifrado se almacenen de forma segura y separada de los datos cifrados, que los IV para AES-GCM sean únicos por operación (véase §3.11.4) y que las claves privadas nunca se transmitan por la red ni se almacenen en texto plano.
Entrada	Operación de cifrado o descifrado; solicitud de uso de clave privada por el firmante.
Salida	Operación ejecutada sin exposición de material criptográfico sensible en logs, respuestas API o almacenamiento temporal.
Actores involucrados	Sistema de cifrado (backend); módulo de gestión de claves; desarrolladores (auditores).
Criterio de aceptación	Dado el análisis de los logs del sistema en cualquier nivel de verbosidad, cuando se buscan patrones de claves o IV en texto plano, entonces no debe encontrarse ninguna clave maestra, clave privada ni IV almacenado junto al contenido cifrado en el mismo registro.

Tabla 3.41: RNF-04: Inmutabilidad de registros críticos

ID	RNF-04
Nombre	Inmutabilidad de registros críticos
Descripción	Los registros de historial procesal, cadena de custodia y bitácora de actividad deben seguir un modelo de solo inserción (append-only), impidiendo la modificación o eliminación de trazas históricas.
Entrada	Intento de operación UPDATE o DELETE sobre tablas de historial procesal, cadena de custodia o bitácora de actividad.
Salida	Operación rechazada con código de error; registro del intento en la bitácora de sistema.
Actores involucrados	Cualquier usuario o proceso del sistema; motor de base de datos NoSQL.
Criterio de aceptación	Dado un registro existente en la bitácora de auditoría, cuando cualquier proceso—incluidos scripts administrativos— intenta modificarlo o eliminarlo, entonces el motor rechaza la operación; verificable mediante pruebas de integración automatizadas.

Tabla 3.42: RNF-05: Privacidad entre despachos

ID	RNF-05
Nombre	Privacidad entre despachos
Descripción	El sistema debe prohibir cualquier fuga de información inter-tenant, verificable mediante pruebas automatizadas de aislamiento.
Entrada	Consultas con parámetros manipulados que incluyan identificadores de tenant ajeno.
Salida	Respuesta vacía o error de autorización; nunca datos de otro tenant.
Actores involucrados	Middleware de aislamiento; capa de acceso a datos; equipo de QA.
Criterio de aceptación	Dado un conjunto de pruebas automatizadas de aislamiento ejecutadas contra el entorno de staging, entonces el 100 % de los intentos de acceso a datos de otro tenant deben resultar en error de autorización.

Rendimiento y Operación

Tabla 3.43: RNF-06: Procesamiento asíncrono

ID	RNF-06
Nombre	Procesamiento asíncrono
Descripción	Las tareas intensivas (envío de notificaciones, generación de reportes, operaciones criptográficas de larga duración) deben procesarse en segundo plano mediante colas de trabajo, sin bloquear la interfaz de usuario.
Entrada	Solicitud de tarea intensiva por parte del usuario.
Salida	Confirmación inmediata de recepción; entrega del resultado mediante notificación cuando el procesamiento concluye.
Actores involucrados	Usuario solicitante; sistema de colas de trabajo (backend); módulo de notificaciones.
Criterio de aceptación	Dado un usuario que solicita la generación de un reporte, cuando el procesamiento supera 2 segundos, entonces la interfaz permanece responsiva con indicador de progreso; el usuario no necesita mantener la pantalla activa para recibir el resultado.

Tabla 3.44: RNF-07: Tiempo de respuesta de interfaz

ID	RNF-07
Nombre	Tiempo de respuesta de interfaz
Descripción	Las operaciones interactivas del sistema deben ofrecer tiempos de respuesta perceptiblemente inmediatos, con actualizaciones reactivas que no requieran recargas completas de página.
Entrada	Interacción del usuario con cualquier elemento de la interfaz (clic, búsqueda, navegación).
Salida	Actualización reactiva de la interfaz sin recarga completa de página.
Actores involucrados	Usuario final; frontend del sistema; API REST del backend.
Criterio de aceptación	Dado un usuario en condiciones de red estándar (>10 Mbps), cuando realiza cualquier operación interactiva que no involucre procesamiento asíncrono, entonces la interfaz responde con retroalimentación visual en menos de 300 ms.

Usabilidad y Experiencia de Usuario

Tabla 3.45: RNF-08: Diseño responsivo

ID	RNF-08
Nombre	Diseño responsivo
Descripción	La interfaz debe adaptarse fluidamente a dispositivos de escritorio y tabletas, respetando los lineamientos de legibilidad y jerarquía visual del sistema de diseño.
Entrada	Acceso al sistema desde dispositivos con resoluciones entre 768 px (tablet) y 1920 px (escritorio).
Salida	Interfaz adaptada correctamente al ancho de pantalla del dispositivo sin desbordamientos ni pérdida de funcionalidad.
Actores involucrados	Litigante, Paralegal, Owner; sistema de diseño (componentes UI).
Criterio de aceptación	Dado un dispositivo tablet con resolución de 768 px de ancho, cuando el usuario accede a cualquier módulo, entonces todos los elementos interactivos son accesibles y legibles sin requerir desplazamiento horizontal.

Tabla 3.46: RNF-09: Soporte de localización

ID	RNF-09
Nombre	Soporte de localización
Descripción	La plataforma debe manejar formatos de fecha, moneda y textos en español de México (es-MX) como configuración predeterminada.
Entrada	Configuración regional del sistema establecida como es-MX.
Salida	Fechas en formato DD/MM/AAAA, montos en MXN con separador de miles y dos decimales, textos de interfaz en español de México.
Actores involucrados	Sistema de internacionalización (i18n); todos los usuarios.
Criterio de aceptación	Dado cualquier módulo del sistema, cuando se muestran fechas o montos, entonces el formato corresponde a es-MX sin que el usuario deba configurar manualmente su preferencia regional.

Cumplimiento Normativo y Mantenibilidad

Tabla 3.47: RNF-10: Conformidad con el CNPP

ID	RNF-10
Nombre	Conformidad con el CNPP
Descripción	El modelado de datos y los flujos de trabajo deben adherirse estrictamente a la terminología y plazos del Código Nacional de Procedimientos Penales.
Entrada	Flujo de trabajo relacionado con etapas procesales, plazos o tipos de audiencia.
Salida	Terminología, plazos y secuencias de estados alineados al CNPP vigente.
Actores involucrados	Litigante; equipo legal del despacho (validador); desarrolladores.
Criterio de aceptación	Dado el catálogo de tipos de audiencia implementado, cuando se compara contra los artículos 307-403 del CNPP, entonces cada tipo debe tener correspondencia exacta con el artículo aplicable y activar los plazos correctos.

Tabla 3.48: RNF-11: Conformidad con la NOM-151

ID	RNF-11
Nombre	Conformidad con la NOM-151
Descripción	Los mecanismos de sellado de tiempo y conservación de mensajes de datos deben cumplir con los requisitos de la NOM-151-SCFI-2016 y el protocolo RFC 3161.
Entrada	Solicitud de sellado de tiempo de un contrato firmado.
Salida	Token RFC 3161 válido emitido por PSC autorizado, verificable de forma independiente.
Actores involucrados	Sistema backend; PSC Cincel; equipo legal.
Criterio de aceptación	Dado un token emitido por el sistema, cuando se verifica con OpenSSL usando el certificado público de la TSA de Cincel, entonces la verificación resulta exitosa y el timestamp corresponde a una fuente sincronizada con CENAM.

Tabla 3.49: RNF-12: Cumplimiento de la LFPDPPP

ID	RNF-12
Nombre	Cumplimiento de la LFPDPPP
Descripción	El tratamiento de datos personales debe cumplir con las obligaciones de la LFPDPPP, particularmente las medidas de seguridad exigidas por su artículo 19.
Entrada	Dato personal de un cliente del despacho ingresado al sistema.
Salida	Dato almacenado cifrado, accesible únicamente por roles autorizados, con registro de acceso en la bitácora.
Actores involucrados	Todos los usuarios; sistema de cifrado; Oficial de Privacidad del despacho.
Criterio de aceptación	Dado el conjunto de medidas técnicas implementadas, cuando se evalúan contra el artículo 19 de la LFPDPPP, entonces el sistema debe evidenciar: cifrado AES-256-GCM (confidencialidad), hash SHA-256 (integridad), RBAC (control de acceso) y bitácora append-only (trazabilidad).

Tabla 3.50: RNF-13: Arquitectura mantenible

ID	RNF-13
Nombre	Arquitectura mantenible
Descripción	El código debe seguir principios de diseño que faciliten la escalabilidad y el mantenimiento futuro, incluyendo separación de responsabilidades, bajo acoplamiento y alta cohesión.
Entrada	Solicitud de cambio o nueva funcionalidad que afecte un módulo existente.
Salida	Módulo modificado sin introducir regresiones; pruebas existentes continúan pasando.
Actores involucrados	Equipo de desarrollo; sistema de integración continua.
Criterio de aceptación	Dado el código fuente del sistema, cuando se analiza con métricas de código, entonces la complejidad ciclomática promedio por función no debe superar 10 y la cobertura de pruebas de los módulos criptográficos debe ser igual o mayor al 90 %.

Tabla 3.51: RNF-14: Aseguramiento de calidad

ID	RNF-14
Nombre	Aseguramiento de calidad
Descripción	El sistema debe someterse a pruebas de aceptación de usuario (UAT) al finalizar cada ciclo de desarrollo, complementadas con pruebas funcionales automatizadas y pruebas específicas de los servicios criptográficos.
Entrada	Entregable de cada iteración XP; matriz de pruebas definida en la Fase I.
Salida	Reporte de resultados de pruebas funcionales, de integración y criptográficas; lista de defectos identificados y su estado de resolución.
Actores involucrados	Equipo de desarrollo; usuarios representativos del despacho (UAT); directora del proyecto.
Criterio de aceptación	Dado el cierre de cada iteración, cuando se ejecuta la suite de pruebas automatizadas, entonces el 100 % de las pruebas de módulos criptográficos (hash, cifrado, firma, sello de tiempo) deben pasar sin errores antes de considerar la iteración completada.

3.5 Análisis de Costos

El presente análisis estima el costo total del proyecto en su fase de prototipo, considerando todos los recursos necesarios para el desarrollo, la infraestructura y los servicios externos requeridos. La estimación se basa en el costo de oportunidad del equipo de desarrollo y en la identificación exhaustiva de cada rubro de gasto, independientemente de que su costo sea cero en la fase actual.

3.5.1 Metodología de Estimación

Se utiliza un enfoque de costo de oportunidad para valorar el recurso humano: el salario de mercado que cada miembro del equipo percibiría como Desarrollador Full-Stack Junior/Mid en la Zona Metropolitana del Valle de México, convertido a tarifa horaria. Los rangos salariales se triangularon a partir de seis fuentes de datos actualizadas al periodo 2025–2026.

Tabla 3.52: Fuentes salariales consultadas para la estimación del costo de recurso humano.

Fuente	Rango Mensual (MXN)	Fecha de Datos
Glassdoor MX (Jr Full-Stack)	\$11,854 – \$20,114	Marzo 2026
Jobted MX (Jr Full-Stack)	\$11,650 promedio Jr	2026
Indeed MX (Programador Jr)	\$12,784 promedio	Febrero 2026
Coderhouse (Jr Full-Stack)	\$22,000 – \$28,000	2025
Talently (Jr Full-Stack MX)	≈\$29,000 (≈\$1,436 USD)	Mayo 2024
Data México (ENOE Q1-2025)	\$8,410 promedio nacional*	Q1 2025

* Data México reporta el promedio nacional incluyendo todas las seniorities y regiones, lo cual sesga el dato hacia abajo. Se utiliza como límite inferior de referencia.

A partir de estas fuentes, se definen tres escenarios salariales. El cálculo asume una jornada mensual estándar de 160 horas (40 hrs/semana × 4 semanas) bajo esquema de honorarios/freelance, lo cual incorpora el sobre costo por ausencia de prestaciones de ley (≈30–35 % sobre nómina tradicional).

Tabla 3.53: Escenarios salariales y tarifa horaria derivada.

Escenario	Salario Mensual Equivalente	Tarifa / Hora	Justificación
Optimista	\$18,000 MXN	\$112.50 MXN	Piso del rango Jr según Indeed/Glassdoor; escenario donde el riesgo tiene bajo costo.
Más Probable	\$25,000 MXN	\$156.25 MXN	Mediana del rango Jr-Mid; consistente con Coderhouse y Glassdoor p50.
Pesimista	\$32,000 MXN	\$200.00 MXN	Techo del rango Mid; incluye prima por conocimiento criptográfico especializado.

Valor adoptado para los cálculos del proyecto: **\$156.25 MXN/hora** (escenario Más Probable). Los escenarios Optimista y Pesimista se reservan para el análisis de sensibilidad en la sección de riesgos.

3.5.2 Capacidad del Equipo

La capacidad efectiva de programación se reduce respecto a una jornada laboral típica por factores inherentes al contexto del proyecto. Los integrantes del equipo son estudiantes de último semestre con carga académica concurrente, y la metodología XP impone overhead por prácticas como Pair Programming, TDD y ceremonias iterativas.

Tabla 3.54: Factores de ajuste sobre la capacidad de desarrollo.

Factor	Reducción Estimada	Razón
Carga académica concurrente	−30 %	Otras materias, exámenes y prácticas reducen la disponibilidad a 30 hrs/semana por desarrollador.
Pair Programming (XP)	Factor $\times 2$ en costo	Ambos desarrolladores trabajan simultáneamente en la misma tarea; se contabiliza el esfuerzo de ambos.
TDD (Test-Driven Development)	−15 %	Overhead por escritura de pruebas antes de código funcional; compensado por menor deuda técnica.
Ceremonias XP (standups, planning, retros)	−5 %	Iteraciones cortas (1–2 semanas) requieren reuniones frecuentes de coordinación.

Partiendo de una disponibilidad base de 30 horas semanales por desarrollador (jornada reducida por carga académica), y aplicando el overhead combinado de TDD y ceremonias XP (−20 %), se obtienen 24 horas efectivas de programación por desarrollador por semana. Con un equipo de 2 desarrolladores y 5 semanas de codificación intensiva (Fase II del plan de iteraciones), la capacidad total es de 240 horas-persona.

Tabla 3.55: Resumen de capacidad del equipo y presupuesto base.

Métrica	Valor
Horas efectivas por desarrollador / semana	24 horas
Horas efectivas del equipo / semana	48 horas-persona
Semanas de codificación (Fase II)	5 semanas
Capacidad total	240 horas-persona
Presupuesto base (recurso humano)	\$37,500.00 MXN

Nota: En sesiones de Pair Programming, ambos desarrolladores trabajan en la misma tarea. Esto se refleja contabilizando las horas de ambos (48 hrs-equipo/semana), pero la producción de funcionalidades corresponde a una línea de trabajo, no dos paralelas.

3.5.3 Desglose de Costos por Rubro

La siguiente tabla presenta el desglose completo de costos del proyecto en su fase de prototipo. Los rubros con costo cero se documentan explícitamente para transparentar que fueron evaluados y que su gratuidad corresponde a decisiones técnicas deliberadas, no a omisiones en la estimación.

Tabla 3.56: Desglose de costos del proyecto en fase de prototipo.

Rubro	Proveedor / Herramienta	Costo en Fase Prototipo	Justificación
Recurso humano (2 desarrolladores)	Costo de oportunidad	\$37,500.00 MXN	240 hrs-persona × \$156.25/hr. Escenario Más Probable.
Sellado de tiempo NOM-151 (PSC)	Cincel PSC – Plan Start	\$0.00 MXN	Plan gratuito: 10 Certificados Smart (constancia NOM-151 + sello de tiempo + huella de auditoría). API Sandbox gratuita para desarrollo.
Infraestructura de servidor	VPS preexistente (aportación del equipo)	\$0.00 MXN	Infraestructura personal aportada por el equipo. No genera costo incremental para el proyecto.
Correo transaccional	Resend – Plan gratuito	\$0.00 MXN	Plan gratuito suficiente para el volumen de notificaciones del prototipo.
Framework y herramientas de desarrollo	Rust, Axum, Astro, Svelte, Git (open source)	\$0.00 MXN	Stack completamente open source. Sin licencias comerciales requeridas.
Base de datos	MySQL + almacenamiento NoSQL (open source)	\$0.00 MXN	Motores de base de datos open source desplegados en el VPS del equipo.
Certificados SSL/TLS	Let’s Encrypt	\$0.00 MXN	Autoridad de certificación gratuita y automatizada.
Reserva de contingencia	Derivada del análisis de riesgos (sección 3.6)	\$35,578.13 MXN	VME total calculado en el análisis de riesgos. Representa el costo esperado ponderado por probabilidad de materialización.

3.5.4 Resumen Financiero

Tabla 3.57: Resumen financiero del proyecto.

Concepto	Monto
Costo base del proyecto (recurso humano)	\$37,500.00 MXN
Costos de infraestructura y servicios	\$0.00 MXN
Costo total sin contingencia	\$37,500.00 MXN
Reserva de contingencia (VME total)	\$35,578.13 MXN
Presupuesto total estimado	\$73,078.13 MXN

La reserva de contingencia representa el 94.9 % del costo base, lo cual refleja el alto riesgo técnico inherente a la integración de servicios criptográficos con tolerancia cero a fallos en un cronograma de 5 semanas de codificación. Este porcentaje es consistente con las recomendaciones del PMI para proyectos con incertidumbre técnica elevada.

Es importante señalar que los costos de infraestructura y servicios son cero exclusivamente en la fase de prototipo. Un despliegue en producción requeriría la contratación del plan Business de Cincel PSC para sellado de tiempo con volumen, infraestructura cloud dedicada con respaldos, y licencias de dominio y certificados de producción, rubros que quedan fuera del alcance de la presente estimación.

3.6 Análisis de Riesgos

El presente análisis identifica, evalúa y prioriza los riesgos que pueden afectar el desarrollo del prototipo, considerando tanto su probabilidad de ocurrencia como su impacto en tiempo y costo. La evaluación combina un enfoque cualitativo (matriz de severidad) con uno cuantitativo (Valor Monetario Esperado) para proporcionar una base objetiva en la toma de decisiones sobre mitigación y asignación de recursos.

3.6.1 Modelo de Evaluación

El impacto financiero de cada riesgo materializado se calcula mediante la fórmula: $IF = H(\text{retraso}) \times N(\text{devs}) \times T(\text{hora})$, donde $H(\text{retraso})$ es el número de horas de retraso estimadas, $N(\text{devs})$ es el número de desarrolladores afectados (1 o 2) y $T(\text{hora})$ es la tarifa horaria del escenario Más Probable (\$156.25 MXN). El Valor Monetario Esperado (VME) pondera el impacto financiero por la probabilidad de ocurrencia: $VME = P \times IF$.

Tabla 3.58: Escala de probabilidad de ocurrencia.

Nivel	Valor	Rango	Criterio Orientativo
Bajo	1	< 20 %	El riesgo es poco probable; el equipo tiene experiencia previa en el área o existen mitigaciones naturales.
Medio	2	20 – 60 %	El riesgo tiene posibilidades razonables de materializarse; depende de factores parcialmente controlables.
Alto	3	> 60 %	El riesgo es altamente probable; involucra tecnología no dominada, dependencias externas críticas o restricciones de tiempo severas.

Tabla 3.59: Escala de impacto en tiempo.

Nivel	Valor	Retraso	Criterio Orientativo
Bajo	1	1 – 2 días (≤ 16 hrs)	Impacto menor; se puede absorber dentro de la iteración XP sin reprogramar.
Medio	2	3 – 5 días (17–40 hrs)	Impacto significativo; requiere repriorizar historias de usuario y posiblemente reducir alcance de la iteración.
Alto	3	> 5 días (> 40 hrs)	Impacto crítico; compromete el hito de entrega de la iteración o del proyecto completo; requiere escalamiento.

La multiplicación de ambas escalas produce un índice de severidad que permite priorizar la atención a riesgos:

Tabla 3.60: Matriz de severidad (Probabilidad $\times$ Impacto).

Prob. \ Impacto	Bajo (1)	Medio (2)	Alto (3)
Bajo (1)	1 – Trivial	2 – Menor	3 – Moderado
Medio (2)	2 – Menor	4 – Significativo	6 – Grave
Alto (3)	3 – Moderado	6 – Grave	9 – Crítico

Clasificación por rango de severidad: 1–2 (Verde): Aceptar y monitorear sin acción inmediata. 3–4 (Amarillo): Mitigar, definir plan de contingencia y asignar responsable. 6 (Naranja): Priorizar, implementar mitigación activa y considerar reducción de alcance. 9 (Rojo): Escalar, riesgo crítico que amenaza la viabilidad del proyecto y requiere acción inmediata.

3.6.2 Riesgos Técnicos y Criptográficos

Tabla 3.61: Ficha del riesgo RTC-01: Falla en integración con PSC (RFC 3161).

ID	RTC-01
Nombre	Falla en integración con PSC (RFC 3161)
Cat.	Técnico
Sev.	6 – Grave
Declaración	<i>Existe el riesgo de que la integración con la API del PSC (Cincel) falle durante el flujo de sellado de tiempo, debido a incompatibilidades en el parseo del token ASN.1 o restricciones de red en el entorno de desarrollo, lo que podría resultar en la imposibilidad de emitir constancias NOM-151 válidas, bloqueando la validación completa del módulo de no repudio.</i>
Mitigación	Asignar las iteraciones iniciales a un Spike Arquitectónico para validar credenciales, red y parseo del token ASN.1 con el sandbox del PSC.
Impacto	2 – Medio (30 h)
VME	\$6,562.50 MXN
Contingencia	Implementar un servicio Mock en Rust que simule las respuestas de la TSA, permitiendo avanzar con el desarrollo funcional mientras se estabiliza la conexión real.

Tabla 3.62: Ficha del riesgo RTC-02: Implementación insegura de AES-256-GCM.

ID	RTC-02
Nombre	Implementación insegura de AES-256-GCM
Cat.	Técnico
Sev.	6 – Grave
Declaración	<i>Existe el riesgo de que el esquema de cifrado autenticado quede criptográficamente comprometido, debido a una generación predecible o reutilización del Vector de Inicialización (IV) en AES-256-GCM, lo que podría resultar en la pérdida simultánea de confidencialidad e integridad de todos los expedientes cifrados almacenados en el sistema.</i>
Mitigación	Aplicar Pair Programming obligatorio en este módulo. Desarrollar pruebas unitarias TDD que validen la aleatoriedad y no reutilización del IV mediante <code>random_bytes</code> .
Impacto	3 – Alto (45 h)
VME	\$5,625.00 MXN
Contingencia	Aislar y revertir el código vulnerado, purgar la base de datos de pruebas, rotar las llaves maestras de cifrado y refactorizar la lógica criptográfica.

Tabla 3.63: Ficha del riesgo RTC-03: Mala configuración de infraestructura.

ID	RTC-03
Nombre	Mala configuración de infraestructura
Cat.	Técnico
Sev.	2 – Menor
Declaración	<i>Existe el riesgo de que el módulo de almacenamiento de objetos quede inaccesible o con permisos incorrectos, debido a una configuración errónea de políticas de acceso o del servicio de almacenamiento en el servidor de desarrollo, lo que podría resultar en el bloqueo de las operaciones de carga y descarga de documentos, impidiendo avanzar con las iteraciones de gestión documental.</i>
Mitigación	Diseñar la configuración de infraestructura con políticas de mínimo privilegio desde la Iteración 4 y documentarla en el repositorio compartido.
Impacto	1 – Bajo (15 h)
VME	\$703.13 MXN
Contingencia	Un desarrollador asume la resolución de infraestructura mientras el otro migra temporalmente el almacenamiento al disco local del servidor para no detener el avance.

Tabla 3.64: Ficha del riesgo RTC-04: Pérdida de clave maestra de cifrado.

ID	RTC-04
Nombre	Pérdida de clave maestra de cifrado
Cat.	Técnico
Sev.	3 – Moderado
Declaración	<i>Existe el riesgo de que los expedientes cifrados se vuelvan irrecuperables de forma permanente, debido a la ausencia de un procedimiento formal de resguardo, rotación y recuperación de la clave maestra AES del tenant, lo que podría resultar en la pérdida total e irreversible de la información cifrada de todos los clientes del despacho, sin posibilidad de restauración.</i>
Mitigación	Definir desde la Iteración 4 el procedimiento de resguardo de claves con almacenamiento separado de los datos cifrados (ej. variable de entorno o servicio de gestión de secretos).
Impacto	3 – Alto (>40 h)
VME	\$7,031.25 MXN
Contingencia	Restaurar desde la copia de seguridad del almacén de claves; si no existe respaldo, declarar incidente crítico de pérdida de datos y notificar a los interesados.

Tabla 3.65: Ficha del riesgo RTC-05: Expiración de certificado X.509 en producción.

ID	RTC-05
Nombre	Expiración de certificado X.509 en producción
Cat.	Técnico
Sev.	4 – Significativo
Declaración	<i>Existe el riesgo de que el flujo de firma digital quede inoperante de forma inesperada en producción, debido a la falta de monitoreo automatizado de la fecha de vencimiento del certificado X.509 utilizado por el despacho, lo que podría resultar en la interrupción del servicio de no repudio y el potencial incumplimiento de compromisos contractuales con clientes activos del despacho.</i>
Mitigación	Implementar en el módulo de administración una alerta preventiva configurable (ej. 30 y 7 días antes del vencimiento) vinculada al atributo de expiración del certificado X.509.
Impacto	2 – Medio (20 h)
VME	\$3,125.00 MXN
Contingencia	Emitir un certificado de reemplazo de forma urgente ante el PSC correspondiente; notificar a los firmantes afectados y reprogramar las operaciones de firma pendientes.

3.6.3 Riesgos Legales y de Cumplimiento

Tabla 3.66: Ficha del riesgo RLC-01: Discrepancia de hashes SHA-256 (NOM-151).

ID	RLC-01
Nombre	Discrepancia de hashes SHA-256 (NOM-151)
Cat.	Legal
Sev.	6 – Grave
Declaración	<i>Existe el riesgo de que las constancias de conservación emitidas por el PSC sean declaradas inválidas ante una instancia judicial, debido a una discrepancia entre el hash SHA-256 calculado por el sistema y el hash recibido por la TSA, originada por inconsistencias en la serialización del documento previo al sellado, lo que podría resultar en la pérdida del valor probatorio de todos los contratos firmados y el incumplimiento formal de la NOM-151-SCFI-2016, exponiendo al despacho a impugnaciones.</i>
Mitigación	Estudiar exhaustivamente el anexo técnico de la NOM-151. Auditar los digests generados en Rust cruzando resultados con herramientas certificadas (OpenSSL CLI) en cada Spike.
Impacto	3 – Alto (48 h)
VME	\$7,500.00 MXN
Contingencia	Detener el flujo de firmas, validar técnicamente la estructura del hash y refactorizar la lógica de serialización antes de cualquier nuevo envío al PSC.

Tabla 3.67: Ficha del riesgo RLC-02: Mutabilidad en registros de auditoría (CNPP).

ID	RLC-02
Nombre	Mutabilidad en registros de auditoría (CNPP)
Cat.	Legal
Sev.	2 – Menor
Declaración	<i>Existe el riesgo de que la cadena de custodia digital pierda su valor probatorio ante un tribunal revisor, debido a la ausencia de controles de inmutabilidad en la capa de persistencia que permitan operaciones UPDATE o DELETE sobre los registros de auditoría, lo que podría resultar en la ruptura de la cadena de custodia conforme a los artículos 227 y 228 del CNPP, invalidando la evidencia digital presentada en juicio.</i>
Mitigación	Diseñar la capa de persistencia y el modelo NoSQL para prohibir operaciones UPDATE o DELETE en las bitácoras, forzando un esquema estrictamente append-only desde el inicio.
Impacto	2 – Medio (24 h)
VME	\$1,125.00 MXN
Contingencia	Restaurar la base de datos desde respaldo previo a la mutación, auditar los registros afectados y aplicar un parche urgente a nivel de base de datos bloqueando la mutabilidad.

Tabla 3.68: Ficha del riesgo RLC-03: Fuga de datos inter-tenant (LFPDPPP).

ID	RLC-03
Nombre	Fuga de datos inter-tenant (LFPDPPP)
Cat.	Legal
Sev.	3 – Moderado
Declaración	<i>Existe el riesgo de que datos confidenciales de un despacho sean accesibles por usuarios de otro tenant, debido a una falla en el middleware de aislamiento lógico multi-tenant que permita consultas sin restricción de tenant_id, lo que podría resultar en una brecha de datos personales que viola el artículo 19 de la LFPDPPP, con exposición a sanciones administrativas y daño reputacional irreversible para el despacho.</i>
Mitigación	Injectar restricción obligatoria de tenant en toda consulta relacional y verificar el aislamiento mediante pruebas automatizadas en cada iteración.
Impacto	3 – Alto (50 h)
VME	\$1,562.50 MXN
Contingencia	Activar modo de mantenimiento, purgar registros expuestos, rotar credenciales comprometidas y refactorizar los middlewares de aislamiento antes de restaurar el servicio.

Tabla 3.69: Ficha del riesgo RLC-04: Indisponibilidad del PSC (Cincel).

ID	RLC-04
Nombre	Indisponibilidad del PSC (Cincel)
Cat.	Legal
Sev.	4 – Significativo
Declaración	<i>Existe el riesgo de que el módulo de sellado de tiempo quede fuera de servicio durante ventanas críticas de firma, debido a una interrupción no planificada en la infraestructura del Prestador de Servicios de Certificación seleccionado, lo que podría resultar en el incumplimiento de plazos procesales del CNPP que dependen de la emisión oportuna de la constancia NOM-151, con potencial afectación al valor probatorio de los documentos.</i>
Mitigación	Diseñar el módulo de sellado con una interfaz abstracta que permita configurar un PSC alternativo (SeguriData, CECOBAN) sin modificar la lógica central del sistema.
Impacto	2 – Medio (20 h)
VME	\$3,125.00 MXN
Contingencia	Encolar las solicitudes de sellado fallidas y reintentar automáticamente al restablecerse el servicio; notificar al Litigante responsable sobre el retraso en la constancia.

3.6.4 Riesgos Operativos y de Metodología XP

Tabla 3.70: Ficha del riesgo ROP-01: Curva de aprendizaje TDD en módulos criptográficos.

ID	ROP-01
Nombre	Curva de aprendizaje TDD en módulos criptográficos
Cat.	Operativo
Sev.	4 – Significativo
Declaración	<i>Existe el riesgo de que el desarrollo de los módulos criptográficos supere el tiempo planificado de forma significativa, debido a la dificultad adicional de formular pruebas unitarias para operaciones criptográficas cuyo comportamiento correcto no siempre es intuitivo (verificación de IV, validación de cadenas de certificados), lo que podría resultar en el consumo del margen de contingencia del cronograma de la Fase II, poniendo en riesgo la entrega del módulo de no repudio en la Iteración 9.</i>
Mitigación	Aplicar TDD estricto solo en los flujos criptográficos core (hash, cifrado AES, validación X.509) y relajarlo para CRUDs básicos que no comprometan la seguridad.
Impacto	2 – Medio (35 h)
VME	\$5,468.75 MXN
Contingencia	Transicionar a pruebas de integración (test-after) en componentes secundarios si un test unitario excede 4 horas de bloqueo productivo sin resolución.

Tabla 3.71: Ficha del riesgo ROP-02: Scope creep en interfaces gráficas.

ID	ROP-02
Nombre	Scope creep en interfaces gráficas
Cat.	Operativo
Sev.	4 – Significativo
Declaración	<i>Existe el riesgo de que el esfuerzo dedicado a interfaces gráficas consuma tiempo crítico de las semanas 8 y 9, debido a la tendencia a invertir iteraciones en refinamiento visual más allá de lo planificado, en detrimento de los módulos de seguridad de mayor criticidad, lo que podría resultar en el desplazamiento de las Iteraciones 8 y 9 (cifrado autenticado y no repudio) hacia fuera del cronograma, comprometiendo los entregables criptográficos centrales del prototipo.</i>
Mitigación	Congelar las historias de usuario visuales y utilizar bibliotecas de componentes preconstruidas para la interfaz, prohibiendo el diseño a medida en la Fase II.
Impacto	2 – Medio (20 h)
VME	\$3,125.00 MXN
Contingencia	Recortar características no críticas (RF-19 Dashboard Ejecutivo o reportes visuales) para canalizar el esfuerzo íntegramente a los módulos de no repudio y cifrado.

Tabla 3.72: Ficha del riesgo ROP-03: Ruptura de cadencia de Pair Programming.

ID	ROP-03
Nombre	Ruptura de cadencia de Pair Programming
Cat.	Operativo
Sev.	2 – Menor
Declaración	<i>Existe el riesgo de que la práctica de Pair Programming quede interrumpida por ausencia temporal de un desarrollador, debido a indisposición o compromisos académicos imprevistos de uno de los integrantes del equipo durante la Fase II de codificación, lo que podría resultar en la generación de silos de conocimiento en módulos críticos de seguridad y la pérdida de velocidad de desarrollo durante el periodo de ausencia.</i>
Mitigación	Mantener política de propiedad colectiva del código e integración continua diaria para garantizar que ambos desarrolladores conozcan todos los módulos.
Impacto	1 – Bajo (16 h)
VME	\$625.00 MXN
Contingencia	El desarrollador activo pivota a tareas de menor riesgo técnico (maquetación, diccionarios de datos) hasta que la célula de pares se restablezca.

3.6.5 Resumen Cuantitativo de Riesgos

Tabla 3.73: Resumen cuantitativo de los riesgos identificados con su severidad y VME.

ID	Nombre	Prob.	Impacto	Severidad	VME (MXN)
RTC-01	Falla en integración con PSC (RFC 3161)	3 Alto (70 %)	2 Medio (30 h)	6 – Grave	\$6,562.50 MXN
RTC-02	Implementación insegura de AES-256-GCM	2 Medio (40 %)	3 Alto (45 h)	6 – Grave	\$5,625.00 MXN
RTC-03	Mala configuración de infraestructura	2 Medio (30 %)	1 Bajo (15 h)	2 – Menor	\$703.13 MXN
RTC-04	Pérdida de clave maestra de cifrado	1 Bajo (15 %)	3 Alto (>40 h)	3 – Moderado	\$7,031.25 MXN
RTC-05	Expiración de certificado X.509 en producción	2 Medio (40 %)	2 Medio (20 h)	4 – Significativo	\$3,125.00 MXN
RLC-01	Discrepancia de hashes SHA-256 (NOM-151)	2 Medio (50 %)	3 Alto (48 h)	6 – Grave	\$7,500.00 MXN
RLC-02	Mutabilidad en registros de auditoría (CNPP)	1 Bajo (15 %)	2 Medio (24 h)	2 – Menor	\$1,125.00 MXN
RLC-03	Fuga de datos intertenant (LFPDPPP)	1 Bajo (10 %)	3 Alto (50 h)	3 – Moderado	\$1,562.50 MXN
RLC-04	Indisponibilidad del PSC (Cincel)	2 Medio (30 %)	2 Medio (20 h)	4 – Significativo	\$3,125.00 MXN
ROP-01	Curva de aprendizaje TDD en módulos criptográficos	2 Medio (50 %)	2 Medio (35 h)	4 – Significativo	\$5,468.75 MXN
ROP-02	Scope creep en interfaces gráficas	2 Medio (50 %)	2 Medio (20 h)	4 – Significativo	\$3,125.00 MXN
ROP-03	Ruptura de cadencia de Pair Programming	2 Medio (25 %)	1 Bajo (16 h)	2 – Menor	\$625.00 MXN

VME total del proyecto: \$45,578.13 MXN. Si llegaran a materializarse simultáneamente los riesgos de mayor severidad (RTC-01, RLC-01 y ROP-01), el retraso combinado sería de 113 horas de reloj, equivalente a 2.35 semanas ($113 \div 48$ horas-equipo/semana), lo que consumiría el 47 % del cronograma de codificación de 5 semanas. En términos de presupuesto, el impacto conjunto asciende a 226 horas-persona (113×2 desarrolladores), equivalente al 94 % de la capacidad total disponible.

Recomendación: El éxito del prototipo radica en su validez como evidencia técnica, no en su amplitud estética ni de reportes. Todo el esfuerzo de exploración de la Fase I (semanas 1 a 5) debe destinarse a resolver los Spikes correspondientes al consumo de la API del PSC y al cifrado bidireccional de AES-256-GCM. Se recomienda no avanzar hacia el desarrollo de vistas web hasta haber comprobado técnicamente la validez del sellado de tiempo de prueba.

3.6.6 Trazabilidad Riesgo–Objetivo

La siguiente tabla relaciona cada riesgo identificado en las secciones 3.6.2 a 3.6.4 con los objetivos específicos que se verían comprometidos si el riesgo se materializa. Este mapeo permite priorizar las mitigaciones cuya ausencia afectaría de forma más directa la entrega del prototipo.

Tabla 3.74: Trazabilidad entre riesgos identificados y objetivos específicos.

ID	Descripción	Objetivo(s) afectado(s)
RTC-01	Falla en integración con PSC (RFC 3161)	OE-3
RTC-02	Implementación insegura de AES-256-GCM	OE-4
RTC-03	Mala configuración de infraestructura	OE-1, OE-6
RTC-04	Pérdida de clave maestra de cifrado	OE-4
RTC-05	Expiración de certificado X.509 en producción	OE-3, OE-5
RLC-01	Discrepancia de hashes SHA-256 (NOM-151)	OE-3, OE-4
RLC-02	Mutabilidad en registros de auditoría (CNPP)	OE-2, OE-6
RLC-03	Fuga de datos inter-tenant (LFPDPPP)	OE-4 (residual en single-tenant)
RLC-04	Indisponibilidad del PSC (Cincel)	OE-3
ROP-01	Curva de aprendizaje TDD en módulos criptográficos	OE-3, OE-4, OE-5
ROP-02	Scope creep en interfaces gráficas	OE-1, OE-2
ROP-03	Ruptura de cadencia de Pair Programming	Transversal (OE-1 a OE-6)

3.7 Diseño de Arquitectura del Sistema

Esta sección documenta las decisiones arquitectónicas que estructuran el prototipo y articula su correspondencia con los requerimientos funcionales y no funcionales especificados en §3.3 y §3.4. La arquitectura se construye alrededor de los atributos de calidad priorizados en §3.7.1, se materializa en el estilo hexagonal seleccionado en §3.7.3, y se enforce mediante el sistema de tipos de Rust y la organización del workspace de Cargo descrita en §3.7.6. Las vistas adicionales —de contexto, componentes, despliegue y seguridad— se derivan del modelo C4 propuesto por Brown [64] y del modelo 4+1 de Kruchten [65], adaptados al alcance del prototipo. Las decisiones arquitectónicas significativas se registran en formato ADR (Architecture Decision Record) propuesto por Nygard [66] en §3.7.10, y la coherencia interna del capítulo se verifica mediante la matriz de trazabilidad de §3.7.11.

3.7.1 Drivers Arquitectónicos: Atributos de Calidad

La arquitectura del sistema no se selecciona por adherencia a una moda tecnológica sino por su capacidad para satisfacer un conjunto explícito de atributos de calidad derivados de los requerimientos no funcionales del §3.4.2. La norma ISO/IEC 25010:2011 [67] clasifica los atributos de calidad de software en ocho características principales (adecuación funcional, eficiencia de desempeño, compatibilidad, usabilidad, fiabilidad, seguridad, mantenibilidad y portabilidad), de las cuales se

priorizan aquellas que tienen mayor impacto sobre el dominio jurídico-criptográfico que aborda el prototipo.

El primer atributo prioritario es la seguridad, condicionada por los requerimientos RNF-01 (aislamiento lógico), RNF-02 (gestión segura de credenciales), RNF-03 (gestión de material criptográfico) y RNF-09 (autenticación robusta). La seguridad no se concibe como una capa añadida al final del diseño sino como una propiedad transversal que la arquitectura debe garantizar desde sus fundamentos. La adopción de Rust como lenguaje del backend, la separación estricta de material criptográfico mediante el patrón *envelope encryption* (véase §3.11.4), y el aislamiento de los puertos criptográficos mediante *traits* intercambiables son decisiones arquitectónicas que materializan este atributo.

El segundo atributo prioritario es la integridad y trazabilidad, condicionada por RNF-04 (inmutabilidad de registros críticos) y RNF-08 (auditabilidad). Los documentos gestionados por el sistema poseen valor probatorio bajo los Artículos 33 del Código de Comercio y 89-bis del mismo ordenamiento, así como bajo la NOM-151-SCFI-2016. Esto exige que la arquitectura garantice la imposibilidad de modificación retroactiva de la bitácora de auditoría —implementada mediante el encadenamiento SHA-256 descrito en §3.8.1—, así como la conservación criptográficamente verificable de los hashes y sellos de tiempo de cada documento.

El tercer atributo es la evolvibilidad, definida por Ford, Parsons y Kua como la capacidad de un sistema para cambiar guiado [68]. El prototipo se diseña para que la sustitución de cualquier sistema externo —el Prestador de Servicios de Certificación (Cincel por SeguriData o CECOBAN), el motor de base de datos, el proveedor de correo— requiera únicamente la implementación de un nuevo adaptador, sin modificación del dominio. Esta propiedad se garantiza mediante la regla de dependencias de la arquitectura hexagonal, formalizada en §3.7.4.

El cuarto atributo es la testabilidad, condicionada por la metodología *Extreme Programming* adoptada en §3.6, que prescribe *Test-Driven Development* como práctica central. Una arquitectura es testeable cuando permite ejercitar la lógica de dominio sin requerir infraestructura real (bases de datos, servicios de red, sistemas externos). La separación explícita del dominio respecto a sus dependencias mediante puertos permite inyectar adaptadores de prueba (*mocks* o *stubs*) durante la ejecución de la suite de pruebas, manteniendo el dominio agnóstico respecto a la infraestructura.

El quinto atributo es la mantenibilidad —entendida como bajo acoplamiento y alta cohesión—, y el sexto es la observabilidad, esencial para la operación del sistema en producción. Atributos de menor prioridad, pero considerados son la performance (en tanto el sistema deba responder a consultas interactivas en menos de 200 ms), y la portabilidad (limitada al despliegue en sistemas Linux POSIX-compliant).

La [tabla 3.75](#) formaliza la priorización adoptada y su mapeo a los requerimientos no funcionales que la justifican. Esta priorización guía todas las decisiones arquitectónicas posteriores: ante un *trade-off* entre dos atributos en tensión, se favorece aquel de mayor prioridad.

Tabla 3.75: Priorización de atributos de calidad y su mapeo a requerimientos no funcionales.

Prioridad	Atributo de calidad	RNFs que lo motivan
1 (más alta)	Seguridad	RNF-01, RNF-02, RNF-03, RNF-09
2	Integridad y trazabilidad	RNF-04, RNF-08
3	Evolubilidad	Sustitución de PSC, BD, SMTP
4	Testabilidad	XP/TDD (§3.6)
5	Mantenibilidad	Bajo acoplamiento, alta cohesión
6 (más baja)	Observabilidad y performance	Operación productiva

3.7.2 Vista de Contexto del Sistema

La vista de contexto, correspondiente al primer nivel del modelo C4 de Brown [64], representa al sistema como una caja negra que interactúa con actores humanos y sistemas externos. Su propósito es establecer las fronteras del alcance del prototipo y los protocolos de integración antes de descender a los detalles internos.

La Figura 4 presenta los tres tipos de actores humanos contemplados —socio (abogado titular), paralegal (rol operativo) y cliente (firmante de contratos de prestación de servicios)— y los sistemas externos con los que el sistema se integra: el Prestador de Servicios de Certificación Cincel para sellado de tiempo conforme al RFC 3161 y la NOM-151-SCFI-2016, el proveedor de correo electrónico SMTP para notificaciones, y los navegadores web utilizados como cliente de la aplicación. Las flechas etiquetan el protocolo o estándar que regula cada interacción.

Figura 4. Vista de contexto del sistema: actores humanos y sistemas externos con sus protocolos de integración.

El sistema queda explícitamente fuera del alcance respecto a la firma criptográfica realizada por entidades distintas a las partes contractuales (por ejemplo, no se integra con el SAT para emisión de e.firma; las razones se discuten en §3.11.2). Las integraciones con sistemas judiciales públicos (Tribunales, Fiscalías) tampoco están en alcance del prototipo, aunque la arquitectura permite añadirlas en el futuro como adaptadores driving adicionales sin modificar el dominio.

3.7.3 Selección del Estilo Arquitectónico

La selección del estilo arquitectónico es la decisión más estructurante del diseño porque condiciona todas las decisiones subsiguientes sobre organización del código, manejo de dependencias y estrategia de pruebas. Para el presente proyecto se evaluaron seis alternativas mayores, todas documentadas en la literatura canónica de arquitectura de software: arquitectura en capas tradicional (N-tier), Clean Architecture de Martin [69], Onion Architecture de Palermo, arquitectura hexagonal o de puertos y adaptadores de Cockburn [70], microservicios [71] y monolito modular sin patrón hexagonal.

La arquitectura en capas tradicional fue descartada por su acoplamiento estructural del dominio a la persistencia: en este estilo, el dominio depende típicamente del repositorio (que a su vez depende del motor de base de datos), lo que impide aislar la lógica de negocio para pruebas sin levantar infraestructura real. Este acoplamiento contradice directamente los atributos de testabilidad y evolvabilidad priorizados en §3.7.1, y resulta especialmente inadecuado para un proyecto que adopta TDD como práctica central.

Los microservicios fueron descartados por desproporción operativa respecto al alcance. Newman documenta el conjunto de prerequisites operacionales que un sistema basado en microservicios necesita —orquestación, descubrimiento de servicios, gestión de configuración distribuida, observabilidad cross-service, pipelines de despliegue independientes por servicio, infraestructura de comunicación inter-servicios— [71]. Para un prototipo desarrollado por un equipo de dos personas en un periodo académico, esta complejidad es claramente desproporcionada respecto al beneficio. Fowler ha argumentado explícitamente la conveniencia de iniciar con un monolito modular y extraer microservicios solo cuando la escala lo justifique [72].

Las tres arquitecturas restantes —Clean, Onion y Hexagonal— comparten el mismo principio fundamental: la regla de dependencias hacia adentro, que establece que las capas internas (dominio) no deben conocer las capas externas (infraestructura). Difieren en su formulación y en el grado de subdivisión que prescriben. Clean Architecture introduce cuatro capas concéntricas (Entities, Use Cases, Interface Adapters, Frameworks & Drivers); Onion Architecture introduce variantes de dos a cinco capas según el autor; Hexagonal —en su formulación original de Cockburn— establece únicamente la distinción entre el dominio (interior) y los adaptadores (exterior), conectados por puertos (interfaces de entrada y salida).

Se selecciona la arquitectura hexagonal por tres razones específicas. Primero, su formulación es la más simple: dos categorías (puertos driving y puertos driven) capturan toda la diversidad de adaptadores necesarios sin obligar a clasificaciones más finas que el alcance no amerita. Segundo, la metáfora del hexágono comunica explícitamente que los adaptadores son intercambiables: el dominio queda en el centro y alrededor pueden orbitar tantos adaptadores driving (REST, CLI, WebSocket) y driven (PostgreSQL, Redis, Cincel) como sea necesario. Tercero, la correspondencia con el sistema de tipos de Rust es directa: los puertos se materializan como traits y los adaptadores como structs con bloques impl, y el compilador garantiza mecánicamente la regla de dependencias mediante el grafo de dependencias del workspace de Cargo (véase §3.7.6).

La [tabla 3.76](#) sintetiza la comparativa entre las seis alternativas consideradas, evaluándolas contra los atributos de calidad priorizados en §3.7.1. La decisión final se enuncia formalmente como ADR-01 en §3.7.10.

Tabla 3.76: Comparativa de estilos arquitectónicos contra atributos de calidad priorizados.

Estilo arquitectónico	Testabili- dad	Evolvabili- dad	Adecuación al alcance
N-tier (capas tradicional)	Baja	Baja	Inadecuada (acoplamiento BD)
Clean Architecture	Alta	Alta	Adecuada pero más prescriptiva
Onion Architecture	Alta	Alta	Equivalente a Hexagonal pero menos clara
Hexagonal (Cockburn)	Alta	Alta	Óptima para el alcance
Microservicios	Media	Alta	Desproporcionada operativamente
Monolito modular sin hexagonal	Media	Media	Insuficiente para enforce dependencias

3.7.4 Arquitectura Hexagonal: Definición y Aplicación

La arquitectura hexagonal, propuesta originalmente por Alistair Cockburn en 2005 [70] y refinada por Vernon [73] en el contexto del Domain-Driven Design [74], organiza una aplicación de software en tres capas concéntricas: el dominio en el centro, la aplicación en la capa intermedia, y los adaptadores en la capa exterior.

El dominio contiene los conceptos centrales del problema modelado: entidades (Case, Document, User, Signature, Hearing, AuditEvent, Certificate), value objects (Nuc, ProcessStage, DocumentHash) y servicios de dominio (lógica de negocio que no pertenece naturalmente a una entidad específica). La regla fundamental que gobierna esta capa es que su código no importa absolutamente nada de las capas externas: depende exclusivamente de la biblioteca estándar de Rust y de un conjunto mínimo de crates de bajo nivel (serde para serialización, thiserror para errores tipados, time para manejo de fechas).

La capa de aplicación contiene los casos de uso del sistema: SignContract, RegisterCase, ScheduleHearing, VerifySignature, TransitionCaseStage, QueryAuditLog, entre otros. Cada caso de uso orquesta las entidades del dominio para satisfacer una intención específica del usuario, y declara las dependencias que requiere del exterior mediante traits (los puertos). La aplicación depende exclusivamente del dominio.

Los adaptadores son las implementaciones concretas que conectan el sistema con el mundo exterior. Se clasifican en dos categorías: los puertos driving (también llamados primary o inbound) son aquellos por los que el sistema recibe peticiones —el adaptador REST construido con Axum, los handlers de WebSocket para notificaciones en tiempo real, y opcionalmente un adaptador de línea de comandos para tareas administrativas y procesos batch—; los puertos driven (también llamados secondary u outbound) son aquellos a través de los cuales el sistema invoca servicios externos —repositorios sobre PostgreSQL vía sqlx, almacén de sesiones sobre Redis vía fred, servicios criptográficos sobre la biblioteca ring, cliente RFC 3161 hacia Cincel vía reqwest, y dispatcher SMTP vía lettre.

La regla de dependencias se enuncia formalmente así: ningún módulo de una capa interior puede importar símbolos de una capa exterior. El dominio no importa de aplicación ni de adaptadores; la aplicación no importa de adaptadores. Esta regla se garantiza mecánicamente mediante el grafo de dependencias del workspace de Cargo (véase §3.7.6): si un desarrollador intentara importar `infrastructure::PostgresCaseRepository` desde un módulo del crate `domain`, el compilador rechazaría la compilación por dependencia inexistente, dado que el `Cargo.toml` del crate `domain` no declara a `infrastructure` entre sus dependencias.

La [figura 3.19](#) presenta la arquitectura hexagonal aplicada al prototipo en su forma conceptual. La versión completa, con todos los puertos nombrados como traits específicos y todos los adaptadores nombrados como structs específicas, se presenta en la Figura A.2 del Anexo A.

Arquitectura Hexagonal: capas y regla de dependencias

Las dependencias apuntan hacia el centro;
el dominio no conoce a los adaptadores

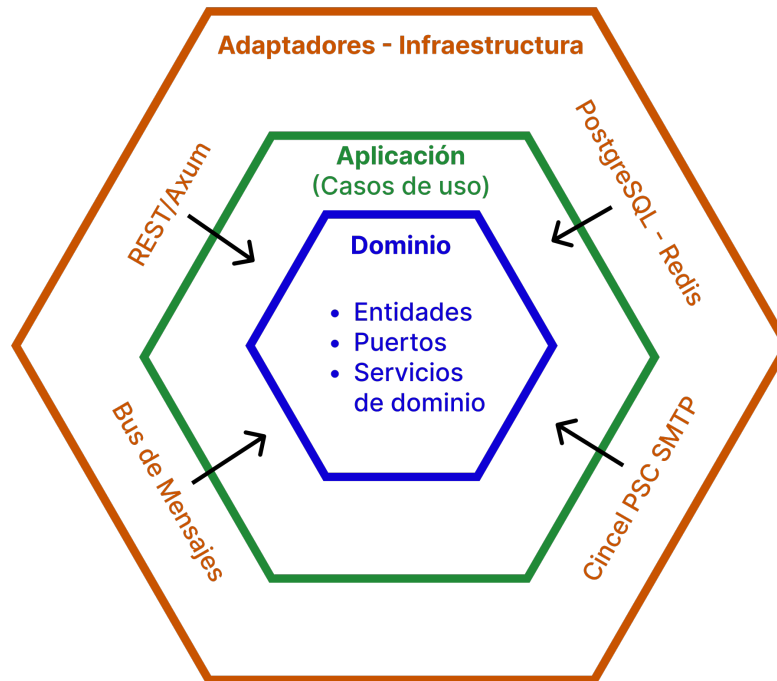


Figura 3.19: Arquitectura Hexagonal: capas conceptuales y regla de dependencias. Las dependencias siempre apuntan hacia el dominio.

El compilador de Rust verifica en tiempo de compilación que `PostgresCaseRepository` cumple con el contrato declarado por el trait `CaseRepository`. Cualquier divergencia (firma incorrecta, tipo de retorno incompatible, ausencia de un método requerido) impide la compilación del programa. Esta verificación mecánica elimina una categoría completa de errores que en lenguajes con tipado dinámico solo se manifestarían en tiempo de ejecución.

3.7.5 Vista de Componentes y Bounded Contexts

La vista de componentes desciende un nivel respecto a la vista de contexto y muestra la organización interna del sistema en términos de bounded contexts —contextos limitados— derivados directamente de las siete agrupaciones funcionales declaradas en §3.2. El concepto de bounded context, introducido por Eric Evans en el contexto de Domain-Driven Design [74], denota una zona del modelo dentro de la cual los conceptos del lenguaje ubicuo tienen un significado específico y consistente.

El sistema se descompone en siete bounded contexts: Identidad y Acceso (autenticación, RBAC, MFA), Gestión de Casos (expedientes y transiciones procesales), Calendario y Plazos (audiencias

y plazos del CNPP), Documentos y Custodia (carga, clasificación y cadena de custodia), Servicios Criptográficos (firma, sellado y verificación), Firma de Contratos (firma con sellado de tiempo) y Operaciones y Auditoría (tableros de control, informes y bitácora). Servicios Criptográficos es un servicio compartido del que dependen tanto Documentos y Custodia como Firma de Contratos.

Vista de Componentes

Vista de los siete contextos limitados y sus dependencias principales

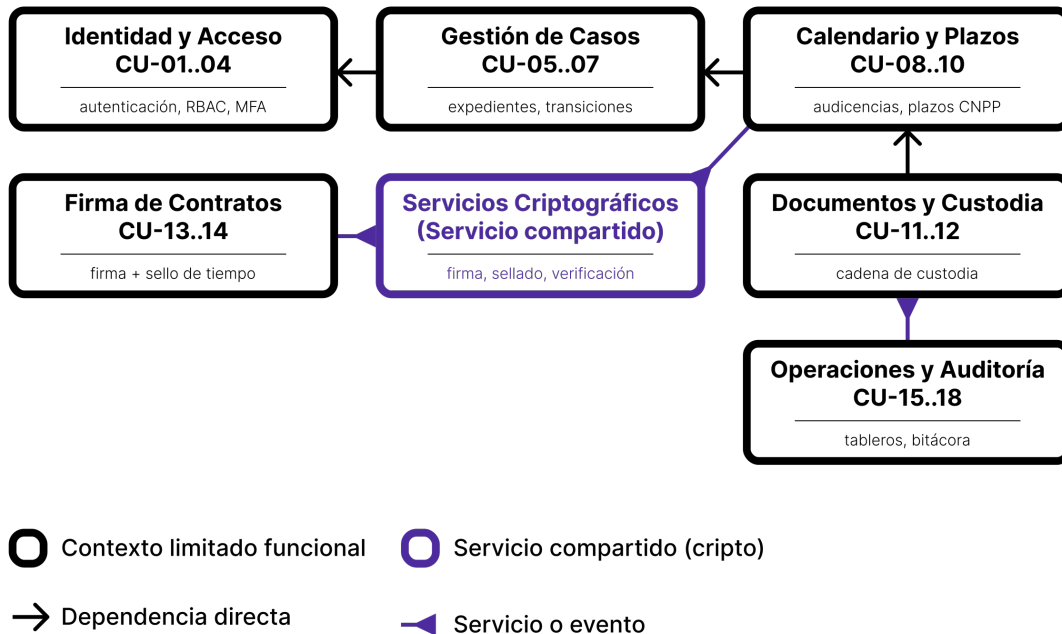


Figura 3.20: Vista de componentes: siete contextos limitados del sistema y sus dependencias principales.

El mapeo entre cada bounded context, los casos de uso que implementa y el crate del workspace de Cargo donde reside su código se presenta en la [tabla 3.77](#). Esta correspondencia permite que las modificaciones a un bounded context queden contenidas dentro de un crate específico, facilitando la atribución de cambios y la asignación de responsabilidades.

Tabla 3.77: Mapeo entre contextos delimitados, casos de uso y módulos del workspace de Cargo.

Contexto delimitado	Casos de uso	Crate / módulo
Identidad y Acceso	CU-01..04	domain::identity, application::identity
Gestión de Casos	CU-05..07	domain::case, application::case
Calendario y Plazos	CU-08..10	domain::calendar, application::calendar
Documentos y Custodia	CU-11..12	domain::document, application::document
Servicios Criptográficos	(transversal)	domain::crypto, infrastructure::crypto
Firma de Contratos	CU-13..14	domain::contract, application::contract
Operaciones y Auditoría	CU-15..18	domain::audit, application::audit

3.7.6 Estructura del Workspace de Cargo

El proyecto se organiza como un workspace de Cargo —el sistema de compilación y gestión de paquetes de Rust— compuesto por cinco crates miembros con responsabilidades estrictamente delimitadas y dependencias permitidas que enforce mecánicamente la regla de la arquitectura hexagonal. Esta estructura se documenta en el `Cargo.toml` raíz del proyecto y se valida en cada compilación.

Los cinco crates son: `domain` (entidades, value objects, traits/puertos y errores de dominio; sus únicas dependencias externas son `serde`, `thiserror` y `time`), `application` (casos de uso, comandos y consultas; depende exclusivamente de `domain` y de `async-trait`), `infrastructure` (adaptadores driven que implementan los traits del dominio; depende de `domain` y `application`), `web` (adaptadores driving HTTP contruidos con Axum, middleware Tower, DTOs y serialización HTTP; depende de `application` y `domain`), y `bin` (composition root que instancia los adaptadores concretos y los inyecta en los casos de uso; depende de todos los anteriores). La [figura 3.21](#) representa esta estructura y las dependencias que el grafo de Cargo permite o prohíbe.

Estructura del espacio de trabajo

Los crates miembros y sus dependencias permitidas.
La regla de dependencias se verifica mecánicamente por el compilador.

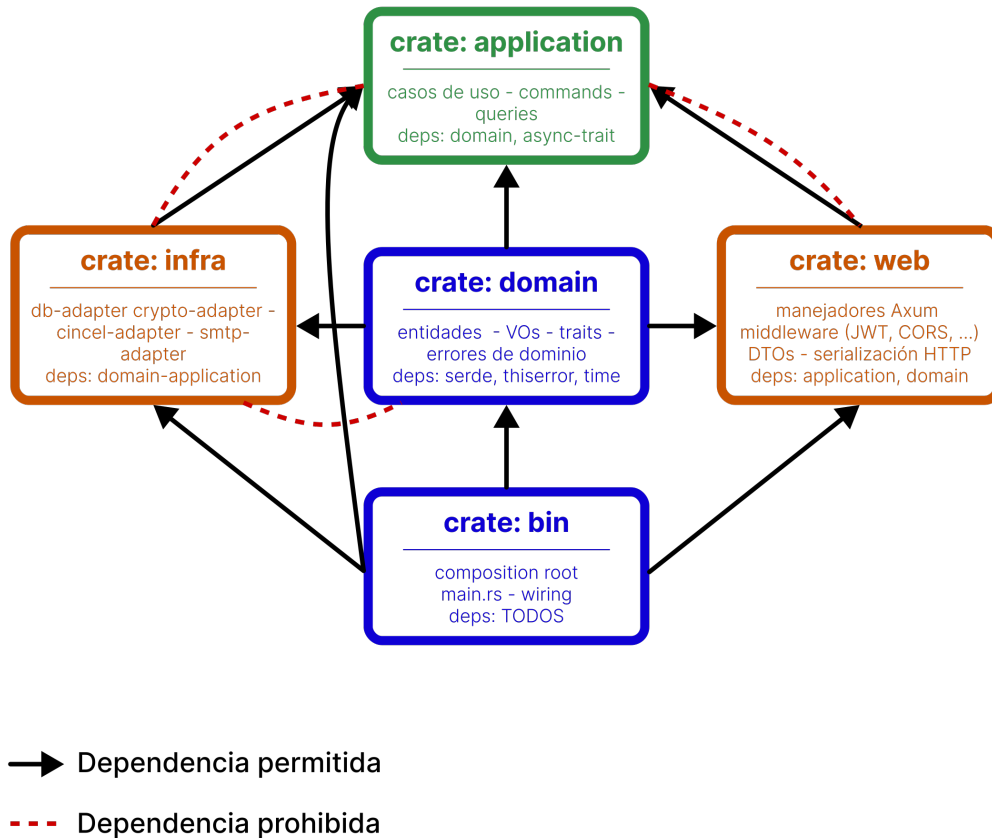


Figura 3.21: Estructura del workspace de Cargo: cinco crates miembros con dependencias permitidas (flechas negras) y prohibidas (flechas rojas punteadas).

La consecuencia técnica de esta organización es que las dependencias prohibidas no son una convención que el equipo deba recordar respetar: son una imposibilidad mecánica. Si un módulo del crate domain intenta importar un símbolo del crate infrastructure mediante una declaración use `infrastructure::PostgresCaseRepository`, el compilador emite el error «unresolved import» porque el Cargo.toml de domain no incluye infrastructure entre sus dependencias. La regla de dependencias se verifica mecánicamente por el compilador en cada build.

El sistema de Cargo features se utiliza para alternar adaptadores intercambiables en tiempo de compilación. Por ejemplo, la feature `cinsel-tsa` activa el adaptador para el PSC Cinsel, mientras que una futura feature `seguridata-tsa` activaría un adaptador alternativo para el PSC SeguriData. La selección se realiza al compilar el binario, manteniendo un único path de código para cada despliegue específico y evitando la complejidad de un sistema de inyección de dependencias en runtime.

3.7.7 Stack Tecnológico

Esta subsección documenta y justifica las tecnologías concretas seleccionadas para implementar el sistema. Cada elección se sustenta en los atributos de calidad priorizados en §3.7.1 y se compara explícitamente con sus alternativas serias del ecosistema actual. Las decisiones más estructurantes se registran adicionalmente como ADRs formales en §3.7.10.

Justificación de Rust como lenguaje del backend

El backend del prototipo se implementa en Rust [75]. La selección responde principalmente a los atributos de seguridad e integridad priorizados en §3.7.1, en cuanto Rust elimina por construcción —mediante su sistema de ownership y verificación en tiempo de compilación— las clases de errores de memoria que han sido históricamente la fuente principal de vulnerabilidades explotables en software de sistemas. Microsoft ha documentado que aproximadamente el 70 % de las vulnerabilidades reportadas en sus productos a lo largo de una década correspondieron a errores de manejo de memoria [76]; un porcentaje similar ha sido reportado por el equipo de seguridad de Chromium. Rust elimina categóricamente estos errores sin recurrir a un recolector de basura, lo que lo distingue de Go, Java o cualquier lenguaje con runtime managed.

Frente a Go, Rust ofrece tipos algebraicos (Result, Option, enums con datos asociados) que permiten modelar errores y casos especiales como parte del sistema de tipos, en lugar de mediante valores centinela o múltiples valores de retorno como hace Go. Esta expresividad es particularmente valiosa para un dominio en el que los errores deben ser explícitos y exhaustivos —una operación de firma puede fallar por certificado revocado, por reloj fuera de sincronía con la TSA, por documento que excede el tamaño máximo, entre otros casos—, y donde olvidar manejar uno de ellos no debe ser silencioso. Rust también ofrece zero-cost abstractions, permitiendo construir abstracciones de alto nivel (traits genéricos, iteradores) sin penalización en tiempo de ejecución, lo que Go renuncia a soportar por su modelo de simplicidad explícita.

Frente a Java o Kotlin con Spring, Rust evita el costo del runtime JVM —tiempo de arranque del orden de segundos, huella de memoria elevada, dependencia de un intérprete de bytecode— que es desproporcionado para un prototipo desarrollado en un equipo de desarrollo individual. Frente a Node.js con TypeScript, Rust proporciona tipado estático verificado en compilación (TypeScript es type erasure: los tipos desaparecen en runtime y no protegen contra errores reales del mundo) y rendimiento criptográfico sustancialmente superior, esencial para un sistema cuyo eje son las operaciones de firma, hash y cifrado intensivo. Frente a Python con FastAPI, Rust elimina el Global Interpreter Lock que limita la concurrencia real de Python, y ofrece un ecosistema criptográfico que ha sido sometido a auditorías formales independientes (particularmente la biblioteca ring, que utilizamos para las primitivas).

Una propiedad operacional adicional de Rust pertinente al alcance del prototipo es que el binario resultante es ejecutable único, sin dependencia de runtime, intérprete ni gestor de paquetes en producción. El despliegue se reduce a copiar un archivo de aproximadamente 15 MB al servidor objetivo, lo que simplifica la operación y reduce significativamente la superficie de ataque del entorno desplegado.

Backend: Axum sobre el ecosistema tokio, tower y hyper

Como framework web se selecciona Axum, desarrollado por el equipo de tokio. Axum se construye sobre tres capas estándar de facto en el ecosistema Rust: tokio como runtime asíncrono multi-thread

con scheduler work-stealing, tower como abstracción de middleware componible basada en el trait `Service<Request, Response>`, y hyper como implementación de los protocolos HTTP/1.1 y HTTP/2. Esta estratificación permite que cada nivel de la pila se evalúe y evolucione independientemente, y que los componentes desarrollados para tower puedan reutilizarse fuera del contexto HTTP.

Axum se distingue de alternativas como actix-web o rocket por no ser opinado respecto a la organización del código de la aplicación, lo que facilita la implementación del estilo arquitectónico hexagonal seleccionado en §3.7.3 sin tener que combatir las convenciones del framework. Los handlers de Axum reciben sus dependencias mediante extractores tipados (extractors), permitiendo inyectar los casos de uso de la capa de aplicación de manera explícita y verificable en compilación.

El pipeline de middleware Tower se configura para ejecutar, en orden, los siguientes interceptores transversales: CORS para el control de origen cruzado de peticiones del navegador; Rate Limiting con ventana deslizante para protección contra abuso; Tracing con propagación de identificador de petición para observabilidad; autenticación JWT para verificación de identidad del solicitante; logging estructurado para auditoría operativa. Cada middleware es composable —su ejecución se especifica declarativamente al construir el router— y verificable en compilación por el sistema de tipos.

Frontend: Astro con Svelte Islands

El frontend del sistema se implementa con Astro como meta-framework y Svelte como librería de componentes interactivos, siguiendo el patrón Islands Architecture propuesto por Saylor-Miller y Miller [77]. Bajo este patrón, las páginas se renderizan como HTML estático por defecto, y solo los componentes que requieren interactividad (calendario jurídico, dashboard, interfaz de verificación de firma) se hidratan selectivamente como islas reactivas. Esta estrategia minimiza el JavaScript enviado al navegador a aquello estrictamente necesario, mejorando los tiempos de carga y reduciendo la superficie de ataque del cliente.

Frente a Next.js con React, Astro y Svelte tienen tres ventajas específicas para el alcance del prototipo. Primero, Svelte compila a JavaScript imperativo sin Virtual DOM ni runtime de framework, produciendo bundles considerablemente más ligeros que React. Segundo, la reactividad de Svelte es sintáctica —se declara con `$:` y asignaciones a variables— lo que reduce el boilerplate frente al modelo de hooks de React. Tercero, Astro está diseñado desde su concepción para emitir el mínimo JavaScript posible, mientras que Next.js parte del modelo de SPA hidratada completa y solo recientemente ha introducido los Server Components para mitigar ese problema.

Frente a SvelteKit puro, Astro se elige porque las páginas mayoritariamente informativas del sistema (landing, documentación, vistas de solo lectura) no se benefician de hidratación completa; ahí Astro emite HTML estático directamente. SvelteKit, en cambio, hidrata todas las páginas como SPA, perdiendo la oportunidad de servir contenido estático puro. La combinación Astro + Svelte aprovecha lo mejor de ambos: contenido estático por defecto y reactividad rica solo donde se necesita.

Persistencia híbrida

El sistema emplea un modelo de persistencia híbrido que combina PostgreSQL como base de datos relacional para los datos con valor probatorio, con Redis como almacén clave-valor en memoria para datos volátiles y comunicación en tiempo real. La justificación completa de esta separación, los esquemas de cada motor, y el mecanismo de encadenamiento criptográfico SHA-256 que garantiza la inmutabilidad de la bitácora de auditoría se documentan en §3.8 (Modelado de Base de Datos Híbrida). Los crates utilizados para acceder a cada motor son `sqlx` para PostgreSQL —que ofrece

verificación de queries SQL en tiempo de compilación contra el esquema real— y fred para Redis —cliente asíncrono con soporte nativo para pub/sub.

Inventario completo de crates

El proyecto utiliza un conjunto curado de crates externos del ecosistema Rust, todos publicados en crates.io con versiones pinneadas en los archivos `Cargo.toml` de cada crate del workspace. Los crates se agrupan por capa arquitectónica para facilitar la auditoría y para enforce las reglas de dependencias entre capas discutidas en §3.7.6. La [tabla 3.78](#) enumera los crates principales del proyecto, agrupados por capa y con sus respectivas funciones. La versión mínima soportada del compilador (Minimum Supported Rust Version, MSRV) es Rust 1.78 estable.

Tabla 3.78: Inventario de crates externos utilizados por el proyecto, agrupados por capa arquitectónica.

Capa	Crate	Función
Dominio	serde	Serialización/deserialización tipada
Dominio	thiserror	Errores tipados por capa
Dominio	time	Manejo de fechas con zona horaria
Dominio	uuid	Identificadores únicos universales
Aplicación	async-trait	Traits asíncronos
Infraestructura cripto	ring	Hash, AES-GCM, HMAC (auditado)
Infraestructura cripto	x509-cert + der	Manejo de certificados X.509 RFC 5280
Infraestructura cripto	rsa	Firma digital RSA-3072 PKCS#1 v1.5
Infraestructura cripto	argon2	Hashing de contraseñas (RFC 9106)
Infraestructura cripto	totp-rs	Autenticación multifactor TOTP (RFC 6238)
Infraestructura datos	sqlx	Cliente PostgreSQL con verificación en compile-time
Infraestructura datos	fred	Cliente Redis asíncrono con pub/sub
Infraestructura red	reqwest	Cliente HTTP asíncrono (Cinco TSA)
Infraestructura red	lettre	Cliente SMTP con TLS y SASL
Web/HTTP	axum	Framework web sobre tokio/tower/hyper
Web/HTTP	tower / tower-http	Middleware composable
Web/HTTP	tokio	Runtime asíncrono multi-thread
Observabilidad	tracing + tracing-subscriber	Logs estructurados con spans
Validación	validator	Validación de DTOs HTTP
Configuración	config + dotenvy	Carga de configuración desde entorno
Errores (boundaries)	anyhow	Errores polimórficos en <code>main.rs</code> y tests
Testing	mockall, proptest, rstest, wiremock	Mocks, pruebas basadas en propiedades, fixtures, mock HTTP

3.7.8 Patrones Arquitectónicos Transversales

Esta subsección documenta cuatro patrones que atraviesan transversalmente todas las capas de la arquitectura. Su tratamiento explícito y consistente es lo que permite que el sistema mantenga coherencia operativa en escala: errores tipados, concurrencia estructurada, inyección de dependencias por composición, y observabilidad estructurada.

Manejo de errores

El sistema adopta una estrategia de errores tipados por capa, implementada con la macro `derive` de `thiserror`. Cada capa define su propio tipo de error con variantes específicas: `DomainError` captura las violaciones de invariantes de negocio (caso inválido, transición prohibida, firma rechazada); `ApplicationError` envuelve errores de orquestación de casos de uso e incluye `DomainError` como variante; los crates de infraestructura definen errores específicos de su backend (`PostgresError`, `CinzelError`, `SmtplibError`); finalmente, `ApiError` representa errores HTTP y mapea desde las capas anteriores mediante el `trait IntoResponse` de `Axum`.

Esta tipificación contrasta con el uso indiscriminado de `anyhow`, que se reserva exclusivamente para el binario principal (`bin/main.rs`) y para las pruebas, donde la conveniencia del polimorfismo de errores supera la necesidad de discriminar tipos. En cambio, en los crates de dominio, aplicación e infraestructura, los errores deben ser exhaustivos y discriminables porque cada caller necesita decidir qué hacer ante cada variante específica.

Modelo de concurrencia asíncrona

El sistema utiliza `tokio` como runtime asíncrono multi-thread con `scheduler work-stealing`, configurado por defecto con tantos worker threads como núcleos lógicos disponibles. Las operaciones I/O bound (consultas a PostgreSQL, llamadas a Cinzel, envíos SMTP) se ejecutan asíncronamente sin bloquear los workers, permitiendo concurrencia masiva con un consumo modesto de threads del sistema operativo. La concurrencia entre tareas se estructura mediante `tokio::spawn` con joins explícitos—siguiendo el principio de `structured concurrency`— para garantizar que ninguna tarea escape del scope de su parent y produzca leaks o panics no manejados.

Las operaciones que pueden quedar bloqueadas indefinidamente (invocaciones HTTP a sistemas externos, esperas a locks distribuidos) se envuelven con `tokio::time::timeout` para garantizar terminación acotada. Las operaciones cancelables utilizan `CancellationToken` propagado desde el handler raíz, permitiendo que un cliente que cierra la conexión HTTP libere inmediatamente todos los recursos asociados a su petición. Los traits `Send + Sync` requeridos para los puertos garantizan en tiempo de compilación que cualquier implementación es segura para usar entre threads, eliminando una categoría completa de errores de concurrencia.

Inyección de dependencias por composición

La inyección de dependencias se realiza por composición explícita en el `composition root`—el archivo `bin/main.rs`—, sin recurrir a un contenedor de DI en runtime. Los casos de uso reciben sus dependencias como parámetros genéricos restringidos por traits (`impl Trait`) o como `trait objects` (`Arc<dyn Trait>`). Por ejemplo, el caso de uso `SignContract` se define como `SignContract<R, S, T>` donde `R`: `CaseRepository`, `S`: `DocumentSigner`, `T`: `TimestampService`; `main.rs` construye `PostgresCaseRepository`, `RingRsaSigner` y `CinzelTsaAdapter`, los inyecta en `SignContract`, y registra el

resultado en el router de Axum. Esta estrategia es completamente verificable en tiempo de compilación —si un adaptador no satisface el contrato del puerto, el programa no compila— y elimina la categoría de errores característicos de los frameworks DI (dependencias no resueltas, ciclos detectados solo en runtime, configuraciones mal escritas).

Observabilidad estructurada

El sistema utiliza el ecosistema tracing para producir logs estructurados con spans tipados. Cada petición HTTP genera un span raíz con un `request_id` propagado a través de todas las invocaciones asíncronas mediante el contexto de tokio. Los logs se emiten en formato JSON line-delimited (JSONL), facilitando su ingesta por agregadores como Vector, Loki o Elasticsearch. Los niveles de verbosidad son configurables por módulo a través de la variable de entorno `RUST_LOG`, permitiendo aumentar temporalmente el detalle de una capa específica sin reiniciar el servicio. Para trazabilidad distribuida, el crate tracing-opentelemetry permite exportar spans a backends compatibles (Jaeger, Tempo) sin modificar el código de la aplicación. La política de redacción de información sensible (referencia cruzada a RNF-03) está implementada como un layer personalizado del subscriber, que aplica patrones regex sobre los campos antes de su emisión para sanitizar secretos y material criptográfico que pudieran filtrarse.

3.7.9 Vista de Seguridad: Fronteras de Confianza

Esta subsección desarrolla la vista de seguridad arquitectónica, complementaria al diseño criptográfico detallado en §3.11. Mientras §3.11 documenta los algoritmos criptográficos específicos (RSA-3072, AES-256-GCM, SHA-256, RFC 3161, PKI con CA interna) y sus parámetros, esta subsección documenta cómo esos mecanismos se distribuyen entre las distintas zonas de confianza del sistema y qué controles se aplican en cada cruce de frontera.

El modelo adoptado sigue el principio de defensa en profundidad formalizado por Saltzer y Schroeder [78] y desarrollado operativamente en el OWASP Application Security Verification Standard [79]. La Figura A.1 en el Anexo A presenta el modelo completo con cuatro zonas de confianza y los controles de seguridad aplicados en cada cruce.

El sistema se modela como cuatro zonas de confianza separadas por tres fronteras explícitas. La primera zona, la red pública, comprende todo aquello que no está bajo control directo del sistema: el navegador del usuario final, los actores adversarios potenciales, y los servicios externos como Cincel PSC y los proveedores SMTP que aunque sean legítimos no operan dentro del perímetro de seguridad del prototipo. La segunda zona, el perímetro de aplicación, contiene el reverse proxy con terminación TLS y la API pública expuesta. La tercera zona, el núcleo aplicativo, contiene el binario Rust con sus tres módulos internos (web, application, domain). La cuarta y más confiable zona, datos persistentes y secretos, contiene PostgreSQL, Redis y el subsistema de gestión de claves criptográficas.

El cruce de la primera frontera —de la red pública al perímetro de aplicación— se controla mediante terminación TLS 1.3 con suites de cifrado modernas; rate limiting con ventana deslizante para protección contra abuso de la API; un Web Application Firewall que filtra patrones de ataque conocidos; y cabeceras CORS estrictas que restringen el origen de las peticiones legítimas. La superficie expuesta a esta frontera es deliberadamente mínima: solo los endpoints HTTPS estrictamente necesarios.

El cruce de la segunda frontera —del perímetro al núcleo aplicativo— se controla mediante autenticación basada en JWT (JSON Web Token) firmado por la propia aplicación; validación

exhaustiva de toda entrada del usuario antes de cualquier procesamiento; y autorización basada en roles (RBAC) que restringe qué operaciones puede invocar cada rol (socio, paralegal, cliente). Cualquier petición que no satisfaga las tres verificaciones es rechazada con un código de error apropiado y registrada en la bitácora de auditoría.

El cruce de la tercera frontera —del núcleo aplicativo a datos persistentes y secretos— se controla mediante conexiones TLS internas entre el binario Rust y los motores de PostgreSQL y Redis; uso obligatorio de consultas parametrizadas mediante `sqlx` (que verifica en compile-time la conformidad de cada query con el esquema, eliminando la posibilidad de inyección SQL); y cifrado en reposo de todos los documentos mediante el patrón `envelope encryption` con KEK protegida por el módulo de gestión de claves (cuyo diseño detallado se documenta en §3.11.4).

Los servicios externos se modelan como entidades de la zona no confiable a las que el sistema invoca explícitamente con canales seguros: la integración con Cincel PSC para sellado de tiempo (RFC 3161) utiliza TLS mutuo más verificación de la firma del sello recibido; la integración con el proveedor SMTP utiliza TLS más autenticación SASL. En ningún caso se confía en estos servicios para operaciones de seguridad sin verificación local del resultado: por ejemplo, el sello de tiempo recibido de Cincel se verifica criptográficamente contra la cadena de certificados del PSC antes de ser aceptado e incorporado al expediente del documento firmado.

El modelo de amenazas STRIDE de Shostack [80] se aplicó como herramienta de revisión sistemática durante el diseño para verificar que cada una de las seis categorías de amenazas (Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege) tuviese al menos un control asignado. La matriz resultante demuestra que la combinación de los controles enumerados ofrece cobertura para todas las categorías, con énfasis particular en Tampering (mediante el encadenamiento SHA-256 de la bitácora) y Repudiation (mediante el sellado de tiempo independiente del PSC).

3.7.10 Decisiones Arquitectónicas Significativas (ADRs)

Las decisiones arquitectónicas más estructurantes del sistema se registran formalmente como Architecture Decision Records (ADRs) en el formato propuesto por Michael Nygard [66]. Cada ADR documenta de forma autocontenida cuatro elementos: el contexto del problema que motivó la decisión, las alternativas consideradas, la decisión adoptada, y las consecuencias —tanto positivas como negativas— de la decisión. Los seis ADRs siguientes cubren las decisiones cuya reversión implicaría una refactorización significativa.

ADR-01. Adopción de Arquitectura Hexagonal

Contexto: el sistema requiere alta testabilidad (XP/TDD) y evolvabilidad (sustitución de PSC, motor de BD). Alternativas: N-tier, Clean, Onion, Hexagonal, Microservicios, Monolito Modular sin patrón hexagonal. Decisión: Monolito Modular con Arquitectura Hexagonal de Cockburn. Consecuencias positivas: dominio aislado y testeable, adaptadores intercambiables, regla de dependencias verificable mecánicamente. Consecuencias negativas: ligero overhead de indirección por cada operación que cruza una capa, requiere disciplina del equipo para no introducir atajos.

ADR-02. Rust como lenguaje del backend

Contexto: prototipo de seguridad con operaciones criptográficas intensivas. Alternativas: Go, Java/Kotlin con Spring, Node.js con TypeScript, Python con FastAPI. Decisión: Rust. Consecuencias positivas: seguridad de memoria sin GC, sistema de tipos algebraicos, ecosistema criptográfico auditado, binario único sin runtime. Consecuencias negativas: curva de aprendizaje del ownership y borrow checker, ecosistema más pequeño que Java o Node, tiempos de compilación más largos.

ADR-03. Axum como framework web

Contexto: necesidad de un framework HTTP que no impusiera estructura incompatible con el estilo hexagonal. Alternativas: actix-web, rocket, warp. Decisión: Axum sobre tokio/tower/hyper. Consecuencias positivas: framework no opinado, ecosistema tower reutilizable para otros servicios, mantenido por el equipo de tokio. Consecuencias negativas: API ergonómica menos madura que actix-web, documentación todavía en evolución.

ADR-04. Astro + Svelte Islands para el frontend

Contexto: páginas mayoritariamente informativas con islas de interactividad rica (calendario, dashboard, verificación de firma). Alternativas: Next.js + React, SvelteKit puro, Remix. Decisión: Astro como meta-framework con Svelte como librería de componentes interactivos. Consecuencias positivas: HTML estático por defecto, JavaScript mínimo enviado al cliente, Svelte sin Virtual DOM. Consecuencias negativas: dos sistemas de templating (Astro y Svelte) que el desarrollador debe conocer, ecosistema de componentes Svelte más pequeño que React.

ADR-05. Monolito Modular sobre Microservicios

Contexto: equipo de desarrollo de dos personas en periodo académico, alcance del prototipo no requiere despliegue distribuido. Alternativas: descomposición en microservicios desde el inicio, monolito modular. Decisión: Monolito Modular siguiendo la recomendación MonolithFirst de Fowler [72]. Consecuencias positivas: simplicidad operativa, despliegue como binario único, sin overhead de comunicación inter-servicios, facilidad de refactorización. Consecuencias negativas: escalado monolítico (ya aceptable para el alcance del prototipo), imposibilidad de desplegar componentes independientemente.

ADR-06. Persistencia híbrida PostgreSQL + Redis

Contexto: el sistema maneja tanto datos con valor probatorio (que requieren persistencia transaccional duradera) como datos volátiles para sesiones, caché y notificaciones en tiempo real. Alternativas: PostgreSQL exclusivamente, Redis exclusivamente, PostgreSQL + Redis. Decisión: PostgreSQL para datos persistentes con responsabilidades específicas en §3.8.1, Redis para datos volátiles con TTL conforme a §3.8.2. Consecuencias positivas: cada motor utilizado para lo que mejor hace, baja latencia para sesiones y notificaciones, integridad transaccional para operaciones críticas. Consecuencias negativas: necesidad de operar dos motores de almacenamiento, mayor complejidad operativa, necesidad de coherencia eventual entre ambos.

3.7.11 Trazabilidad Arquitectura ↔ Requerimientos

Esta subsección presenta la matriz de trazabilidad que cierra el Capítulo 3 demostrando que cada requerimiento funcional y no funcional cuenta con un componente arquitectónico responsable, y que ningún componente arquitectónico carece de justificación en un requerimiento. La [tabla 3.79](#) sintetiza este mapeo en una vista de alto nivel; la matriz completa con cada uno de los veintidós casos de uso (CU-01 a CU-18 y RNF-01 a RNF-09 de §3.4) se desarrolla en §3.7.11.1 (matriz extendida) que se entrega como anexo electrónico complementario al documento.

Tabla 3.79: Mapeo de alto nivel entre componentes arquitectónicos y los requerimientos que satisfacen.

Componente arquitectónico	Requerimientos atendidos
Bounded Context «Identidad y Acceso»	CU-01..04, RNF-01, RNF-02, RNF-09
Bounded Context «Gestión de Casos»	CU-05..07, RNF-04 (parcial)
Bounded Context «Calendario y Plazos»	CU-08..10
Bounded Context «Documentos y Custodia»	CU-11..12, RNF-03, RNF-04
Bounded Context «Servicios Criptográficos»	CU-11..14, RNF-03
Bounded Context «Firma de Contratos»	CU-13..14
Bounded Context «Operaciones y Auditoría»	CU-15..17, RNF-04, RNF-08
Crate domain con traits (puertos)	Soporta evolvabilidad transversal
Workspace de Cargo con regla de dependencias	Mantenibilidad transversal
Pipeline Tower middleware	RNF-09 (autenticación), seguridad cross-cutting
Modelo de fronteras de confianza (§3.7.9)	RNF-01, RNF-02, RNF-03, RNF-09
Subsistema observabilidad (tracing)	RNF-08

Fitness functions

Siguiendo el enfoque de arquitecturas evolutivas formalizado por Ford, Parsons y Kua [68], la coherencia entre la arquitectura prescrita y la arquitectura efectiva del código se verifica mediante un conjunto de fitness functions: pruebas automatizadas que comprueban propiedades arquitectónicas que no podrían verificarse mediante pruebas funcionales tradicionales. Estas fitness functions se ejecutan como parte del pipeline de Integración Continua y, en caso de fallo, bloquean la integración del cambio en la rama principal.

Las fitness functions implementadas para el prototipo son: (1) verificación de que ningún módulo del crate domain importa símbolos de los crates infrastructure ni web (verificada por el compilador en cada build); (2) verificación de que todo handler HTTP envuelve su lógica en un span de tracing (verificada con un lint personalizado de clippy); (3) verificación de que ningún log emitido contiene literales que matcheen patrones de claves criptográficas (verificada con un test que ejecuta toda la suite e inspecciona los logs producidos); (4) verificación de que cada trait que define un puerto

driven tiene al menos una implementación concreta y al menos un mock para tests (verificada por inspección del workspace en cada build); (5) verificación de que el binario compilado no excede 25 MB (verificada por el pipeline de release).

3.8 Modelado de Base de Datos Híbrida

El sistema emplea un modelo de persistencia híbrido que combina **PostgreSQL** (base de datos relacional) con **Redis** (almacén clave-valor en memoria), con responsabilidades estrictamente delimitadas. Esta decisión responde a los requisitos funcionales y no funcionales identificados en el protocolo, particularmente RF-22 (bitácora de auditoría), RNF-04 (integridad append-only) y la necesidad de notificaciones en tiempo real.

3.8.1 PostgreSQL: Datos Persistentes con Valor Probatorio

PostgreSQL se selecciona como motor relacional principal por las siguientes razones: (1) soporte nativo de **JSONB** para metadatos variables de expedientes, lo que permite modelar la diversidad del sistema acusatorio oral mexicano (CNPP, Art. 211-215) sin sacrificar la integridad referencial; (2) **RULE** para enforce de append-only en la bitácora de auditoría, impidiendo operaciones UPDATE y DELETE a nivel de motor; (3) extensiones criptográficas nativas (pgcrypto); (4) tipo de dato INET para registro de direcciones IP en la bitácora.

La bitácora de auditoría (audit_log) implementa un mecanismo de **encadenamiento SHA-256**: cada registro incluye un campo sha256_chain que contiene el hash (véase §2.3.1) del registro anterior concatenado con los datos del registro actual. Esto crea una cadena verificable de integridad que permite detectar cualquier manipulación retroactiva, cumpliendo con el Art. 33 del Código de Comercio (retención mínima de 10 años).

Decisión de diseño: Single-Tenant

El sistema se diseña para un solo despacho legal (single-tenant), eliminando la complejidad de aislamiento multi-tenant descrita en RNF-01 y RNF-05 del protocolo original. Esta simplificación es coherente con el alcance del prototipo y reduce significativamente la superficie de ataque.

3.8.2 Redis: Datos Volátiles y Comunicación en Tiempo Real

Redis se emplea exclusivamente para datos efímeros que **no requieren persistencia a largo plazo ni tienen valor probatorio**:

- **Sesiones JWT**: almacenamiento de tokens de sesión con TTL configurable (24h por defecto), permitiendo invalidación inmediata por revocación.
- **Caché de permisos**: materialización temporal de las autorizaciones del usuario (TTL 5 minutos) para evitar consultas repetidas a PostgreSQL en cada petición.
- **Pub/Sub para notificaciones**: canal de comunicación entre el backend y los clientes WebSocket. Cuando ocurre un evento relevante (nuevo documento, firma completada, deadline próximo), se publica en un canal Redis que el adaptador WebSocket consume y retransmite al navegador del usuario.

- ### 3.8.3 Diagrama del Modelo de Datos

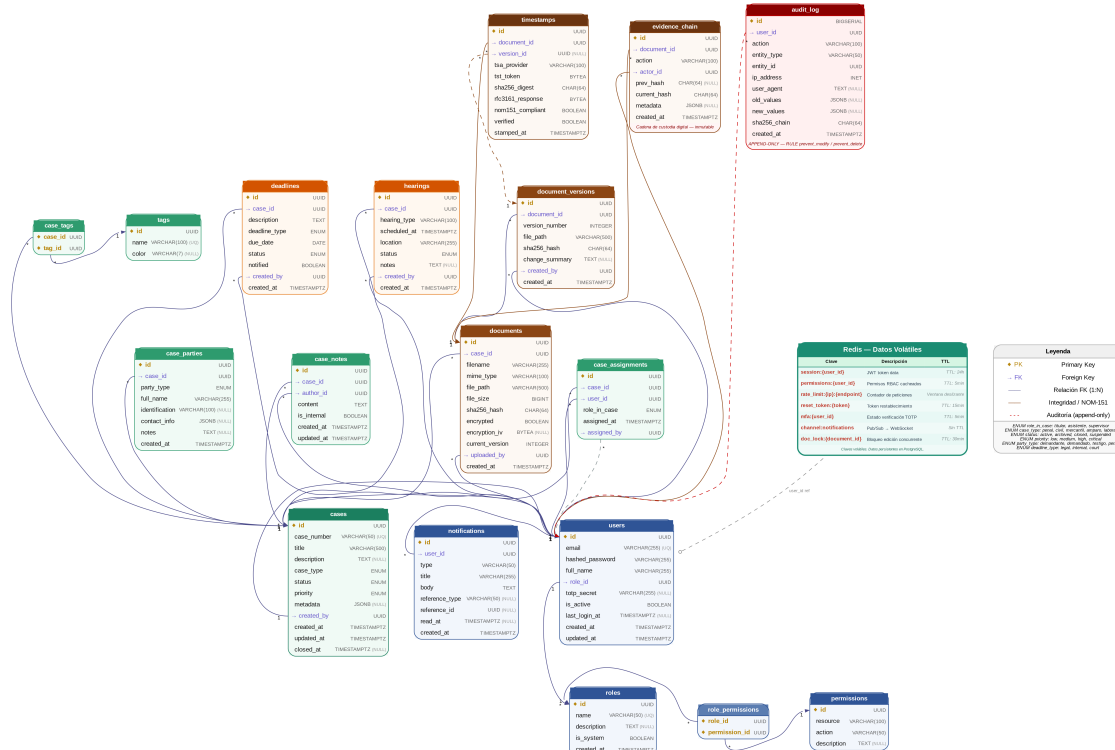
Modelo de Base de Datos Híbrido — Sistema de Gestión de Expedientes Legales
PostgreSQL + Redis

Figura 3.22: Modelo de datos híbrido: PostgreSQL para datos persistentes con valor probatorio, Redis para datos volátiles.

Nótese que la tabla `audit_log` está resaltada en rojo para indicar su naturaleza especial: es la única tabla del sistema con restricción `RULE` que impide `UPDATE` y `DELETE`. Su campo `sha256_chain` implementa el encadenamiento criptográfico descrito en la [sección 3.8.1](#). El campo `metadata` `JSONB` en la tabla `cases` permite almacenar atributos específicos de cada tipo de procedimiento sin necesidad de alterar el esquema relacional.

3.9 Diagrama de Despliegue y Stack Tecnológico

La **figura 3.23** presenta la vista de despliegue del sistema, ilustrando la interacción entre las capas del frontend, el backend y los servicios de infraestructura.

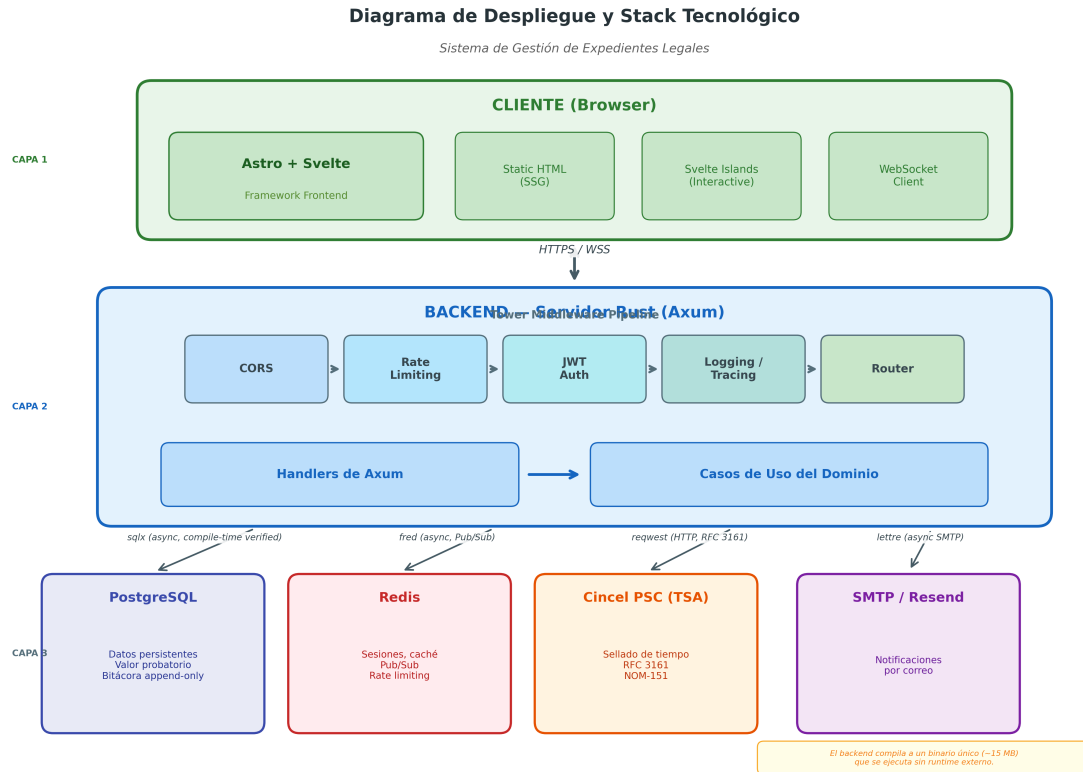


Figura 3.23: Diagrama de despliegue: Astro+Svelte (cliente) → Axum/Rust (backend) → PostgreSQL + Redis + servicios externos.

El backend Rust compila a un **binario único** de aproximadamente 15 MB que incluye todas las dependencias. El binario Rust se ejecuta directamente sin runtime externo, eliminando la necesidad de intérpretes, servidores web adicionales o gestores de paquetes. Esto simplifica significativamente el despliegue y reduce la superficie de ataque del servidor.

La capa de **Tower Middleware** opera como un pipeline composable donde cada middleware es una capa que envuelve al siguiente. El flujo de una petición HTTP es: CORS → Rate Limiting → Autenticación JWT → Logging → Handler de Axum → Dominio. Esta composición es declarativa y verificada en tiempo de compilación por el sistema de tipos de Rust.

La comunicación con **Cincel PSC** para sellado de tiempo RFC 3161 se realiza a través de request (cliente HTTP asíncrono). El diseño del puerto TimestampService como trait abstracto permite sustituir Cincel por cualquier otra TSA (SeguriData, CECOBAN; véase §2.3.3.4) implementando únicamente un nuevo adaptador, sin modificar el dominio ni los demás componentes del sistema.

Las conexiones a **PostgreSQL** se gestionan mediante sqlx, que ofrece verificación de queries SQL en tiempo de compilación contra el esquema real de la base de datos. Las conexiones a **Redis** se gestionan mediante fred, un cliente asíncrono compatible con cluster que soporta pub/sub nativo para las notificaciones en tiempo real.

3.10 Modelo de Datos Jurídico-Técnico

La fundamentación del proceso penal expuesta en el marco teórico tiene una consecuencia directa sobre el diseño del prototipo: la base de datos no puede ser un conjunto de tablas genéricas, sino que debe reflejar fielmente las dependencias y restricciones que el CNPP impone. Esta sección articula los vínculos explícitos entre la teoría jurídica y los requerimientos funcionales.

Un caso en el prototipo no es un registro estático, sino una entidad que evoluciona a través de los estados que el CNPP define como etapas [1]. La transición de un estado a otro solo es posible mediante la carga del documento procesal habilitante: de Investigación a Intermedia únicamente mediante el escrito de acusación; de Intermedia a Juicio Oral mediante el auto de apertura. El historial de transiciones debe mantenerse de forma inmutable como parte del expediente, dado que un tribunal revisor puede requerir verificar la secuencia procesal completa.

3.11 Diseño Criptográfico del Prototipo

Esta sección documenta las decisiones de diseño criptográfico adoptadas para el prototipo, fundamentadas en los conceptos teóricos expuestos en el capítulo 2 y en las restricciones impuestas por el marco legal mexicano. Cada decisión se justifica con referencia a los estándares y publicaciones del NIST, las RFC del IETF y las guías de OWASP que las sustentan.

3.11.1 Nivel de Seguridad Objetivo

El prototipo adopta un nivel de fortaleza de seguridad de 128 bits conforme a NIST SP 800-57 Part 1 Rev 5 [37]. Este nivel unificado exige que cada primitivo criptográfico ofrezca al menos 128 bits de resistencia: SHA-256 proporciona 128 bits de resistencia a colisiones, AES-256 proporciona 256 bits de fortaleza, y RSA-3072 proporciona aproximadamente 128 bits. La elección de 128 bits como objetivo coherente garantiza que ningún eslabón de la cadena criptográfica sea más débil que los demás. NIST considera este nivel seguro al menos hasta 2030 para aplicaciones de uso general.

La Tabla 2 del NIST SP 800-57 [37] clasifica los niveles de fortaleza en función de los tamaños de clave recomendados para cada familia de algoritmos. El nivel de 112 bits, correspondiente a RSA-2048, está clasificado como legacy-use: aceptable para procesar información existente, pero no recomendado para proteger información nueva más allá de 2030. El nivel de 128 bits, correspondiente a RSA-3072, AES-128 o AES-256 y SHA-256, es el primer nivel que NIST clasifica como aceptable para uso general sin restricción temporal. Dado que el prototipo gestiona documentos con valor probatorio que pueden requerirse como prueba judicial años después de su firma, la elección del nivel de 128 bits proporciona un margen de seguridad adecuado frente a la evolución del poder computacional. Cabe señalar que la e.firma del SAT utiliza RSA-2048 (112 bits), un nivel inferior al adoptado por el prototipo; la libertad de elegir parámetros que otorga la CA interna permite superar ese piso normativo.

La coherencia entre primitivos se verifica de la siguiente manera: SHA-256 proporciona 128 bits de resistencia a colisiones y 256 bits de resistencia a preimagen; RSA-3072 proporciona aproximadamente 128 bits de fortaleza para firma digital; AES-256 proporciona 256 bits de fortaleza para cifrado simétrico, superando el nivel objetivo pero seleccionado por ser el tamaño estándar de clave para GCM en aplicaciones de nivel 128 bits o superior; y Argon2id con hash de salida de 32 bytes proporciona 256 bits de resistencia a preimagen para el almacenamiento de contraseñas. Ningún

primitivo del sistema presenta una fortaleza inferior a 128 bits, lo que garantiza la ausencia de un eslabón débil en la cadena criptográfica. Esta propiedad de coherencia es especialmente relevante en un sistema que combina múltiples servicios criptográficos —integridad, confidencialidad, no repudio y autenticación—, ya que un atacante racional concentraría su esfuerzo en el primitivo más débil.

3.11.2 Firma Digital

El esquema de firma digital emplea RSA-3072 con SHA-256 y padding PKCS#1 v1.5 (OID sha256WithRSAEncryption). Se descartó ECDSA P-256 tras verificar que la Política de Certificados de la ACR2-SE [42] establece que los certificados emitidos bajo la jerarquía PKI mexicana deben contener claves públicas RSA con sha256WithRSAEncryption como algoritmo de firma; ECDSA no está contemplado para certificados legalmente reconocidos bajo PSC mexicano. La elección de PKCS#1 v1.5 sobre PSS se justifica por la alineación con el esquema que usa la PKI mexicana real (ACR2-SE y e.firma), lo que facilita la migración futura a certificados emitidos por un PSC sin rediseñar el verificador.

Los certificados X.509 v3 de los socios del despacho son emitidos por una Autoridad Certificadora (CA) interna del prototipo, implementada con OpenSSL scriptado en una topología de una sola capa: un certificado raíz autofirmado con vigencia de cinco años firma directamente los certificados de los socios con vigencia de un año. Esta elección expone al equipo al ciclo de vida completo de una PKI —generación de la clave raíz, emisión de CSRs (Certificate Signing Request, solicitudes de firma de certificado), firma de certificados, validación de cadena y revocación— que una integración con la e.firma del SAT o un PSC comercial ocultaría detrás de una API. El módulo de firma acepta cualquier certificado X.509 RSA + SHA-256, de modo que en un despliegue productivo la CA interna podría sustituirse por la e.firma o un PSC autorizado sin modificar la lógica de verificación.

La validación del estado de revocación se realiza mediante una Lista de Certificados Revocados (CRL) conforme a RFC 5280 [44], publicada como archivo PEM en el endpoint GET /pki/crl.pem con vigencia de siete días. La CRL se regenera bajo demanda tras cada revocación y periódicamente antes de su expiración. Se descartó OCSP por la escala reducida del prototipo (~2–5 certificados), donde la CRL es de tamaño despreciable y no requiere un servicio persistente adicional.

La elección de una CA interna sobre la e.firma del SAT o un PSC comercial responde a múltiples consideraciones. En primer lugar, las firmas generadas con certificados de la CA interna son matemáticamente idénticas a las generadas con certificados de la e.firma o de un PSC: mismo algoritmo (RSA-3072 + SHA-256), misma estructura X.509 v3, mismo proceso de verificación. Lo único que cambia es el emisor del certificado. La demostración de los servicios de integridad, autoría y no repudio es, por tanto, completamente válida con esta elección. En segundo lugar, el valor probatorio del flujo de firma se sostiene sobre el sello de tiempo RFC 3161 [27] emitido por Cincel bajo NOM-151 [14], no sobre la cadena de confianza del certificado del firmante; el sello acredita de forma independiente la existencia e integridad del documento en un momento específico, que es el elemento probatorio más difícil de sustituir.

En tercer lugar, usar la e.firma habría obligado a que el socio subiera su archivo .key y su contraseña al prototipo, o a implementar firma del lado del cliente parseando el formato propietario del SAT. Ambas rutas introducen un problema de custodia de claves que contradice el objetivo declarado de no repudio: si el servidor custodia la clave privada del firmante, la firma pierde su propiedad vinculante porque no puede atribuirse exclusivamente a su titular. Con la CA interna, el ciclo de vida de las claves queda bajo control del prototipo y es auditable. Finalmente, montar la CA internamente expone al equipo al ciclo de vida completo de una PKI —generación de la clave raíz, emisión de CSRs, firma de certificados con extensiones X.509 v3, construcción de la cadena de confianza, validación

y revocación— que una integración con la e.firma o un PSC comercial ocultaría detrás de una API externa. Este aprendizaje es parte del valor formativo declarado del Trabajo Terminal.

La implementación de la CA se realiza con OpenSSL scriptado en lugar de herramientas como step-ca o EJBCA. OpenSSL expone cada paso del proceso de forma transparente y auditable: la generación de la clave raíz (openssl genrsa), la creación del certificado autofirmado (openssl req -x509), la firma de solicitudes de certificado (openssl x509 -req -CA) y la generación de CRLs (openssl ca -gencrl) se encapsulan en aproximadamente cuatro invocaciones cuyo resultado es verificable con openssl x509 -text. step-ca automatiza y oculta esa mecánica detrás de una API REST, lo cual es deseable en producción pero contraproducente para un ejercicio académico. Además, OpenSSL no introduce dependencias adicionales al stack del prototipo. Respecto a las vigencias, el certificado raíz tiene una validez de cinco años para sobrevivir ampliamente al ciclo de vida del proyecto y al período de evaluación, mientras que los certificados de los socios tienen una validez de un año, alineada con la práctica estándar de la industria y suficiente para demostrar que el prototipo contempla la renovación de certificados.

3.11.3 Sellado de Tiempo

El sellado de tiempo se delega en Cincel, PSC autorizado por la Secretaría de Economía para la emisión de Sellos Digitales de Tiempo y constancias de conservación conforme a la NOM-151-SCFI-2016 [47]. El flujo opera conforme al protocolo RFC 3161 [27]: se calcula el hash SHA-256 del documento firmado, se envía a la API REST de Cincel [81], y se recibe una respuesta TimeStampResp en formato ASN.1 DER que se almacena como artefacto independiente (.tsr) vinculado al documento en la base de datos. El módulo de sellado abstrae al proveedor detrás de una interfaz interna, permitiendo sustituir Cincel por SeguriData o CECOBAN sin modificar la lógica central, siempre que el proveedor alternativo implemente RFC 3161.

Para facilitar la verificación independiente por un tercero (tribunal, contraparte, perito), el prototipo genera un paquete ZIP descargable que contiene el documento original, la firma RSA del socio, el sello de tiempo .tsr, los certificados del firmante y de la CA raíz, e instrucciones con comandos OpenSSL para la verificación completa. Este diseño garantiza que la verificación no dependa de la disponibilidad de la plataforma.

La selección de Cincel como proveedor de sellado de tiempo obedece a tres factores. Primero, Cincel es un PSC acreditado por la Secretaría de Economía para la emisión de Sellos Digitales de Tiempo (SDT) y constancias de conservación de mensajes de datos (CCMD), con acreditación publicada en el Diario Oficial de la Federación el 24 de noviembre de 2023 [47]. Segundo, Cincel expone un entorno de sandbox sin costo que permite obtener sellos de prueba durante la fase de desarrollo sin contratar un plan comercial, lo que es determinante para el cronograma de diez semanas del prototipo. Tercero, su API REST v3 [81] proporciona una interfaz moderna basada en JSON: se envía el hash SHA-256 del documento en formato hexadecimal y se recibe un enlace al archivo ASN.1 (NOM-151) en formato DER conforme a RFC 3161 [27]. Si el PSC tarda más de 100 milisegundos en generar el sello, Cincel lo procesa de forma asíncrona y recomienda reintentar tras aproximadamente un minuto, lo que el prototipo maneja con un mecanismo de reintento configurable.

El sello de tiempo se almacena como la respuesta cruda TimeStampResp en formato ASN.1 DER (extensión .tsr) en lugar de empaquetarlo en una estructura CAdES-T o embebido en un PDF (PAdES-T). Esta decisión se justifica por tres razones. Primera, con artefactos independientes cada componente del flujo criptográfico —documento, firma, sello, certificado— puede inspeccionarse y verificarse por separado con herramientas estándar; el comando openssl ts -verify opera directamente

sobre archivos .tsr sin necesidad de parsear contenedores CMS ni estructuras PDF. Segunda, CAdES-T requeriría construir estructuras CMS con atributos no firmados y PAdES-T requeriría manipular los mecanismos internos del formato PDF (ByteRange, signature dictionaries, incremental saves), tareas de ingeniería de formatos que consumirían tiempo del cronograma sin aportar al objetivo criptográfico del Trabajo Terminal. Tercera, el valor legal es idéntico independientemente del contenedor: el sello de tiempo que aporta valor probatorio bajo la NOM-151 [14] es el TimeStampToken RFC 3161 emitido por Cincel, y ese token es criptográficamente el mismo ya sea almacenado como .tsr, embebido en CAdES-T o dentro de PAdES-T. La norma no prescribe un formato de contenedor específico.

El flujo de verificación completo del sello de tiempo procede en cuatro pasos: (1) se parsea el TimeStampResp para extraer el TimeStampToken; (2) se verifica que el campo messageImprint.hashedMessage coincida con el hash SHA-256 recalculado del documento original; (3) se verifica la firma de la TSA de Cincel sobre el token; y (4) se verifica el certificado de la TSA contra la cadena de confianza del PSC emisor hasta la ACR2-SE [42]. Con OpenSSL, este proceso completo se ejecuta con un solo comando: `openssl ts -verify -data documento.pdf -in sello.tsr -CAfile cincel_ca.pem`. Un despliegue productivo podría migrar a CAdES-T o PAdES-T para ofrecer un paquete autocontenido más conveniente para el usuario final, sin cambiar el token subyacente ni el flujo de obtención del sello, dado que el TimeStampToken es el mismo objeto ASN.1 en cualquier contenedor.

3.11.4 Cifrado en Reposo

Los documentos almacenados se cifran con AES-256-GCM conforme a NIST SP 800-38D [50]. Cada operación utiliza un nonce (número de uso único) aleatorio de 96 bits generado con un CSPRNG (Generador de Números Pseudoaleatorios Criptográficamente Seguro), cuya probabilidad de colisión es despreciable cuando cada documento emplea su propia clave (NIST SP 800-38D §8.3 establece un límite de 2^{32} invocaciones por clave). La gestión de claves sigue un esquema de envelope encryption: una Clave de Cifrado de Clave (KEK), almacenada en una variable de entorno del servidor, envuelve una Clave de Cifrado de Datos (DEK) generada aleatoriamente para cada documento conforme a NIST SP 800-38F [52]. Esta separación permite rotar la KEK re-cifrando únicamente las DEKs envueltas, sin necesidad de re-cifrar los documentos del repositorio. Los Datos Adicionales Autenticados (AAD) de GCM incluyen el identificador del documento y su versión, lo que previene ataques de intercambio (swap) y de reversión (rollback) entre documentos.

La elección de un nonce aleatorio sobre un nonce de contador responde a la prioridad de evitar el modo de fallo más catastrófico de GCM: la reutilización de un par (clave, nonce). Un nonce de contador requiere mantener un estado persistente que se incremente atómicamente en cada operación de cifrado; si ese estado se reinicia por un error de software, una restauración de respaldo o una condición de carrera, el contador repite un valor y el esquema GCM se rompe irrecuperablemente, exponiendo tanto el texto claro como la clave de autenticación. Un nonce aleatorio de 96 bits generado con un CSPRNG elimina esta dependencia de estado por diseño: cada invocación es independiente y no requiere coordinación con invocaciones anteriores. NIST SP 800-38D [50] §8.3 establece que con nonces aleatorios de 96 bits el número total de invocaciones por clave no debe exceder 2^{32} (aproximadamente 4,300 millones) para mantener la probabilidad de colisión por debajo de $\sim 2^{-33}$. Con envelope encryption, donde cada documento emplea su propia DEK, el número de invocaciones por clave es efectivamente uno, lo que hace la probabilidad de colisión exactamente cero en la práctica.

La arquitectura de envelope encryption se seleccionó sobre dos alternativas: una clave única compartida para todo el repositorio y una derivación de claves mediante HKDF. Una sola clave compartida concentra el riesgo —su compromiso expone la totalidad de la información— y hace la rotación

prohibitivamente costosa porque cada documento debe re-cifrarse. Un esquema basado en HKDF derivaría una clave por documento a partir de una clave maestra y un contexto único (por ejemplo, el identificador del documento), lo que evita almacenar claves envueltas pero presenta dos desventajas: si la clave maestra se compromete, todas las claves derivadas caen sin posibilidad de revocar una sola; y la unicidad absoluta del contexto de derivación reintroduce un problema de estado similar al del nonce de contador. Envelope encryption aísla el daño por diseño: el compromiso de una DEK solo expone un documento, y el compromiso de la KEK requiere además acceso al almacenamiento cifrado para descifrar las DEKs. Este es el patrón estándar de la industria, implementado por AWS KMS, Google Cloud KMS y Azure Key Vault [52].

El flujo de cifrado procede de la siguiente manera al almacenar un documento: (1) se genera una DEK aleatoria de 32 bytes con un CSPRNG; (2) se genera un nonce aleatorio de 12 bytes; (3) se cifra el documento con AES-256-GCM utilizando la DEK, el nonce y los AAD (`document_id + version`), obteniendo el ciphertext y un authentication tag de 16 bytes; (4) se genera un segundo nonce de 12 bytes para la envoltura; y (5) se cifra la DEK con la KEK usando AES-256-GCM. El paquete cifrado del documento se almacena en formato `nonce (12 bytes) || ciphertext || tag (16 bytes)`, y la DEK envuelta sigue el mismo formato. El flujo de descifrado invierte el proceso: primero se descifra la DEK con la KEK verificando la integridad del tag, y después se descifra el documento con la DEK recuperada. Si cualquiera de los dos tags falla la verificación, la operación se rechaza íntegramente, lo que previene la entrega de documentos corrompidos o manipulados.

La rotación de la KEK es una operación ligera que no requiere re-cifrar ningún documento. Al generar una nueva KEK con un CSPRNG, se itera sobre las DEKs del repositorio: cada una se descifra con la KEK vigente y se re-cifra con la nueva. Dado que las DEKs son bloques de 32 bytes, esta operación es de tamaño fijo y se ejecuta en tiempo constante por documento, independientemente del tamaño del documento protegido. Los documentos en sí no se tocan: sus DEKs no cambian, solo cambia su envoltura. Esta separación es la ventaja principal de envelope encryption sobre un esquema de clave única: la rotación opera sobre claves (rápida, de tamaño fijo) y no sobre documentos (potencialmente de varios megabytes). Para el prototipo, basta con implementar y documentar el mecanismo de rotación; ejecutar una rotación periódica queda fuera del alcance de la demostración.

3.11.5 Autenticación y Control de Acceso

Las contraseñas de los usuarios se almacenan hasheadas con Argon2id (RFC 9106) [59], [60], la variante híbrida recomendada por OWASP [61] y NIST SP 800-63B Rev 4 [56] para nuevas implementaciones. Los parámetros adoptados son: memoria $m = 46$ MiB, iteraciones $t = 1$, paralelismo $p = 1$, sal de 16 bytes y hash de salida de 32 bytes, correspondientes a la configuración recomendada de OWASP, calibrada para producir un tiempo de hash de 0.5–1.0 segundo por intento legítimo. Estos parámetros deben verificarse empíricamente en el hardware de despliegue antes de la puesta en producción.

Los clientes del despacho cuentan adicionalmente con autenticación de doble factor mediante TOTP (RFC 6238) [19], [82] con HMAC-SHA1, códigos de 6 dígitos, período de 30 segundos y secreto de 20 bytes, alcanzando el nivel AAL2 de NIST SP 800-63B [56]. Se descartó WebAuthn/FIDO2 (AAL3) por la barrera de adopción que representa para clientes de un despacho legal que requiere solo un smartphone con una app autenticadora estándar. Los socios, por su parte, se autentican mediante certificados digitales X.509 emitidos por la CA interna (sección 3.11.2), lo que provee un nivel de aseguramiento equivalente a AAL3 sin hardware dedicado adicional.

La selección de Argon2id sobre bcrypt se fundamenta en la propiedad de dureza de memoria

(memory-hardness). bcrypt, diseñado en 1999, es resistente a fuerza bruta en CPU gracias a su costo iterativo, pero utiliza únicamente aproximadamente 4 KiB de memoria por invocación, lo que permite a un atacante con GPUs o ASICs ejecutar miles de instancias en paralelo a bajo costo por unidad de intento. Argon2id obliga a reservar decenas de megabytes por cada intento de hash (46 MiB en la configuración adoptada), lo que hace que escalar el ataque con hardware masivo sea prohibitivamente caro porque la memoria DRAM es el recurso que peor escala en paralelo. Argon2 fue el ganador de la Password Hashing Competition (PHC) en julio de 2015 [59], una competencia abierta de dos años con 24 candidatos evaluados por un panel de criptógrafos. Esta validación pública es análoga a la que AES recibió del concurso NIST en 2001 y aporta confianza en que el diseño ha sido ampliamente escrutado.

Argon2 define tres variantes que difieren en su resistencia a distintos vectores de ataque. Argon2d maximiza la resistencia a ataques con GPU y ASIC, pero es vulnerable a ataques de canal lateral si el atacante puede observar los patrones de acceso a memoria del proceso. Argon2i es resistente a ataques de canal lateral al usar un patrón de acceso independiente de los datos, pero ofrece ligeramente menos resistencia a hardware especializado. Argon2id es la variante híbrida: ejecuta Argon2i en el primer pase para proteger contra canal lateral, y Argon2d en los pases subsiguientes para maximizar la resistencia a GPU. RFC 9106 [60] §4 recomienda explícitamente Argon2id para hashing de contraseñas por esta combinación de protecciones. Los parámetros adoptados ($m = 46$ MiB, $t = 1$, $p = 1$, sal de 16 bytes, hash de 32 bytes) corresponden a la configuración recomendada de OWASP [61], que a su vez se basa en las configuraciones de referencia de RFC 9106. La sal de 128 bits excede el mínimo de 64 bits de RFC 9106 y es el valor recomendado por OWASP.

La selección de HMAC-SHA1 como función base del TOTP merece una justificación explícita dado que SHA-1 está desaconsejado para firmas digitales desde 2017 por la demostración práctica de colisiones. Sin embargo, la seguridad de HMAC no depende de la resistencia a colisiones de la función hash subyacente, sino de la pseudoaleatoriedad de su función de compresión interna. NIST SP 800-107 Rev 1 [57] confirma que HMAC-SHA-1 sigue siendo aceptable para autenticación de mensajes y generación de códigos. Adicionalmente, HMAC-SHA1 es el único algoritmo soportado universalmente por todas las aplicaciones autenticadoras del mercado; Google Authenticator históricamente solo soporta SHA-1, lo que haría que la adopción de HMAC-SHA256 o HMAC-SHA512 excluyera a una parte significativa de los dispositivos de los clientes del despacho.

El flujo de registro (enrollment) del segundo factor procede de la siguiente manera: (1) el cliente inicia sesión con usuario y contraseña; (2) el sistema genera un secreto de 20 bytes con un CSPRNG; (3) se codifica como URI otpauth (otpauth://totp/Despacho:cliente@email?secret=BASE32(secret)) y se presenta como código QR; (4) el cliente escanea con su aplicación autenticadora; (5) el cliente ingresa el código actual para confirmar la configuración; y (6) el sistema almacena el secreto cifrado con AES-256-GCM y genera ocho códigos de recuperación de un solo uso, hashados con Argon2id antes de almacenarse. Durante la autenticación, el sistema calcula el TOTP esperado para tres ventanas temporales (t_{0-1} , t_0 , t_{0+1}), lo que tolera un desfase de reloj de hasta 30 segundos entre servidor y dispositivo. Se aplica rate limiting de cinco intentos fallidos consecutivos con bloqueo temporal de 15 minutos para prevenir fuerza bruta en línea sobre el espacio de 10^6 combinaciones (6 dígitos).

3.11.6 Postura Legal del Prototipo

La firma generada por el prototipo constituye una firma electrónica simple conforme al artículo 89 del Código de Comercio [13], dado que los certificados no provienen de un PSC autorizado (artículo 97, requisito 5). No obstante, su valor probatorio se sustenta en tres pilares: (1) la admisibilidad de la firma

simple como prueba, ya que el artículo 89 no condiciona la admisibilidad a la intervención de un PSC; (2) la cláusula de equivalencia funcional del artículo 100, que permite argumentar la fiabilidad del método basándose en la robustez de estándares reconocidos internacionalmente (RSA-3072 conforme a NIST SP 800-57 [37], SHA-256 conforme a FIPS 180-4 [25]); y (3) el sello de tiempo NOM-151 de Cincel, que proporciona fecha cierta, integridad verificada por un tercero de confianza autorizado y cumplimiento del artículo 93 bis. La distinción práctica respecto de una firma avanzada radica en la carga de la prueba: quien invoca la firma simple debe acreditar la fiabilidad del método, mientras que la firma avanzada goza de presunción legal. En un despliegue productivo, la sustitución de la CA interna por un PSC autorizado convertiría la firma en avanzada sin cambios arquitectónicos, dado que el módulo de firma acepta cualquier certificado X.509 RSA + SHA-256.

La arquitectura del prototipo está diseñada para que la transición de firma simple a firma avanzada sea una operación de configuración, no de rediseño. El módulo de firma define una interfaz abstracta que acepta cualquier certificado X.509 con clave RSA y algoritmo sha256WithRSAEncryption. En un despliegue productivo, el despacho podría sustituir la CA interna por certificados emitidos por un PSC autorizado como SeguriData [45] o CECOBAN [46], convirtiendo la firma en avanzada conforme al artículo 97 del Código de Comercio [13]; o bien integrar la e.firma del SAT si los socios ya disponen de ella, sin modificar la lógica de verificación. De forma análoga, el módulo de sellado de tiempo define una interfaz abstracta que permite sustituir Cincel por cualquier TSA que implemente RFC 3161 [27]. Esta portabilidad del emisor es un acierto arquitectónico deliberado: el prototipo demuestra la corrección de los mecanismos criptográficos con una infraestructura soberana del despacho, mientras que la producción puede adoptar la infraestructura regulada sin tocar el código de verificación.

CAPÍTULO 4

Conclusiones y trabajo futuro

4.1 Resultados obtenidos

El presente Trabajo Terminal diseñó la arquitectura de un sistema de gestión de expedientes penales para despachos jurídicos mexicanos, integrando seis servicios criptográficos fundamentales: integridad de documentos mediante SHA-256 [25], confidencialidad en reposo mediante AES-256-GCM [50] con envelope encryption [52], no repudio mediante firma digital RSA-3072 con SHA-256 y certificados X.509 emitidos por una CA interna, sellado de tiempo conforme a RFC 3161 [27] a través de Cincel como PSC autorizado bajo la NOM-151-SCFI-2016 [14], autenticación robusta mediante Argon2id [60] para hashing de contraseñas y TOTP [19] como segundo factor, y revocación de certificados mediante CRL conforme a RFC 5280 [44].

El diseño se fundamentó en un análisis riguroso del marco legal mexicano aplicable a las transacciones entre particulares: el Código de Comercio [13] (artículos 89, 89 bis, 93, 93 bis, 97 y 100), el Código Federal de Procedimientos Civiles [38] (artículo 210-A), el Código Nacional de Procedimientos Penales [1] (artículos 356 y 380) y la NOM-151-SCFI-2016. Este análisis permitió establecer que la firma electrónica simple, respaldada por un sello de tiempo de un PSC autorizado, constituye una estrategia probatoria válida y defendible en sede judicial, conforme a la cláusula de equivalencia funcional del artículo 100 del Código de Comercio.

La arquitectura hexagonal adoptada separa explícitamente el dominio de negocio de las dependencias externas mediante puertos e interfaces abstractas. Esta separación se manifiesta en dos decisiones de diseño clave: el módulo de firma acepta cualquier certificado X.509 RSA + SHA-256, independientemente de su emisor; y el módulo de sellado de tiempo opera contra cualquier proveedor que implemente RFC 3161. Ambas decisiones permiten sustituir la infraestructura criptográfica del prototipo (CA interna, Cincel) por infraestructura regulada (e.firma del SAT, PSC comercial) sin modificar la lógica de verificación.

4.2 Contribuciones

La contribución principal de este trabajo es el diseño de un puente documentado entre la teoría criptográfica contemporánea (NIST SP 800-57 [37], RFC 9106 [60], RFC 6238 [19]) y los requisitos específicos del marco legal mexicano para documentos electrónicos con valor probatorio. Cada decisión de diseño criptográfico se justificó con referencia tanto a los estándares internacionales que la sustentan como a los artículos del Código de Comercio y el CNPP que determinan su admisibilidad en sede judicial.

Como contribución adicional, el trabajo establece que la distinción entre firma electrónica simple y avanzada en el derecho mexicano no es de admisibilidad —ambas son admisibles conforme al artículo 89 del Código de Comercio— sino de carga de la prueba. Esta precisión, documentada con

referencia a los artículos 97 y 100, permite argumentar que un prototipo académico con CA interna genera evidencia criptográfica válida sin necesidad de contratar un PSC para la emisión de certificados de firmante, siempre que el sello de tiempo provenga de un PSC autorizado.

4.3 Limitaciones

El presente trabajo presenta las siguientes limitaciones que deben considerarse al interpretar sus resultados. En primer lugar, el prototipo opera bajo una arquitectura de inquilino único (single-tenant): cada instancia sirve a un solo despacho. Un despliegue comercial requeriría una arquitectura multi-tenant con aislamiento de datos entre despachos, lo que introduce complejidad adicional en la gestión de claves y el control de acceso. En segundo lugar, la CA interna del prototipo emite certificados que constituyen firma electrónica simple, no avanzada; aunque esto es suficiente para la demostración académica, un despliegue productivo debería evaluar la migración a certificados emitidos por un PSC autorizado para obtener la presunción legal del artículo 97.

En tercer lugar, la confirmación empírica del algoritmo de firma de la TSA de Cincel queda pendiente: se presume sha256WithRSAEncryption por coherencia con la PKI mexicana, pero debe verificarse parseando un sello del sandbox con OpenSSL. En cuarto lugar, los parámetros de Argon2id ($m = 46$ MiB, $t = 1$, $p = 1$) corresponden a la configuración recomendada de OWASP [61] pero deben calibrarse empíricamente en el hardware de despliegue para confirmar que el tiempo de hash se mantiene entre 0.5 y 1.0 segundo. Finalmente, la CRL del prototipo tiene una vigencia de siete días, lo que introduce una ventana teórica de exposición entre la revocación de un certificado y su detección por los verificadores; en un entorno productivo, esta ventana podría reducirse complementando la CRL con un responder OCSP.

4.4 Trabajo futuro

Las líneas de trabajo futuro derivadas del presente diseño se organizan en tres horizontes. En el corto plazo, correspondiente a la fase de implementación del prototipo: (1) codificar los módulos criptográficos en Rust utilizando las bibliotecas ring, x509-cert y argon2 identificadas en el stack tecnológico; (2) obtener un sello de prueba del sandbox de Cincel y parsear el TimeStampToken con OpenSSL para confirmar el algoritmo de firma de la TSA; (3) implementar la suite de pruebas unitarias y de integración para los flujos de firma, cifrado, sellado de tiempo y verificación; y (4) calibrar empíricamente los parámetros de Argon2id en el hardware de despliegue.

En el mediano plazo, orientado a fortalecer la postura de seguridad del sistema: (1) integrar un módulo de seguridad de hardware (HSM) o un servicio de gestión de claves en la nube (KMS) para el almacenamiento de la KEK, eliminando la dependencia de variables de entorno; (2) implementar un responder OCSP que complemente la CRL para reducir la ventana de exposición ante revocaciones; (3) evaluar la migración del formato de sello de tiempo de .tsr independiente a CAdES-T o PAdES-T para ofrecer paquetes de verificación autocontenidos; y (4) incorporar WebAuthn/FIDO2 como opción progresiva de MFA para clientes con dispositivos compatibles, alcanzando el nivel AAL3 de NIST SP 800-63B [56].

En el largo plazo, orientado a la viabilidad comercial: (1) rediseñar la arquitectura para soportar múltiples inquilinos (multi-tenant) con aislamiento criptográfico por despacho, donde cada tenant disponga de su propia KEK y su propio espacio de certificados; (2) migrar los certificados de firmante

de la CA interna a un PSC autorizado para convertir la firma en avanzada conforme al artículo 97 del Código de Comercio [13], beneficiándose de la portabilidad arquitectónica diseñada desde el inicio; y (3) incorporar mecanismos de auditoría a nivel de sistema operativo y bitacorización inmutable (append-only) con firmas periódicas de la bitácora para fortalecer la cadena de custodia digital ante instancias judiciales.

Referencias

- [1] Cámara de Diputados del H. Congreso de la Unión. «Código Nacional de Procedimientos Penales.» Texto Vigente, Última Reforma DOF 19-02-2021. (2021), dirección: <https://www.diputados.gob.mx/LeyesBiblio/pdf/CNPP.pdf>.
- [2] Justia México. «Nuevo Sistema de Justicia Penal,» Justia México Derecho Penal. (2024), dirección: <https://mexico.justia.com/derecho-penal/nuevo-sistema-de-justicia-penal/>.
- [3] Consejo de la Judicatura Federal. «Acuerdo General del Pleno del Consejo de la Judicatura Federal que regula la integración y trámite de expediente electrónico y el uso de videoconferencias,» Suprema Corte de Justicia de la Nación. (2020), dirección: https://www.scjn.gob.mx/sites/default/files/normativa/electronico/documentos/143196_5.pdf.
- [4] Poder Judicial de la Ciudad de México. «Expedientes Digitales con Total Legalidad,» PJCDMX. (2023), dirección: https://www.poderjudicialcdmx.gob.mx/expedientes_digitales_legalidad/.
- [5] «Humanismo: Cero papel en el Poder Judicial del Estado de México,» Heraldo del Estado de México. (mar. de 2026), dirección: <https://hgrupoeditorial.com/humanismo-25/>.
- [6] A. Bello-Hernández, «Hacia una teoría sobre la e-justice o justicia digital: instrucciones para armar,» *Cuestiones Constitucionales: Revista Mexicana de Derecho Constitucional*, n.º 46, págs. 177-214, 2022. dirección: https://www.scielo.org.mx/scielo.php?script=sci_arttext&pid=S1405-91932022000100177.
- [7] ESET Latinoamérica. «ESET Security Report 2025: El estado de la ciberseguridad en empresas de Latinoamérica,» ESET. (2025), dirección: <https://www.welivesecurity.com/es/informes/eset-security-report-2025-ciberseguridad-empresas-latinoamerica/>.
- [8] ESET Latinoamérica. «Las amenazas más detectadas en Latinoamérica en el primer semestre 2024,» ESET. (2024), dirección: <https://www.eset.com/py/acerca-de-eset/sala-de-prensa/comunicados-de-prensa/articulos-de-prensa/las-amenazas-mas-detectadas-en-latinoamerica-en-el-primer-semestre-2024/>.
- [9] LexLatin. «Ciberseguridad: ¿Cómo las firmas legales protegen los datos de sus clientes en la era de las legaltech?» LexLatin. (2023), dirección: <https://lexlatin.com/reportajes/ciberseguridad-firmas-protegen-datos-clientes-legaltech>.
- [10] American Bar Association. «2023 Cybersecurity TechReport,» ABA Legal Technology Resource Center. (2023), dirección: https://www.americanbar.org/groups/law_practice/resources/tech-report/2023/2023-cybersecurity-techreport/.
- [11] IBM Security. «Cost of a Data Breach Report 2024,» IBM. (2024), dirección: <https://www.clcio.com/blog/data-breach-lawyers/>.

- [12] Enthec. «Ciberseguridad en despachos de abogados,» Enthec. (2025), dirección: <https://enthec.com/ciberseguridad-despachos-abogados/>.
- [13] Cámara de Diputados del H. Congreso de la Unión. «Código de Comercio.» Texto Vigente, Última Reforma DOF 28-03-2018. (2018), dirección: <https://www.diputados.gob.mx/LeyesBiblio/pdf/CCom.pdf>.
- [14] Secretaría de Economía. «NOM-151-SCFI-2016, Requisitos que deben observarse para la conservación de mensajes de datos y digitalización de documentos,» Diario Oficial de la Federación. (2016), dirección: https://www.dof.gob.mx/normasOficiales/6499/seecoll_C/seecoll_C.html (visitado 15-09-2025).
- [15] Mifiel. «Prueba electrónica en México: el valor probatorio del mensaje de datos,» Blog Mifiel. (sep. de 2025), dirección: <https://blog.mifiel.com/prueba-electronica/>.
- [16] UBT Compliance. «Cómo documentar una prueba digital y su cadena de custodia,» UBT Compliance. (jul. de 2025), dirección: <https://ubtcompliance.com/blog/cadena-de-custodia-prueba-digital/>.
- [17] Poder Judicial de la Federación. «Guía para la valoración judicial de la prueba pericial en materia de análisis de video digital,» Órgano de Administración Judicial, México. (), dirección: https://www.oaj.gob.mx/PJD/PJD_resources/guias/lib/P01008.pdf.
- [18] Cámara de Diputados del H. Congreso de la Unión. «Ley Federal de Protección de Datos Personales en Posesión de los Particulares.» Texto Vigente, Última Reforma DOF 25-06-2018. (2018), dirección: <https://www.diputados.gob.mx/LeyesBiblio/pdf/LFPDPPP.pdf>.
- [19] D. M'Raihi, S. Machani, M. Pei y J. Rydell, «TOTP: Time-Based One-Time Password Algorithm,» Internet Engineering Task Force, RFC 6238, mayo de 2011. dirección: <https://www.rfc-editor.org/rfc/rfc6238>.
- [20] International Organization for Standardization. «ISO/IEC 27001:2022, Information security, cybersecurity and privacy protection — Information security management systems — Requirements,» ISO/IEC. (2022), dirección: <https://www.iso.org/standard/27001> (visitado 15-09-2025).
- [21] Themis Solutions Inc. «Clio: Legal Practice Management Software,» Clio. (2025), dirección: <https://www.clio.com/> (visitado 22-09-2025).
- [22] 8am. «Legal Case Management Software and Solutions,» MyCase. (2025), dirección: <https://www.mycase.com/> (visitado 17-09-2025).
- [23] PracticePanther. «Law Practice Management Software,» PracticePanther. (2025), dirección: <https://www.practicepanther.com> (visitado 17-09-2025).
- [24] C. Paar y J. Pelzl, *Understanding Cryptography: A Textbook for Students and Practitioners*. Berlin, Heidelberg: Springer-Verlag, 2010. dirección: <https://link.springer.com/book/10.1007/978-3-642-04101-3>.
- [25] National Institute of Standards and Technology, «Secure Hash Standard (SHS),» National Institute of Standards y Technology, inf. téc. NIST FIPS 180-4, ago. de 2015. doi: [10.6028/NIST.FIPS.180-4](https://doi.org/10.6028/NIST.FIPS.180-4).
- [26] National Institute of Standards and Technology, «Advanced Encryption Standard (AES),» National Institute of Standards y Technology, inf. téc. NIST FIPS 197, nov. de 2001, Updated May 2023. doi: [10.6028/NIST.FIPS.197-upd1](https://doi.org/10.6028/NIST.FIPS.197-upd1).

- [27] C. Adams, P. Cain, D. Pinkas y R. Zuccherato, «Internet X.509 Public Key Infrastructure Time-Stamp Protocol (TSP),» Internet Engineering Task Force, RFC 3161, ago. de 2001. dirección: <https://www.rfc-editor.org/rfc/rfc3161>.
- [28] W. Stallings, *Cryptography and Network Security: Principles and Practice*, 7.^a ed. Upper Saddle River, NJ, USA: Pearson, 2017.
- [29] Archivo General del Estado de Puebla. «La evolución del Sistema Penal Acusatorio,» Artículos de Investigación. (2020), dirección: https://archivogeneraldelestado.puebla.gob.mx/articulos-de-investigacion/item/download/4_b2f24cd4244c77bfbe5c964ab5545.
- [30] Instituto de Estudios Judiciales de la CDMX. «Unidades de Gestión Judicial en el Sistema Acusatorio,» IEJ CDMX. (2018), dirección: <https://www.iejcdmx.gob.mx/wp-content/uploads/UGAS070518.pdf>.
- [31] La Salle Bajío, «El sistema acusatorio penal mexicano,» *De La Salle, Revista de Derecho*, n.º 13, 2015. dirección: https://www.lasallebajio.edu.mx/delasalle/contenidos/revistas/derecho/numero_13/maestros_elsistema.html.
- [32] Órgano de Administración Judicial. «La e-Justicia en el Consejo de la Judicatura Federal,» OAJ. (2023), dirección: <https://apps.cjf.gob.mx/dgetd/assets/PDF/ebook.pdf>.
- [33] M. A. García Ramírez, «Etapas de Investigación en el CNPP,» en *Código Nacional de Procedimientos Penales Comentado*, UNAM, 2015, cap. 5. dirección: <https://archivos.juridicas.unam.mx/www/bjv/libros/11/5262/5.pdf>.
- [34] Poder Judicial del Estado de Guanajuato. «Los sujetos procesales en el juicio oral penal,» PJ Guanajuato. (2015), dirección: <https://www.poderjudicial-gto.gob.mx/pdfs/2encuentro/LIC.%20MYRNA%20EDITH%20HIGAREDA%20LORENZO.pdf>.
- [35] Gobierno de México. «¿Quiénes son los actores del nuevo Sistema de Justicia Penal?» gob.mx. (2022), dirección: <https://www.gob.mx/justiciapenal/articulos/quienes-son-los-actores-del-nuevo-sistema-de-justiciapenal>.
- [36] Órgano de Administración Judicial. «Guía de apoyo para el estudio del Código Nacional de Procedimientos Penales,» OAJ. (2023), dirección: <https://www.oaj.gob.mx/documentos/guiacnpp.pdf>.
- [37] E. Barker, «Recommendation for Key Management: Part 1 – General,» National Institute of Standards y Technology, NIST Special Publication 800-57 Part 1, Rev. 5, mayo de 2020. doi: 10.6028/NIST.SP.800-57pt1r5. dirección: <https://doi.org/10.6028/NIST.SP.800-57pt1r5>.
- [38] Cámara de Diputados del H. Congreso de la Unión. «Código Federal de Procedimientos Civiles.» Texto Vigente, Última Reforma DOF 07-06-2023, Diario Oficial de la Federación. (2023), dirección: <https://www.diputados.gob.mx/LeyesBiblio/pdf/CFPC.pdf>.
- [39] Cámara de Diputados del H. Congreso de la Unión. «Ley de Firma Electrónica Avanzada.» Texto Vigente, DOF 11-01-2012, Diario Oficial de la Federación. (2012), dirección: <https://www.diputados.gob.mx/LeyesBiblio/pdf/LFEA.pdf>.
- [40] Secretaría de Economía. «Directorio de Prestadores de Servicios de Certificación,» psc.economia.gob.mx. (2026), dirección: <https://psc.economia.gob.mx/directorio.html>.

- [41] Mifiel. «API para constancias de conservación NOM-151,» Blog Mifiel. (2024), dirección: <https://blog.mifiel.com/api-nom-151-constancias-conservacion/>.
- [42] Secretaría de Economía. «Política de Certificados de la Autoridad Certificadora Raíz Segunda de la Secretaría de Economía (ACR2-SE),» Secretaría de Economía. (), dirección: https://psc.economia.gob.mx/docs_l/Politica_de_Certificados.pdf.
- [43] Cámara de Diputados del H. Congreso de la Unión. «Reglamento del Código de Comercio en Materia de Prestadores de Servicios de Certificación.» Texto Vigente, Diario Oficial de la Federación. (), dirección: https://www.diputados.gob.mx/LeyesBiblio/regley/Reg_CCom_MPSC.pdf.
- [44] D. Cooper, S. Santesson, S. Farrell, S. Boeyen, R. Housley y W. Polk, «Internet X.509 Public Key Infrastructure Certificate and Certificate Revocation List (CRL) Profile,» Internet Engineering Task Force, RFC 5280, mayo de 2008. dirección: <https://www.rfc-editor.org/rfc/rfc5280>.
- [45] SeguriData. «Política de Certificados para Infraestructura de Clave Pública,» SeguriData PSC. (), dirección: <https://psc.seguridata.com/docs/doc06.pdf>.
- [46] CECOBAN. «Política de Certificación de la Agencia Certificadora,» CECOBAN S.A. de C.V. (), dirección: <https://www.cecoban.org.mx/AgenciaSE/Soporte/Politicasy20de%20Certificacion.pdf>.
- [47] comparasoftware.com. «Cinel: Acreditado como el Primer Prestador de Servicios de Certificación nativo en la nube.» (2026), dirección: <https://www.comparasoftware.com/cinel>.
- [48] A. J. Menezes, P. C. van Oorschot y S. A. Vanstone, *Handbook of Applied Cryptography*. Boca Raton, FL, USA: CRC Press, 1996. dirección: <https://cacr.uwaterloo.ca/hac/>.
- [49] M. Dworkin, «Recommendation for Block Cipher Modes of Operation: Methods and Techniques,» National Institute of Standards y Technology, NIST Special Publication 800-38A, dic. de 2001. doi: [10.6028/NIST.SP.800-38A](https://doi.org/10.6028/NIST.SP.800-38A). dirección: <https://doi.org/10.6028/NIST.SP.800-38A>.
- [50] M. Dworkin, «Recommendation for Block Cipher Modes of Operation: Galois/Counter Mode (GCM) and GMAC,» National Institute of Standards y Technology, NIST Special Publication 800-38D, nov. de 2007. dirección: <https://nvlpubs.nist.gov/nistpubs/legacy/sp/nistspecialpublication800-38d.pdf>.
- [51] D. McGrew, «An Interface and Algorithms for Authenticated Encryption,» Internet Engineering Task Force, RFC 5116, ene. de 2008. dirección: <https://www.rfc-editor.org/rfc/rfc5116>.
- [52] M. Dworkin, «Recommendation for Block Cipher Modes of Operation: Methods for Key Wrapping,» National Institute of Standards y Technology, NIST Special Publication 800-38F, dic. de 2012. doi: [10.6028/NIST.SP.800-38F](https://doi.org/10.6028/NIST.SP.800-38F). dirección: <https://doi.org/10.6028/NIST.SP.800-38F>.
- [53] National Institute of Standards and Technology, «Digital Signature Standard (DSS),» National Institute of Standards y Technology, NIST FIPS 186-5, feb. de 2023. doi: [10.6028/NIST.FIPS.186-5](https://doi.org/10.6028/NIST.FIPS.186-5). dirección: <https://doi.org/10.6028/NIST.FIPS.186-5>.

- [54] International Telecommunication Union. «Information technology – Open Systems Interconnection – The Directory: Public-key and attribute certificate frameworks,» ITU-T Rec. X.509. (oct. de 2019), dirección: <https://www.itu.int/rec/T-REC-X.509-201910-I>.
- [55] National Institute of Standards and Technology, «Digital Identity Guidelines: Authentication and Lifecycle Management,» National Institute of Standards y Technology, NIST Special Publication 800-63B, jun. de 2017. dirección: <https://pages.nist.gov/800-63-3/sp800-63b.html>.
- [56] National Institute of Standards and Technology, «Digital Identity Guidelines: Authentication and Lifecycle Management,» National Institute of Standards and Technology, NIST Special Publication 800-63B Rev. 4, ago. de 2024. dirección: <https://pages.nist.gov/800-63-4/sp800-63b.html>.
- [57] Q. Dang, «Recommendation for Applications Using Approved Hash Algorithms,» National Institute of Standards and Technology, NIST Special Publication 800-107 Rev. 1, ago. de 2012. doi: [10.6028/NIST.SP.800-107r1](https://doi.org/10.6028/NIST.SP.800-107r1).
- [58] D. M'Raihi, M. Bellare, F. Hoornaert, D. Naccache y O. Ranen, «HOTP: An HMAC-Based One-Time Password Algorithm,» Internet Engineering Task Force, RFC 4226, dic. de 2005. dirección: <https://www.rfc-editor.org/rfc/rfc4226>.
- [59] A. Biryukov, D. Dinu y D. Khovratovich. «Argon2: the memory-hard function for password hashing and other applications.» Password Hashing Competition winner. (2015), dirección: <https://www.password-hashing.net/>.
- [60] A. Biryukov, D. Dinu, D. Khovratovich y S. Josefsson, «Argon2 Memory-Hard Function for Password Hashing and Proof-of-Work Applications,» Internet Research Task Force, RFC 9106, sep. de 2021. dirección: <https://www.rfc-editor.org/rfc/rfc9106>.
- [61] OWASP Foundation. «Password Storage Cheat Sheet,» OWASP Cheat Sheet Series. (2024), dirección: https://cheatsheetseries.owasp.org/cheatsheets/Password_Storage_Cheat_Sheet.html.
- [62] National Institute of Standards and Technology, «Security and Privacy Controls for Information Systems and Organizations,» National Institute of Standards y Technology, inf. téc. NIST Special Publication 800-53, Rev. 5, 2020. dirección: <https://csrc.nist.gov/publications/detail/sp/800-53/rev-5/final> (visitado 19-09-2025).
- [63] K. Beck y C. Andres, *Extreme Programming Explained: Embrace Change*, 2.^a ed. Boston, MA, USA: Addison-Wesley, 2004.
- [64] S. Brown, *The C4 Model for Visualising Software Architecture: Definitions, notation and examples*. Leanpub, 2024. dirección: <https://c4model.com>.
- [65] P. Kruchten, «The 4+1 View Model of Architecture,» *IEEE Software*, vol. 12, n.º 6, págs. 42-50, nov. de 1995. doi: [10.1109/52.469759](https://doi.org/10.1109/52.469759).
- [66] M. Nygard. «Documenting Architecture Decisions,» cognitect.com. (nov. de 2011), dirección: <https://cognitect.com/blog/2011/11/15/documenting-architecture-decisions>.

- [67] International Organization for Standardization. «ISO/IEC 25010:2011, Systems and software engineering — Systems and software Quality Requirements and Evaluation (SQuaRE) — System and software quality models,» ISO/IEC. (2011), dirección: <https://www.iso.org/standard/35733.html>.
- [68] N. Ford, R. Parsons y P. Kua, *Building Evolutionary Architectures: Automated Software Governance*, 2.^a ed. Sebastopol, CA, USA: O'Reilly Media, 2023.
- [69] R. C. Martin, *Clean Architecture: A Craftsman's Guide to Software Structure and Design*. Upper Saddle River, NJ, USA: Prentice Hall, 2017.
- [70] A. Cockburn. «Hexagonal Architecture.» (2005), dirección: <https://alistair.cockburn.us/hexagonal-architecture/>.
- [71] S. Newman, *Building Microservices: Designing Fine-Grained Systems*, 2.^a ed. Sebastopol, CA, USA: O'Reilly Media, 2021.
- [72] M. Fowler. «MonolithFirst.» (2015), dirección: <https://martinfowler.com/bliki/MonolithFirst.html>.
- [73] V. Vernon, *Implementing Domain-Driven Design*. Upper Saddle River, NJ, USA: Addison-Wesley Professional, 2013.
- [74] E. Evans, *Domain-Driven Design: Tackling Complexity in the Heart of Software*. Boston, MA, USA: Addison-Wesley Professional, 2003.
- [75] S. Klabnik y C. Nichols, *The Rust Programming Language*, 2.^a ed. San Francisco, CA, USA: No Starch Press, 2023. dirección: <https://doc.rust-lang.org/book/>.
- [76] Microsoft Security Response Center. «A proactive approach to more secure code.» (2019), dirección: <https://msrc.microsoft.com/blog/2019/07/a-proactive-approach-to-more-secure-code/>.
- [77] K. Sylor-Miller y J. Miller. «Islands Architecture.» (2019), dirección: <https://jasonformat.com/islands-architecture/>.
- [78] J. H. Saltzer y M. D. Schroeder, «The Protection of Information in Computer Systems,» *Proceedings of the IEEE*, vol. 63, n.º 9, págs. 1278-1308, 1975. doi: [10.1109/PROC.1975.9939](https://doi.org/10.1109/PROC.1975.9939).
- [79] OWASP Foundation. «Application Security Verification Standard (ASVS) v4.0.3,» OWASP. (2021), dirección: <https://owasp.org/www-project-application-security-verification-standard/>.
- [80] A. Shostack, *Threat Modeling: Designing for Security*. Indianapolis, IN, USA: Wiley, 2014.
- [81] Cincel. «Documentación API v3: Timestamps NOM-151,» Cincel Certificadora Digital. (2024), dirección: <https://docs.cincel.digital/v3/timestamps/nom151/>.
- [82] OWASP Foundation. «Multifactor Authentication Cheat Sheet,» OWASP Cheat Sheet Series. (2024), dirección: https://cheatsheetseries.owasp.org/cheatsheets/Multifactor_Authentication_Cheat_Sheet.html.

Glosario de Términos

- AAD** Additional Authenticated Data (Datos Adicionales Autenticados). Información que no se cifra pero cuya integridad se protege mediante la etiqueta de autenticación del cifrado autenticado GCM.
- AAL** Authentication Assurance Level (Nivel de Aseguramiento de Autenticación). Clasificación del NIST SP 800-63B que define tres niveles de confianza en la autenticación: AAL1 (factor único), AAL2 (dos factores) y AAL3 (dos factores con hardware criptográfico).
- ACR2-SE** Autoridad Certificadora Raíz Segunda de la Secretaría de Economía. Raíz de la jerarquía PKI mexicana bajo la cual operan los PSC autorizados.
- AEAD** Authenticated Encryption with Associated Data (Cifrado Autenticado con Datos Asociados). Esquema criptográfico que provee simultáneamente confidencialidad, integridad y autenticación del mensaje. AES-GCM es una instancia de AEAD.
- AES** Advanced Encryption Standard (Estándar de Cifrado Avanzado). Algoritmo de cifrado simétrico por bloques estandarizado en FIPS 197. AES-256 utiliza claves de 256 bits.
- API** Application Programming Interface (Interfaz de Programación de Aplicaciones). Conjunto de definiciones y protocolos que permite la comunicación entre componentes de software.
- Argon2id** Variante híbrida de la función de hashing de contraseñas Argon2, ganadora de la Password Hashing Competition (2015) y estandarizada en RFC 9106. Combina resistencia a ataques de canal lateral (Argon2i) con resistencia a hardware especializado (Argon2d).
- ASIC** Application-Specific Integrated Circuit (Circuito Integrado de Aplicación Específica). Hardware diseñado para ejecutar una tarea específica, utilizado en ataques de fuerza bruta contra funciones hash.
- ASN.1** Abstract Syntax Notation One (Notación de Sintaxis Abstracta Uno). Estándar internacional para definir estructuras de datos criptográficas, utilizado en certificados X.509 y sellos de tiempo RFC 3161.
- backend** Capa lógica del servidor que procesa la lógica de negocio, el acceso a datos y los servicios criptográficos, en contraposición al frontend que interactúa con el usuario.
- bcrypt** Función de hashing de contraseñas diseñada en 1999, basada en el cifrador Blowfish. Incorpora un factor de costo ajustable pero carece de dureza de memoria configurable.
- CA** Certificate Authority (Autoridad Certificadora). Entidad de confianza responsable de emitir, renovar y revocar certificados digitales dentro de una infraestructura de clave pública (PKI).
- CAdES-T** CMS Advanced Electronic Signatures with Timestamp. Formato de firma electrónica avanzada que incorpora un sello de tiempo dentro de una estructura CMS (Cryptographic Message Syntax).

- CRL** Certificate Revocation List (Lista de Certificados Revocados). Documento firmado por una CA que enumera los certificados revocados antes de su fecha de expiración, conforme a RFC 5280.
- CSPRNG** Cryptographically Secure Pseudo-Random Number Generator (Generador de Números Pseudoaleatorios Criptográficamente Seguro). Generador cuya salida es computacionalmente indistinguible de datos aleatorios verdaderos.
- CSR** Certificate Signing Request (Solicitud de Firma de Certificado). Mensaje enviado a una CA para solicitar la emisión de un certificado digital, conteniendo la clave pública del solicitante.
- DEK** Data Encryption Key (Clave de Cifrado de Datos). En un esquema de envelope encryption, clave simétrica generada aleatoriamente para cifrar un documento individual.
- DER** Distinguished Encoding Rules. Reglas de codificación binaria para estructuras ASN.1, utilizadas en certificados X.509 y sellos de tiempo.
- DOF** Diario Oficial de la Federación. Órgano del Gobierno de México para la publicación de leyes, reglamentos y acuerdos oficiales.
- e.firma** Certificado de firma electrónica avanzada emitido por el Servicio de Administración Tributaria (SAT) para personas físicas y morales en México. Utiliza RSA-2048 con SHA-256.
- ECDSA** Elliptic Curve Digital Signature Algorithm (Algoritmo de Firma Digital de Curva Elíptica). Esquema de firma basado en la dificultad del logaritmo discreto sobre curvas elípticas.
- endpoint** Punto de acceso de una API, identificado por una URL y un método HTTP (por ejemplo, GET /pki/crl.pem).
- envelope encryption** Cifrado de envoltorio. Esquema de gestión de claves donde una clave maestra (KEK) cifra claves de datos individuales (DEK), cada una asociada a un documento específico.
- FIPS** Federal Information Processing Standards (Estándares Federales de Procesamiento de Información). Conjunto de estándares del gobierno de Estados Unidos para sistemas informáticos. FIPS 180-4 define SHA-256; FIPS 197 define AES.
- framework** Marco de trabajo o plataforma de desarrollo que proporciona una estructura predefinida para construir aplicaciones de software.
- GCM** Galois/Counter Mode (Modo Galois/Contador). Modo de operación de cifrado por bloques que provee cifrado autenticado (AEAD), especificado en NIST SP 800-38D.
- GPU** Graphics Processing Unit (Unidad de Procesamiento Gráfico). Procesador diseñado para cómputo paralelo masivo, utilizado también en ataques de fuerza bruta contra funciones hash.
- hash** Resumen criptográfico o huella digital. Valor de longitud fija producido por una función hash criptográfica a partir de una entrada de longitud arbitraria. Cualquier modificación en la entrada produce un hash completamente diferente.
- HKDF** HMAC-based Key Derivation Function (Función de Derivación de Claves basada en HMAC). Mecanismo para derivar múltiples claves criptográficas a partir de una clave maestra y un contexto único.
- HMAC** Hash-based Message Authentication Code (Código de Autenticación de Mensajes basado en Hash). Construcción criptográfica que combina una función hash con una clave secreta para verificar integridad y autenticidad.

- HOTP** HMAC-Based One-Time Password (Contraseña de Un Solo Uso basada en HMAC). Algoritmo definido en RFC 4226 que genera códigos de un solo uso a partir de un secreto compartido y un contador.
- IETF** Internet Engineering Task Force. Organismo internacional que desarrolla y publica estándares de protocolos de Internet, incluyendo las RFC.
- IV** Initialization Vector (Vector de Inicialización). Valor aleatorio o único utilizado junto con una clave para iniciar un algoritmo de cifrado, garantizando que el mismo texto plano produzca diferentes textos cifrados.
- JWT** JSON Web Token. Estándar abierto (RFC 7519) para la creación de tokens de acceso firmados digitalmente en formato JSON, utilizados para autenticación y autorización.
- KEK** Key Encryption Key (Clave de Cifrado de Clave). En un esquema de envelope encryption, clave maestra utilizada exclusivamente para cifrar y descifrar las DEKs.
- legacy-use** Uso heredado. Clasificación del NIST para algoritmos o tamaños de clave que son aceptables para procesar información existente pero no recomendados para proteger información nueva.
- memory-hardness** Dureza de memoria. Propiedad de una función criptográfica que requiere una cantidad configurable de memoria durante su ejecución, encareciendo proporcionalmente los ataques con hardware paralelo.
- MFA** Multi-Factor Authentication (Autenticación por Múltiples Factores). Mecanismo que requiere la presentación de al menos dos categorías de evidencia de identidad: algo que el usuario sabe, posee o es.
- middleware** Capa de software intermedia que intercepta y procesa peticiones HTTP entre el cliente y la lógica de la aplicación, realizando funciones transversales como autenticación, registro de actividad o limitación de frecuencia.
- NIST** National Institute of Standards and Technology (Instituto Nacional de Estándares y Tecnología). Organismo del gobierno de Estados Unidos que publica estándares criptográficos y guías de seguridad.
- NOM** Norma Oficial Mexicana. Regulación técnica de observancia obligatoria emitida por dependencias del gobierno federal de México. NOM-151-SCFI-2016 establece los requisitos para la conservación de mensajes de datos.
- nonce** Número de uso único (del inglés number used once). Valor que no debe repetirse con la misma clave en operaciones criptográficas. En AES-GCM, su reutilización compromete catastróficamente el esquema.
- OCSP** Online Certificate Status Protocol (Protocolo de Estado de Certificado en Línea). Protocolo que permite consultar en tiempo real el estado de revocación de un certificado ante un servidor autorizado.
- OID** Object Identifier (Identificador de Objeto). Secuencia numérica única que designa un algoritmo, atributo u objeto en el estándar ASN.1. Ejemplo: 1.2.840.113549.1.1.11 identifica sha256WithRSAEncryption.

- OWASP** Open Worldwide Application Security Project. Proyecto abierto de referencia internacional en seguridad de aplicaciones web, que publica guías de mejores prácticas y listas de vulnerabilidades.
- PAdES-T** PDF Advanced Electronic Signatures with Timestamp. Formato de firma electrónica avanzada embebida dentro de un documento PDF, con sello de tiempo incorporado.
- PEM** Privacy-Enhanced Mail. Formato de codificación Base64 para certificados, claves criptográficas y listas de revocación, delimitado por encabezados como —BEGIN CERTIFICATE—.
- PHC** Password Hashing Competition (Competencia de Hashing de Contraseñas). Concurso criptográfico internacional celebrado entre 2013 y 2015 con 24 candidatos, cuyo ganador fue Argon2.
- PKCS#1** Public-Key Cryptography Standards #1. Estándar que define el formato y los esquemas de firma y cifrado RSA, incluyendo los esquemas de relleno (padding) v1.5 y PSS.
- PKI** Public Key Infrastructure (Infraestructura de Clave Pública). Conjunto de entidades, políticas y procedimientos para crear, gestionar, distribuir y revocar certificados digitales.
- PSC** Prestador de Servicios de Certificación. Entidad autorizada por la Secretaría de Economía de México para emitir certificados digitales, sellos de tiempo y constancias de conservación bajo la jerarquía ACR2-SE.
- rate limiting** Limitación de frecuencia. Mecanismo de seguridad que restringe el número de peticiones o intentos que un usuario puede realizar en un período de tiempo, previniendo ataques de fuerza bruta.
- RBAC** Role-Based Access Control (Control de Acceso Basado en Roles). Modelo de autorización que asigna permisos a roles predefinidos y asocia cada usuario a uno o más roles.
- REST** Representational State Transfer (Transferencia de Estado Representacional). Estilo arquitectónico para diseñar servicios web basado en recursos identificados por URLs y operados mediante métodos HTTP estándar.
- RFC** Request for Comments (Solicitud de Comentarios). Serie de documentos técnicos publicados por el IETF que definen estándares y protocolos de Internet. Cada RFC se identifica con un número único (por ejemplo, RFC 3161).
- RSA** Rivest-Shamir-Adleman. Algoritmo de criptografía asimétrica basado en la dificultad de factorizar números enteros grandes, utilizado para firma digital y cifrado de clave pública.
- salt** Sal. Valor aleatorio único que se concatena con la contraseña antes de aplicar la función hash, garantizando que contraseñas idénticas produzcan hashes diferentes.
- sandbox** Entorno de pruebas aislado que replica las funcionalidades de un sistema en producción sin afectar datos reales ni generar efectos legales.
- SAT** Servicio de Administración Tributaria. Órgano del gobierno de México responsable de la recaudación fiscal y emisor de la e.firma para personas físicas y morales.
- SHA-256** Secure Hash Algorithm de 256 bits. Función hash criptográfica de la familia SHA-2 estandarizada en FIPS 180-4, que produce un resumen de 256 bits (32 bytes) y proporciona 128 bits de resistencia a colisiones.

- SP** Special Publication (Publicación Especial). Serie de documentos técnicos del NIST que contienen guías, recomendaciones y estándares de seguridad. Ejemplo: NIST SP 800-57.
- TOTP** Time-Based One-Time Password (Contraseña de Un Solo Uso basada en Tiempo). Algoritmo definido en RFC 6238 que genera códigos temporales a partir de un secreto compartido y la hora actual, utilizado como segundo factor de autenticación.
- TSA** Time-Stamp Authority (Autoridad de Sellado de Tiempo). Entidad de confianza que emite sellos de tiempo criptográficos conforme al protocolo RFC 3161, acreditando la existencia de un documento en un momento determinado.
- WebAuthn** Web Authentication. Estándar del W3C y FIDO Alliance para autenticación sin contraseña basada en criptografía de clave pública, mediante llaves de seguridad físicas o biometría del dispositivo.
- X.509** Estándar de la ITU-T que define el formato de los certificados digitales de clave pública, incluyendo la estructura de la cadena de confianza, las extensiones y los perfiles de listas de revocación (CRL).

APÉNDICE A

Diagramas detallados de arquitectura

Este anexo presenta las versiones detalladas de los diagramas arquitectónicos cuya densidad de información requiere la orientación apaisada para mantener la legibilidad de todas sus etiquetas. Las figuras de este anexo se referencian desde las subsecciones correspondientes del cuerpo del Capítulo 3.

A.1 Vista detallada de Fronteras de Confianza

Modelo completo de defensa en profundidad: cuatro zonas de confianza (red pública, perímetro de aplicación, núcleo aplicativo, datos persistentes y secretos), tres fronteras con sus respectivos controles de seguridad (TLS 1.3, Rate Limiting, WAF/CORS, Autenticación JWT, Validación de input, Autorización RBAC, Conexiones TLS internas, Consultas parametrizadas vía sqlx, Cifrado en reposo mediante envelope encryption), y los servicios externos (Cincel PSC, Proveedor SMTP) ubicados en la zona no confiable con sus canales seguros explícitos.

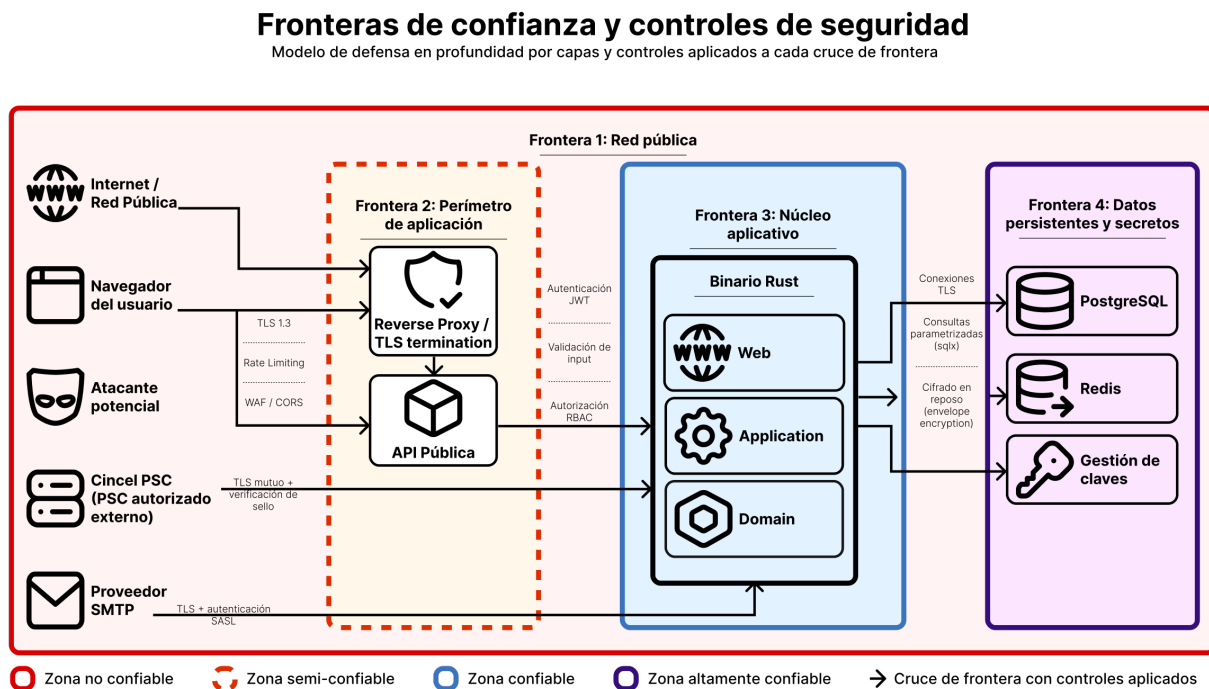


Figura A.1: Modelo de defensa en profundidad por capas y controles aplicados a cada cruce de frontera.

A.2 Arquitectura Hexagonal completa con puertos y adaptadores nombrados

Implementación detallada de la arquitectura hexagonal del prototipo: todos los puertos driving del sistema (RestApiPort sobre Axum, CommandLinePort sobre Clap, WebSocketPort sobre Axum WebSocket), todos los puertos driven (CaseRepository, DocumentRepository, DocumentSigner, TimestampService, NotificationDispatcher, AuditLogger, SessionStore) y sus adaptadores concretos correspondientes. Cada puerto se materializa como un trait de Rust en el crate domain, y cada adaptador como una struct con bloque impl en el crate infrastructure.

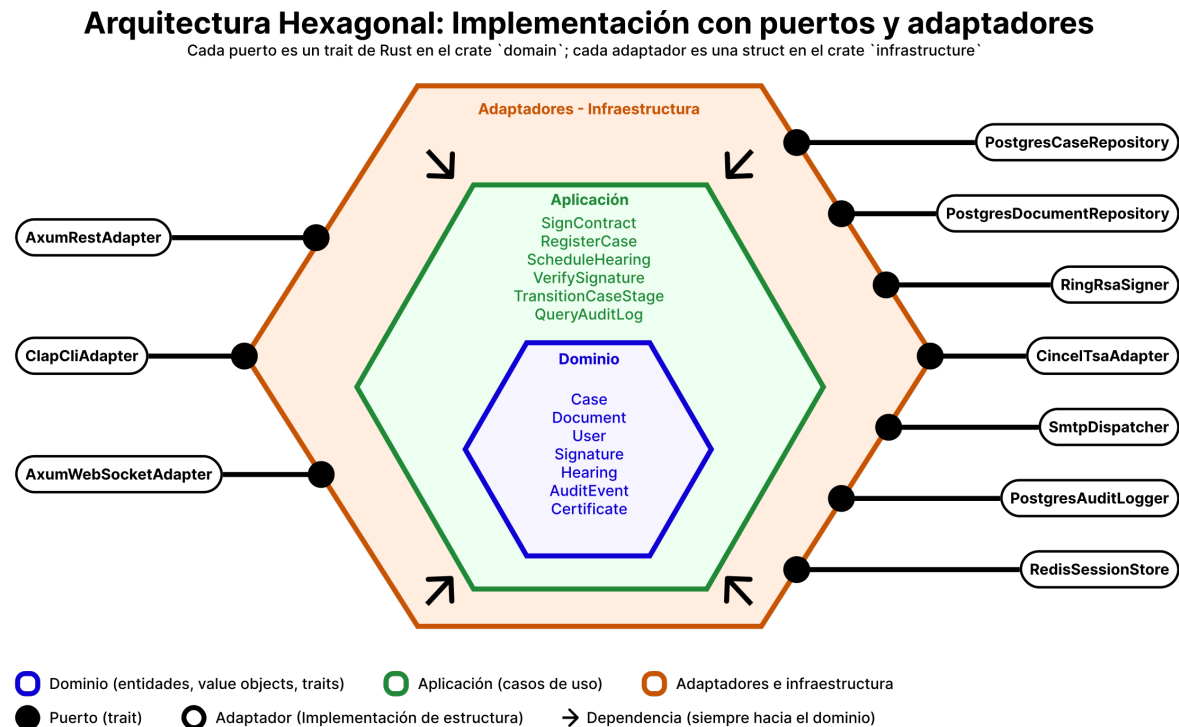


Figura A.2: Arquitectura hexagonal completa: cada puerto es un trait de Rust en el crate domain; cada adaptador es una struct en el crate infrastructure.